



1~100

▼ 1

▼ 英文

A company has an AWS Lambda function that creates image thumbnails from larger images. The Lambda function needs read and write access to an Amazon S3 bucket in the same AWS account. Which solutions will provide the Lambda function this access? (Choose two.)

A: Create an IAM user that has only programmatic access. Create a new access key pair. Add environmental variables to the Lambda function with the access key ID and secret access key. Modify the Lambda function to use the environmental variables at run time during communication with Amazon S3.

B: Generate an Amazon EC2 key pair. Store the private key in AWS Secrets Manager. Modify the Lambda function to retrieve the private key from Secrets Manager and to use the private key during communication with Amazon S3.

C: Create an IAM role for the Lambda function. Attach an IAM policy that allows access to the S3 bucket.

D: Create an IAM role for the Lambda function. Attach a bucket policy to the S3 bucket to allow access. Specify the function's IAM role as the principal.

E: Create a security group. Attach the security group to the Lambda function. Attach a bucket policy that allows access to the S3 bucket through the security group ID.

▼ 中文

一家公司有一个 AWS Lambda 函数，用于将较大的图片建立成缩图。此 Lambda 函数需要对相同 AWS 帐户中的 Amazon S3 储存桶拥有读写权限。

哪些解决方案可以为 Lambda 函数提供此存取权限？（选两项。）

A: 建立仅具有编程存取权限的 IAM 使用者。建立新的存取密钥对。使用存取金钥 ID 和秘密存取金钥将环境变数新增至 Lambda 函数。修改 Lambda 函数，使其在与 Amazon S3 通讯时在执行时使用环境变数。

B: 产生 Amazon EC2 金钥对。将私钥储存在 AWS Secrets Manager 中。修改 Lambda 函数以从 Secrets Manager 中检索私钥，并在与 Amazon S3 通讯时使用该私钥。

C: 为 Lambda 函数建立 IAM 角色。附加允许存取 S3 储存桶的 IAM 策略。

D: 为 Lambda 函数建立 IAM 角色。将储存桶策略附加到 S3 储存桶以允许存取。将函数的 IAM 角色指定为委託人。

E: 建立安全群组。将安全性群组附加到 Lambda 函数。附加储存桶策略，允许透过安全群组 ID 存取 S3 储存桶。

▼ 解答

CD

题目分析与解答

1. 考察的知识点

IAM 角色与策略的使用：如何为 AWS Lambda 函数赋予权限以访问其他 AWS 资源（如 S3 桶）。

安全性最佳实践：避免使用硬编码的凭证或不安全的访问方式。
资源策略（如S3桶策略）的应用：如何通过资源策略控制访问权限。

2. 选项分析

A. 创建一个仅具有编程访问权限的IAM用户，并使用环境变量存储访问密钥。

错误：使用IAM用户和访问密钥对的方式不符合安全性最佳实践。AWS建议使用IAM角色而不是硬编码的凭证。

环境变量存储访问密钥可能导致泄露风险。

B. 使用Amazon EC2密钥对，并通过Secrets Manager存储私钥。

错误：EC2密钥对用于SSH连接，而不是用于与S3桶通信。此选项与题目需求不相关。

Secrets Manager存储私钥的方式不适用于此场景。

C. 创建一个IAM角色并附加允许访问S3桶的IAM策略。

正确：这是为Lambda函数赋予权限的推荐方法。IAM角色可以安全地为Lambda函数提供所需的权限。

通过IAM策略可以精确控制对S3桶的访问权限。

D. 创建一个IAM角色并附加S3桶策略，指定IAM角色为主体。

正确：桶策略可以进一步限制访问权限，并指定IAM角色为主体以允许访问。

这种方法结合了IAM角色和资源策略的使用，是安全性最佳实践的一部分。

E. 使用安全组并通过桶策略允许访问。

错误：安全组用于控制网络流量，而不是用于控制对S3桶的访问权限。

桶策略无法通过安全组ID来控制访问权限。

3. 我选的答案

C

D

4. 官方答案

C

D

5. 与官方答案的比较

我的答案与官方答案一致。

没有需要重新思考的地方。

▼ 2

▼ 英文

A security engineer is configuring a new website that is named example.com. The security engineer wants to secure communications with the website by requiring users to connect to example.com through HTTPS.

Which of the following is a valid option for storing SSL/TLS certificates?

A. Custom SSL certificate that is stored in AWS Key Management Service (AWS KMS)

B. Default SSL certificate that is stored in Amazon CloudFront

C. Custom SSL certificate that is stored in AWS Certificate Manager (ACM)

D. Default SSL certificate that is stored in Amazon S3

▼ 中文

一位安全工程师正在配置一个名为 example.com 的新网站。这位安全工程师希望透过要求用户透过 HTTPS 连接到 example.com 来确保与该网站的通讯安全。

下列哪一项是储存 SSL/TLS 凭证的有效选项？

- A:储存在 AWS Key Management Service (AWS KMS) 中的自订 SSL 证书
- B:储存在 Amazon CloudFront 中的预设 SSL 凭证
- C:储存在 AWS凭证管理员 (ACM) 中的自订 SSL 凭证
- D:储存在 Amazon S3 中的预设 SSL 凭证

▼ 解答

C

1. 考察的知识点

本题考察的是如何在AWS中正确存储和管理SSL/TLS证书以实现HTTPS通信。

涉及的服务包括AWS Certificate Manager (ACM)、AWS Key Management Service (KMS)、Amazon CloudFront和Amazon S3。

2. 选项分析

A. Custom SSL certificate that is stored in AWS Key Management Service (AWS KMS)

错误：AWS KMS主要用于管理加密密钥，而不是存储SSL/TLS证书。虽然KMS可以管理加密密钥，但它并不是设计用来

存储和管理SSL/TLS证书的服务。

B. Default SSL certificate that is stored in Amazon CloudFront

错误：虽然Amazon CloudFront支持SSL/TLS证书，但它使用的是默认的SSL证书，无法存储自定义证书。自定义证书需

要通过AWS Certificate Manager (ACM)或其他方式配置。

C. Custom SSL certificate that is stored in AWS Certificate Manager (ACM)

正确：AWS Certificate Manager (ACM)是专门设计用于管理SSL/TLS证书的服务。它支持存储、分发和自动续订SSL/TLS

证书，非常适合用于HTTPS通信。

D. Default SSL certificate that is stored in Amazon S3

错误：Amazon S3是对象存储服务，不适合存储SSL/TLS证书。虽然可以将证书文件存储在S3中，但这不是推荐的做

法，也无法直接用于HTTPS通信。

3. 我的选择

我选择的答案是：C

4. 官方答案

官方正确答案是：C

5. 与官方答案的比较

我的答案与官方答案一致，没有差异。

▼ 3

▼ 英文

A security engineer needs to develop a process to investigate and respond to potential security events on a company's Amazon EC2 instances. All the EC2 instances are backed by Amazon Elastic Block Store (Amazon EBS). The company uses AWS Systems Manager to manage all the EC2 instances and has installed Systems Manager Agent (SSM Agent) on all the EC2 instances.

The process that the security engineer is developing must comply with AWS security best practices and must meet the following requirements:

A compromised EC2 instance's volatile memory and non-volatile memory must be preserved for forensic purposes.

A compromised EC2 instance's metadata must be updated with corresponding incident

ticket information.

A compromised EC2 instance must remain online during the investigation but must be isolated to prevent the spread of malware.

Any investigative activity during the collection of volatile data must be captured as part of the process.

Which combination of steps should the security engineer take to meet these requirements with the LEAST operational overhead? (Choose three.)

A. Gather any relevant metadata for the compromised EC2 instance. Enable termination protection. Isolate the instance by updating the instance's security groups to restrict access. Detach the instance from any Auto Scaling groups that the instance is a member of. Deregister the instance from any Elastic Load Balancing (ELB) resources.

B. Gather any relevant metadata for the compromised EC2 instance. Enable termination protection. Move the instance to an isolation subnet that denies all source and destination traffic. Associate the instance with the subnet to restrict access. Detach the instance from any Auto Scaling groups that the instance is a member of. Deregister the instance from any Elastic Load Balancing (ELB) resources.

C. Use Systems Manager Run Command to invoke scripts that collect volatile data.

D. Establish a Linux SSH or Windows Remote Desktop Protocol (RDP) session to the compromised EC2 instance to invoke scripts that collect volatile data.

E. Create a snapshot of the compromised EC2 instance's EBS volume for follow-up investigations. Tag the instance with any relevant metadata and incident ticket information.

F. Create a Systems Manager State Manager association to generate an EBS volume snapshot of the compromised EC2 instance. Tag the instance with any relevant metadata and incident ticket information.

▼ 中文

一位安全工程师需要开发一个流程来调查和回应公司 Amazon EC2 执行个体上的潜在安全事件。所有 EC2 执行个体均由 Amazon Elastic Block Store (Amazon EBS) 支援。该公司使用 AWS Systems Manager 管理所有 EC2 实例，并在所有 EC2 执行个体上安装了 Systems Manager 代理程式 (SSM 代理程式)。

安全工程师正在开发的流程必须符合 AWS 安全最佳实践，并且必须满足以下要求：

必须保留受损 EC2 执行个体的挥发性记忆体和非挥发性记忆体以用于取证。

必须使用对应的事件工单资讯更新受损 EC2 执行个体的元资料。

受损 EC2 执行个体在调查期间必须保持在线，但必须进行隔离以防止恶意软体传播。

在收集易失性资料期间进行的任何调查活动都必须作为流程的一部分进行捕获。

安全工程师应采取哪些步骤组合来以最少的营运开销满足这些要求？（选择三项。）

A: 收集受损 EC2 执行个体的所有相关元资料。启用终止保护。透过更新执行个体的安全性群组来隔离执行个体以限制存取。将执行个体与其所属的任何 Auto Scaling 群组分离。从所有 Elastic Load Balancing (ELB) 资源中取消注册该执行个体。

B: 收集受损 EC2 执行个体的所有相关元资料。启用终止保护。将执行个体移至拒绝所有来源和目标流量的隔离子网路。将实例与子网路关联以限制存取。将执行个体与其所属的任何 Auto Scaling 群组分离。从所有 Elastic Load Balancing (ELB) 资源中取消注册该执行个体。

C: 呼叫收集挥发性资料的脚本。

D: 与受损的 EC2 执行个体建立 Linux SSH 或 Windows 远端桌面协定 (RDP) 会话，以呼叫收集挥发性资料的脚本。

E:建立受感染 EC2 执行个体的 EBS 磁碟区快照，以便后续调查。使用任何相关元资料和事件工单资讯标记该实例。

F:建立 Systems Manager 状态管理器关联，以产生受感染 EC2 执行个体的 EBS 磁碟区快照。使用任何相关元资料和事件工单资讯标记该实例。

▼ 解答

ACE

1. 考察的知识点

使用AWS Systems Manager进行实例管理和数据收集。

隔离受感染的EC2实例以防止进一步传播。

遵循AWS安全最佳实践进行事件响应和取证。

收集易失性数据和非易失性数据以进行后续调查。

2. 选项分析

A.

正确：收集元数据是取证的关键步骤。

正确：启用终止保护可以防止实例被意外删除。

正确：更新安全组以隔离实例是防止恶意软件传播的有效方法。

正确：从Auto Scaling组和ELB资源中分离实例可以确保实例不会被自动替换或继续处理流量。

B.

错误：将实例移动到一个完全隔离的子网会导致实例无法保持在线状态，违反了题目要求。

C.

正确：使用Systems Manager Run Command可以远程收集易失性数据，同时记录所有操作，符合取证要求。

D.

错误：直接使用SSH或RDP会增加安全风险，并且无法记录所有操作，不符合AWS安全最佳实践。

E.

正确：创建EBS卷快照可以保存非易失性数据以供后续调查。

正确：标记实例以记录事件工单信息是取证的必要步骤。

F.

错误：使用State Manager生成快照会增加操作复杂性，不符合“最少操作开销”的要求。

▼ 4

▼ 英文

A company has an organization in AWS Organizations. The company wants to use AWS CloudFormation StackSets in the organization to deploy various AWS design patterns into environments. These patterns consist of Amazon EC2 instances, Elastic Load Balancing (ELB) load balancers, Amazon RDS databases, and Amazon Elastic Kubernetes Service (Amazon EKS) clusters or Amazon Elastic Container Service (Amazon ECS) clusters. Currently, the company's developers can create their own CloudFormation stacks to increase the overall speed of delivery. A centralized CI/CD pipeline in a shared services AWS account deploys each CloudFormation stack.

The company's security team has already provided requirements for each service in accordance with internal standards. If there are any resources that do not comply with the internal standards, the security team must receive notification to take appropriate action. The security team must implement a notification solution that gives developers the ability to maintain the same overall delivery speed that they currently have.

Which solution will meet these requirements in the MOST operationally efficient way?

A. Create an Amazon Simple Notification Service (Amazon SNS) topic. Subscribe the security team's email addresses to the SNS topic. Create a custom AWS Lambda function that will run the `aws cloudformation validate-template` AWS CLI command on all CloudFormation templates before the build stage in the CI/CD pipeline. Configure the CI/CD pipeline to publish a notification to the SNS topic if any issues are found.

B. Create an Amazon Simple Notification Service (Amazon SNS) topic. Subscribe the security team's email addresses to the SNS topic. Create custom rules in CloudFormation Guard for each resource configuration. In the CI/CD pipeline, before the build stage, configure a Docker image to run the `cfn-guard` command on the CloudFormation template. Configure the CI/CD pipeline to publish a notification to the SNS topic if any issues are found.

C. Create an Amazon Simple Notification Service (Amazon SNS) topic and an Amazon Simple Queue Service (Amazon SQS) queue. Subscribe the security team's email addresses to the SNS topic. Create an Amazon S3 bucket in the shared services AWS account. Include an event notification to publish to the SQS queue when new objects are added to the S3 bucket. Require the developers to put their CloudFormation templates in the S3 bucket. Launch EC2 instances that automatically scale based on the SQS queue depth. Configure the EC2 instances to use CloudFormation Guard to scan the templates and deploy the templates if there are no issues. Configure the CI/CD pipeline to publish a notification to the SNS topic if any issues are found.

D. Create a centralized CloudFormation stack set that includes a standard set of resources that the developers can deploy in each AWS account. Configure each CloudFormation template to meet the security requirements. For any new resources or configurations, update the CloudFormation template and send the template to the security team for review. When the review is completed, add the new CloudFormation stack to the repository for the developers to use.

▼ 中文

一家公司在 AWS Organizations 中设有一个组织。该公司希望在组织中使用 AWS CloudFormation StackSets 将各种 AWS 设计模式部署到环境中。这些模式包括 Amazon EC2 执行个体、Elastic Load Balancing (ELB) 负载均衡器、Amazon RDS 资料库以及 Amazon Elastic Kubernetes Service (Amazon EKS) 丛集或 Amazon Elastic Container Service (Amazon ECS) 丛集。

目前，该公司的开发人员可以创建自己的 CloudFormation 堆叠来提高整体交付速度。共用服务 AWS 帐户中的集中式 CI/CD 管道负责部署每个 CloudFormation 堆叠。

该公司的安全团队已根据内部标准为每项服务提供了要求。如果有任何资源不符合内部标准，安全团队必须收到通知以采取适当的措施。安全团队必须实施通知解决方案，使开发人员能够保持与目前相同的整体交付速度。[哪一种解决方案能够以最高效的方式满足这些要求？](#)

A: 建立 Amazon Simple Notification Service (Amazon SNS) 主题。将安全团队的电子邮件地址订阅至该 SNS 主题。建立一个自订 AWS Lambda 函数，该函数将在 CI/CD 管道的建置阶段之前对所有 CloudFormation 范本执行 `aws cloudformation valid-template` AWS CLI 命令。配置 CI/CD 管道，以便在发现任何问题时向 SNS 主题发布通知。

B: 建立 Amazon Simple Notification Service (Amazon SNS) 主题。将安全团队的电子邮件地址订阅至该 SNS 主题。在 CloudFormation Guard 中为每个资源配置建立自订规则。在 CI/CD 管道中，在建置阶段之前，配置 Docker 映像以在 CloudFormation 范本上执行 `cfn-guard` 命令。配置 CI/CD 管道，以便在发现任何问题时向 SNS 主题发布通知。

C:建立 Amazon Simple Notification Service (Amazon SNS) 主题和 Amazon Simple Queue Service (Amazon SQS) 队列。使用安全团队的电子邮件地址订阅 SNS 主题。在共用服务 AWS 帐户中建立 Amazon S3 储存桶。新增事件通知，当新物件新增至 S3 储存桶时，发布到 SQS 队列。要求开发人员将其 CloudFormation 范本放入 S3 储存桶。启动根据 SQS 队列深度自动扩展的 EC2 执行个体。配置 EC2 执行个体以使用 CloudFormation Guard 扫描模板，并在没有问题的情况下部署模板。配置 CI/CD 管道，以便在发现任何问题时向 SNS 主题发布通知。

D:建立一个集中式 CloudFormation 堆叠集，其中包含一组标准资源，开发人员可以在每个 AWS 帐户中部署这些资源。配置每个 CloudFormation 范本以满足安全要求。对于任何新的资源或配置，请更新 CloudFormation 范本并将范本传送给安全团队进行审核。审核完成后，将新的 CloudFormation 堆叠新增至储存库，供开发人员使用。

▼ 解答

B

题目分析与解答

1. 考察的知识点

AWS CloudFormation StackSets的使用
CI/CD管道的集成与自动化
CloudFormation模板的验证与合规性检查
通知机制的实现 (Amazon SNS)
CloudFormation Guard的使用

2. 选项分析

A. 创建SNS主题并使用Lambda函数验证模板

分析：

使用Lambda函数运行 `aws cloudformation validate-template` 命令可以验证模板的语法，但无法检查模板是否符合安全要求或内部标准。

虽然可以发送通知，但无法满足对资源配置合规性检查的需求。此选项错误。

B. 创建SNS主题并使用CloudFormation Guard验证模板

分析：

CloudFormation Guard是专门用于检查CloudFormation模板是否符合预定义规则的工具，非常适合用于合规性检查。

在CI/CD管道中集成CloudFormation Guard可以自动化模板验证，同时保持开发速度。

通过SNS发送通知满足了安全团队的需求。

此选项正确。

C. 使用S3、SQS和EC2实例进行模板验证

分析：

此选项设计复杂，涉及多个服务（S3、SQS、EC2），增加了操作复杂性和成本。

虽然可以实现模板验证，但不如CloudFormation Guard直接且高效。

此选项错误。

D. 使用集中式StackSet并手动审核模板

分析：

手动审核模板会显著降低开发速度，与题目要求的“保持开发速度”相悖。

此选项错误。

3. 我选的答案

B

4. 官方答案

B

5. 与官方答案比较

我的答案与官方答案一致。

理由：CloudFormation Guard是专门设计用于验证模板合规性的工具，能够满足题目中对安全性和开发速度的要求，同时通过SNS实现通知功能。

▼ 5

▼ 英文

A company is migrating one of its legacy systems from an on-premises data center to AWS. The application server will run on AWS, but the database must remain in the on-premises data center for compliance reasons. The database is sensitive to network latency. Additionally, the data that travels between the on-premises data center and AWS must have IPsec encryption.

Which combination of AWS solutions will meet these requirements? (Choose two.)

- A: AWS Site-to-Site VPN
- B: AWS Direct Connect
- C: AWS VPN CloudHub
- D: VPC peering
- E: NAT gateway

▼ 中文

一家公司正在将其一个旧系统从本地资料中心迁移到 AWS。应用程序服务器将在 AWS 上运行，但出于合规性原因，**资料库必须保留在本地资料中心**。资料库对网路延迟非常敏感。此外，**在本机资料中心和 AWS 之间传输的资料必须采用 IPsec 加密**。

哪种 AWS 解决方案组合可以满足这些要求？（选两项。）

- A: AWS 站点到站点 VPN
- B: AWS Direct Connect
- C: AWS VPN CloudHub
- D: VPC 对等连接
- E: NAT 闸道

▼ 解答

AB

1. 考察的知识点

网络连接选项：了解如何在AWS与本地数据中心之间建立安全、低延迟的连接。

加密通信：确保数据在传输过程中通过IPsec协议进行加密。

AWS服务选择：熟悉AWS Direct Connect和AWS Site-to-Site VPN的功能和适用场景。

2. 选项分析

A. AWS Site-to-Site VPN

正确：AWS Site-to-Site VPN支持IPsec加密，可以在AWS和本地数据中心之间建立安全的通信通道。

适用于需要加密通信的场景，但可能会受到网络延迟的影响。

B. AWS Direct Connect

正确：AWS Direct Connect提供专用的低延迟网络连接，适合对网络延迟敏感的应用。

虽然Direct Connect本身不提供加密，但可以与AWS Site-to-Site VPN结合使用以实现IPsec加密。

C. AWS VPN CloudHub

错误：AWS VPN CloudHub主要用于连接多个站点（如多个分支机构），不适合单一站点到AWS的连接场景。

D. VPC peering

错误：VPC Peering用于连接两个AWS VPC，无法连接本地数据中心与AWS。

E. NAT gateway

错误：NAT Gateway用于管理出站流量的网络地址转换，与本题的需求无关。

▼ 6

▼ 英文

A company has an application that uses dozens of Amazon DynamoDB tables to store data. Auditors find that the tables do not comply with the company's data protection policy.

The company's retention policy states that all data must be backed up twice each month: once at midnight on the 15th day of the month and again at midnight on the 25th day of the month. The company must retain the backups for 3 months.

Which combination of steps should a security engineer take to meet these requirements? (Choose two.)

A: Use the DynamoDB on-demand backup capability to create a backup plan. Configure a lifecycle policy to expire backups after 3 months.

B: Use AWS DataSync to create a backup plan. Add a backup rule that includes a retention period of 3 months.

C: Use AWS Backup to create a backup plan. Add a backup rule that includes a retention period of 3 months.

D: Set the backup frequency by using a cron schedule expression. Assign each DynamoDB table to the backup plan.

E: Set the backup frequency by using a rate schedule expression. Assign each DynamoDB table to the backup plan.

▼ 中文

一家公司有一个应用程序使用数十个 Amazon DynamoDB 表来储存资料。审计人员发现这些表格不符合公司的资料保护政策。

该公司的保留政策规定，**所有资料必须每月备份两次**：一次在**每月 15 日午夜**，另一次在**每月 25 日午夜**。公司必须将备份保留 3 个月。

安全工程师应该采取哪些步骤组合来满足这些要求？（选两项。）

A: 使用 DynamoDB 按需备份功能建立备份计划。配置生命周期策略，使备份在 3 个月后过期。

B: 使用 AWS DataSync 建立备份计划。新增包含 3 个月保留期的备份规则。

C: 使用 AWS Backup 建立备份计划。新增包含 3 个月保留期的备份规则。

D: 使用 cron 计划表达式设定备份频率。将每个 DynamoDB 表格。分配给备份计划。

E: 使用速率计划表达式设定备份频率。将每个 DynamoDB 表格分配给备份计划。

▼ 解答

CD

1. 考察的知识点

Amazon DynamoDB的备份与恢复功能。

AWS Backup服务的使用，包括备份计划和生命周期管理。
备份频率的调度表达式（cron和rate）的使用。

2. 选项分析

- A. 使用 DynamoDB 的按需备份功能创建备份计划。配置生命周期策略以在3个月后过期备份。
错误：DynamoDB的按需备份功能可以手动创建备份，但无法自动化备份计划，也无法直接配置生命周期策略。
- B. 使用 AWS DataSync 创建备份计划。添加一个包含3个月保留期的备份规则。
错误：AWS DataSync主要用于数据迁移和同步，而不是用于创建备份计划或管理备份生命周期。
- C. 使用 AWS Backup 创建备份计划。添加一个包含3个月保留期的备份规则。
正确：AWS Backup支持DynamoDB表的备份，可以创建备份计划并设置保留期为3个月。
- D. 使用 cron 调度表达式设置备份频率。将每个 DynamoDB 表分配到备份计划中。
正确：AWS Backup支持使用cron表达式设置备份频率，可以精确地满足题目要求的备份时间（每月15日和25日的午夜）。
- E. 使用 rate 调度表达式设置备份频率。将每个 DynamoDB 表分配到备份计划中。
错误：rate表达式用于设置固定间隔的备份频率（如每小时或每天），无法满足题目中指定的具体日期和时间要求。

▼ 7

▼ 英文

A company needs a security engineer to implement a scalable solution for multi-account authentication and authorization. The solution should not introduce additional user-managed architectural components. Native AWS features should be used as much as possible. The security engineer has set up AWS Organizations with all features activated and AWS IAM Identity Center (AWS Single Sign-On) enabled. Which additional steps should the security engineer take to complete the task?

A: Use AD Connector to create users and groups for all employees that require access to AWS accounts. Assign AD Connector groups to AWS accounts and link to the IAM roles in accordance with the employees' job functions and access requirements. Instruct employees to access AWS accounts by using the AWS Directory Service user portal.

B: Use an IAM Identity Center default directory to create users and groups for all employees that require access to AWS accounts. Assign groups to AWS accounts and link to permission sets in accordance with the employees' job functions and access requirements. Instruct employees to access AWS accounts by using the IAM Identity Center user portal.

C: Use an IAM Identity Center default directory to create users and groups for all employees that require access to AWS accounts. Link IAM Identity Center groups to the IAM users present in all accounts to inherit existing permissions. Instruct employees to access AWS accounts by using the IAM Identity Center user portal.

D: Use AWS Directory Service for Microsoft Active Directory to create users and groups for all employees that require access to AWS accounts. Enable AWS Management Console access in the created directory and specify IAM Identity Center as a source of information for integrated accounts and permission sets. Instruct employees to access AWS accounts by using the AWS Directory Service user portal.

▼ 中文

一家公司需要一名安全工程师来实施一个可扩展的多帐户身份验证和授权解决方案。该解决方案不应引入额外的用户管理架构组件。应尽可能使用原生 AWS 功能。此安全工程师已设定

AWS Organizations，并启动了所有功能，并启用了 AWS IAM Identity Center（AWS 单一登入）。

安全工程师还需要采取哪些额外步骤来完成这项任务？

A:使用 AD Connector 为所有需要存取 AWS 帐户的员工建立使用者和群组。根据员工的工作职能和存取要求，将 AD Connector 群组指派给 AWS 帐户并关联到 IAM 角色。指导员工使用 AWS Directory Service 使用者入口网站存取 AWS 帐户。

B:使用 IAM Identity Center 预设目录为所有需要存取 AWS 帐户的员工建立使用者和群组。根据员工的工作职能和存取要求，将群组指派给 AWS 帐户并关联到权限集。指导员工使用 IAM Identity Center 使用者入口网站存取 AWS 帐户。

C:使用 IAM Identity Center 预设目录为所有需要存取 AWS 帐户的员工建立使用者和群组。将 IAM Identity Center 群组关联到所有帐户中的 IAM 用户，以继承现有权限。指导员工使用 IAM Identity Center 使用者入口网站存取 AWS 帐户。

D:使用适用于 Microsoft Active Directory 的 AWS Directory Service 为所有需要存取 AWS 帐户的员工建立使用者和群组。在建立的目录中启用 AWS 管理控制台存取权限，并指定 IAM Identity Center 作为整合帐户和权限集的资料来源。指导员工使用 AWS Directory Service 使用者入口网站存取 AWS 帐户。

▼ 解答

B

1. 考察的知识点

本题考察的是AWS Organizations与IAM Identity Center（AWS Single Sign-On）的集成使用，以及如何实现跨账户的身份认证和授权。

重点在于使用原生AWS功能实现多账户的用户管理和权限分配，同时避免引入额外的用户管理组件。

2. 选项分析

A. 使用AD Connector为所有需要访问AWS账户的员工创建用户和组。

错误：AD Connector是用于连接本地Active Directory与AWS的工具，但题目要求使用原生AWS功能，并且不引入额外的用

户管理组件。AD Connector并非原生AWS功能，且需要额外的配置和管理。

B. 使用IAM Identity Center默认目录为所有需要访问AWS账户的员工创建用户和组。

正确：IAM Identity Center默认目录是原生AWS功能，支持创建用户和组，并通过权限集

（Permission Sets）分配跨账户的访问权限。员工可以通过IAM Identity Center用户门户访问AWS账户，完全符合题目要求。

C. 将IAM Identity Center组链接到所有账户中现有的IAM用户以继承现有权限。

错误：IAM Identity Center的权限管理是基于权限集（Permission Sets）而非直接继承IAM用户的权限。此选项的描述与IAM Identity Center的实际功能不符。

D. 使用AWS Directory Service for Microsoft Active Directory为所有需要访问AWS账户的员工创建用户和组。

错误：AWS Directory Service for Microsoft Active Directory是一个托管的Active Directory服务，虽然可以与IAM Identity

Center集成，但它并非题目要求的“原生AWS功能”，且引入了额外的用户管理组件。

▼ 8

▼ 英文

A company has deployed Amazon GuardDuty and now wants to implement automation for potential threats. The company has decided to start with RDP brute force attacks that come from Amazon EC2 instances in the company's AWS environment. A security engineer needs to implement a solution that blocks the detected communication from a suspicious instance until investigation and potential remediation can occur.

Which solution will meet these requirements?

A. Configure GuardDuty to send the event to an Amazon Kinesis data stream. Process the event with an Amazon Kinesis Data Analytics for Apache Flink application that sends a notification to the company through Amazon Simple Notification Service (Amazon SNS). Add rules to the network ACL to block traffic to and from the suspicious instance.

B. Configure GuardDuty to send the event to Amazon EventBridge. Deploy an AWS WAF web ACL. Process the event with an AWS Lambda function that sends a notification to the company through Amazon Simple Notification Service (Amazon SNS) and adds a web ACL rule to block traffic to and from the suspicious instance.

C. Enable AWS Security Hub to ingest GuardDuty findings and send the event to Amazon EventBridge. Deploy AWS Network Firewall. Process the event with an AWS Lambda function that adds a rule to a Network Firewall firewall policy to block traffic to and from the suspicious instance.

D. Enable AWS Security Hub to ingest GuardDuty findings. Configure an Amazon Kinesis data stream as an event destination for Security Hub. Process the event with an AWS Lambda function that replaces the security group of the suspicious instance with a security group that does not allow any connections.

▼ 中文

一家公司已部署 Amazon GuardDuty，現在希望實現潛在威脅的自動化處理。該公司決定首先應對來自其 AWS 環境中 Amazon EC2 執行個體的 RDP 暴力破解攻擊。一位安全工程師需要實施一項解決方案，阻止檢測到的來自可疑實例的通信，直到調查和潛在補救措施得以實施。哪種解決方案能夠滿足這些要求？

A: 配置 GuardDuty 將事件傳送到 Amazon Kinesis 資料流。使用適用於 Apache Flink 的 Amazon Kinesis Data Analytics 應用程式處理此事件，該應用程式透過 Amazon Simple Notification Service (Amazon SNS) 向本公司發送通知。在網路 ACL 中新增規則，以阻止往返於可疑實例的流量。

B: 配置 GuardDuty 將事件傳送至 Amazon EventBridge。部署 AWS WAF Web ACL。使用 AWS Lambda 函數處理此事件，該函數透過 Amazon Simple Notification Service (Amazon SNS) 向本公司發送通知，並新增 Web ACL 規則以阻止往返於可疑執行個體的流量。

C: 啟用 AWS Security Hub 來提取 GuardDuty 發現結果並將事件傳送至 Amazon EventBridge。部署 AWS 網路防火牆。使用 AWS Lambda 函數處理事件，該函數將規則新增至網路防火牆的防火牆策略中，以阻止往返可疑執行個體的流量。

D: 啟用 AWS Security Hub 來擷取 GuardDuty 發現結果。將 Amazon Kinesis 資料流配置為 Security Hub 的事件目標。使用 AWS Lambda 函數處理事件，該函數將可疑執行個體的安全性群組替換為不允許任何連線的安全群組。

▼ 解答

C

1. 考察的知识点

Amazon GuardDuty的威胁检测功能。

事件处理与自动化响应（EventBridge、Lambda、Security Hub等）。

网络安全控制（AWS Network Firewall、Security Group、ACL等）。

2. 选项分析

A. 配置 GuardDuty 将事件发送到 Amazon Kinesis 数据流，并使用 Kinesis Data Analytics 处理事件。

错误原因：

虽然可以通过 Kinesis 数据流处理事件，但使用网络 ACL 来阻止流量并不适合动态阻止特定实例的通信，因为网络 ACL是针对整个子网的规则，无法针对单个实例进行精确控制。

此方案复杂且不符合题目要求的最佳实践。

B. 配置 GuardDuty 将事件发送到 Amazon EventBridge，并使用 AWS WAF web ACL 处理事件。

错误原因：

AWS WAF主要用于保护Web应用程序免受恶意流量攻击，而不是用于阻止EC2实例之间的通信。

题目要求阻止可疑实例的通信，WAF web ACL不适合此场景。

C. 启用 AWS Security Hub 以摄取 GuardDuty 发现，并将事件发送到 Amazon EventBridge，使用 AWS Network Firewall阻止流量。

正确原因：

Security Hub可以整合GuardDuty的发现，并通过EventBridge触发自动化响应。

AWS Network Firewall是专门设计用于管理和阻止网络流量的工具，能够动态添加规则以阻止特定实例的通信。

此方案符合题目要求，能够有效阻止可疑实例的通信。

D. 启用 AWS Security Hub，并使用 Lambda 替换可疑实例的安全组。

错误原因：

虽然替换安全组可以阻止实例的通信，但此方法可能会影响实例的其他正常功能，且操作复杂。

相比使用AWS Network Firewall动态添加规则，此方法不够优雅且不符合最佳实践。

▼ 9

▼ 英文

A company has an AWS account that hosts a production application. The company receives an email notification that Amazon GuardDuty has detected an Impact:IAMUser/AnomalousBehavior finding in the account. A security engineer needs to run the investigation playbook for this security incident and must collect and analyze the information without affecting the application.

Which solution will meet these requirements MOST quickly?

A. Log in to the AWS account by using read-only credentials. Review the GuardDuty finding for details about the IAM credentials that were used. Use the IAM console to add a DenyAll policy to the IAM principal.

B. Log in to the AWS account by using read-only credentials. Review the GuardDuty finding to determine which API calls initiated the finding. Use Amazon Detective to review the API calls in context.

C. Log in to the AWS account by using administrator credentials. Review the GuardDuty finding for details about the IAM credentials that were used. Use the IAM console to add a DenyAll policy to the IAM principal.

D. Log in to the AWS account by using read-only credentials. Review the GuardDuty finding to determine which API calls initiated the finding. Use AWS CloudTrail Insights and AWS CloudTrail Lake to review the API calls in context.

▼ 中文

一家公司拥有一个託管生产应用程序的 AWS 帐户。该公司收到一封电子邮件通知，告知Amazon GuardDuty 在该帐户中侦测到了Impact:IAMUser/AnomalousBehavior 发现。一位安全工程师需要针对此安全事件执行调查手册，并且必须在**不影响应用程序的情况下收集和分析资讯**。

哪一种解决方案能够最快地满足这些要求？

A:使用唯读凭证登入 AWS 帐户。查看 GuardDuty 检测结果，以了解所用 IAM 凭证的详细资讯。使用 IAM 控制台将 DenyAll 政策新增至 IAM 委託人。

B:使用唯读凭证登入 AWS 帐户。查看 GuardDuty 侦测结果，确定哪些 API 呼叫触发了该侦测结果。使用 Amazon Detective 在上下文中查看 API 呼叫。

C:使用管理员凭证登入 AWS 帐户。查看 GuardDuty 检测结果，以了解所用 IAM 凭证的详细资讯。使用 IAM 控制台将 DenyAll 政策新增至 IAM 委託人。

D:使用唯读凭证登入 AWS 帐户。查看 GuardDuty 侦测结果，确定哪些 API 呼叫触发了该侦测结果。使用 AWS CloudTrail Insights 和 AWS CloudTrail Lake 在上下文中查看 API 呼叫。

▼ 解答

B

1. 考察的知识点

Amazon GuardDuty的功能和使用场景。

如何调查和响应安全事件。

Amazon Detective的作用和使用方法。

IAM权限管理和安全事件处理的最佳实践。

2. 选项分析

A. Log in to the AWS account by using read-only credentials. Review the GuardDuty finding for details about the IAM

credentials that were used. Use the IAM console to add a DenyAll policy to the IAM principal.

错误：虽然使用只读凭证可以避免对生产环境的影响，但直接添加DenyAll策略可能会导致误操作，影响正常的IAM用

户或角色功能。

此外，该选项没有提到如何分析API调用的上下文信息，这对于调查事件至关重要。

B. Log in to the AWS account by using read-only credentials. Review the GuardDuty finding to determine which API calls

initiated the finding. Use Amazon Detective to review the API calls in context.

正确：使用只读凭证可以避免对生产环境的影响。

Amazon Detective是专门设计用于分析安全事件的工具，[可以提供API调用的上下文信息，帮助快速调查事件。](#)

这是最符合题目要求的解决方案。

C. Log in to the AWS account by using administrator credentials. Review the GuardDuty finding for details about the IAM

credentials that were used. Use the IAM console to add a DenyAll policy to the IAM principal.

错误：使用管理员凭证可能会增加安全风险，尤其是在处理安全事件时。

直接添加DenyAll策略可能会导致误操作，影响正常的IAM用户或角色功能。

没有提到如何分析API调用的上下文信息，这对于调查事件至关重要。

D. Log in to the AWS account by using read-only credentials. Review the GuardDuty finding to determine which API calls

initiated the finding. Use AWS CloudTrail Insights and AWS CloudTrail Lake to review the API calls in context.

错误：虽然CloudTrail Insights和CloudTrail Lake可以提供API调用的上下文信息，但[它们的功能不如Amazon Detective专注于安全事件调查。](#)

Amazon Detective是专门设计用于分析安全事件的工具，使用它可以更快速地满足题目要求。

▼ 10

▼ 英文

Company A has an AWS account that is named Account A. Company A recently acquired Company B, which has an AWS account that is named Account B. Company B stores its files in an Amazon S3 bucket. The administrators need to give a user from Account A full access to the S3 bucket in Account B.

After the administrators adjust the IAM permissions for the user in Account A to access the S3 bucket in Account B, the user still cannot access any files in the S3 bucket.

Which solution will resolve this issue?

A: In Account B, create a bucket ACL to allow the user from Account A to access the S3 bucket in Account B.

B: In Account B, create an object ACL to allow the user from Account A to access all the objects in the S3 bucket in Account B.

C: In Account B, create a bucket policy to allow the user from Account A to access the S3 bucket in Account B.

D: In Account B, create a user policy to allow the user from Account A to access the S3 bucket in Account B.

▼ 中文

A 公司有一个名为「帐户 A」的 AWS 帐户。A 公司最近收购了 B 公司，而 B 公司有一个名为「帐户 B」的 AWS 帐户。B 公司将其档案储存在 Amazon S3 储存桶中。管理员需要授予帐户 A 中的使用者对帐户 B 中 S3 储存桶的完全存取权。

管理员调整了帐户 A 使用者存取帐户 B 中 S3 储存桶的 IAM 权限后，该使用者仍然无法存取 S3 储存桶中的任何档案。

哪种解决方案可以解决这个问题？

A: 帐户 B 中，建立一个储存桶 ACL，以允许帐户 A 中的使用者存取帐户 B 中的 S3 储存桶。

B: 在帐户 B 中，建立一个物件 ACL，以允许帐户 A 中的使用者存取帐户 B 中 S3 储存桶中的所有物件。

C: 在帐户 B 中，建立一个储存桶策略，允许帐户 A 中的使用者存取帐户 B 中的 S3 储存桶。

D: 在帐户 B 中，建立使用者策略，允许帐户 A 中的使用者存取帐户 B 中的 S3 储存桶。

▼ 解答

C

1. 考察的知识点

跨账户访问 Amazon S3 的权限管理。

理解 IAM 权限、S3 Bucket Policy 和 ACL 的作用及区别。

2. 选项分析

A. 在帐户 B 中，创建一个 bucket ACL，以允许帐户 A 的用户访问帐户 B 中的 S3 bucket。

Bucket ACL 主要用于授予基本的读写权限，但它的功能有限，无法提供细粒度的权限控制。

ACL 不支持跨账户的复杂权限管理，尤其是无法直接授予帐户 A 的用户对整个 bucket 的访问权限。因此此选项错误。

B. 在帐户 B 中，创建一个 object ACL，以允许帐户 A 的用户访问帐户 B 中 S3 bucket 中的所有对象。

Object ACL 仅适用于单个对象的权限管理，无法批量管理整个 bucket 的权限。

如果 bucket 中有大量对象，逐个设置 ACL 是不可行的，且不符合最佳实践。

因此此选项错误。

C. 在帐户 B 中，创建一个 bucket policy，以允许帐户 A 的用户访问帐户 B 中的 S3 bucket。

Bucket Policy 是管理 S3 bucket 访问权限的推荐方式，支持跨账户访问。

通过 bucket policy，可以明确指定帐户 A 的用户对 bucket 的访问权限。

此选项正确。

D. 在帐户 B 中，创建一个 user policy，以允许帐户 A 的用户访问帐户 B 中的 S3 bucket。

User Policy 是针对帐户 B 内部用户的权限管理，无法直接授予帐户 A 的用户权限。

跨账户访问需要使用 bucket policy，而不是 user policy。
因此此选项错误。

3. 我选的答案

C. 在账户 B 中，创建一个 bucket policy，以允许账户 A 的用户访问账户 B 中的 S3 bucket。

4. 官方答案

C. 在账户 B 中，创建一个 bucket policy，以允许账户 A 的用户访问账户 B 中的 S3 bucket。

5. 与官方答案比较

我的答案与官方答案一致。

原因分析正确，无需重新思考。

▼ 11

▼ 英文

A company wants to receive an email notification about critical findings in AWS Security Hub. The company does not have an existing architecture that supports this functionality. Which solution will meet the requirement?

A. Create an AWS Lambda function to identify critical Security Hub findings. Create an Amazon Simple Notification Service (Amazon SNS) topic as the target of the Lambda function. Subscribe an email endpoint to the SNS topic to receive published messages.

B. Create an Amazon Kinesis Data Firehose delivery stream. Integrate the delivery stream with Amazon EventBridge. Create an EventBridge rule that has a filter to detect critical Security Hub findings. Configure the delivery stream to send the findings to an email address.

C. Create an Amazon EventBridge rule to detect critical Security Hub findings. Create an Amazon Simple Notification Service (Amazon SNS) topic as the target of the EventBridge rule. Subscribe an email endpoint to the SNS topic to receive published messages.

D. Create an Amazon EventBridge rule to detect critical Security Hub findings. Create an Amazon Simple Email Service (Amazon SES) topic as the target of the EventBridge rule. Use the Amazon SES API to format the message. Choose an email address to be the recipient of the message.

▼ 中文

一家公司希望收到有关 AWS Security Hub 中关键发现的电子邮件通知。该公司目前尚无支援此功能的架构。哪种解决方案可以满足该需求？

A: 建立 AWS Lambda 函数来识别关键的 Security Hub 发现结果。建立一个 Amazon Simple Notification Service (Amazon SNS) 主题作为 Lambda 函数的目标。将电子邮件终端节点订阅至 SNS 主题以接收已发布的讯息。

B: 传输流。将传输流与 Amazon EventBridge 整合。建立包含筛选器的 EventBridge 规则，用于侦测关键的 Security Hub 发现结果。配置传输流，将发现结果传送至电子邮件地址。

C: 建立 Amazon EventBridge 规则以侦测关键的 Security Hub 发现结果。建立一个 Amazon Simple Notification Service (Amazon SNS) 主题作为 EventBridge 规则的目标。将电子邮件终端节点订阅至 SNS 主题以接收已发布的讯息。

D: 建立 Amazon EventBridge 规则以侦测关键的 Security Hub 发现结果。建立一个 Amazon Simple Email Service (Amazon SES) 主题作为 EventBridge 规则的目标。使用 Amazon SES API 格式化讯息。选择一个电子邮件地址作为讯息的收件者。

▼ 解答

C

1. 考察的知识点

本题考察的是AWS Security Hub与事件通知服务的集成，包括Amazon EventBridge和Amazon SNS的使用。

重点在于如何检测关键的Security Hub发现，并通过电子邮件通知相关人员。

2. 选项分析

A. 创建一个 AWS Lambda 函数来识别关键的 Security Hub 发现。创建一个 Amazon SNS 主题作为 Lambda 函数的目标。

将电子邮件端点订阅到 SNS 主题以接收发布的消息。

错误：虽然可以使用Lambda函数来处理Security Hub发现，但这增加了不必要的复杂性。AWS Security Hub已经可以通过EventBridge直接发送事件，无需额外的Lambda函数。

B. 创建一个 Amazon Kinesis Data Firehose 交付流。将交付流与 Amazon EventBridge 集成。创建一个具有过滤器以

检测关键 Security Hub 发现的 EventBridge 规则。配置交付流将发现发送到电子邮件地址。

错误：Kinesis Data Firehose主要用于数据流的持久化和分析，不适合直接发送电子邮件通知。此选项复杂且不符合需求。

C. 创建一个 Amazon EventBridge 规则以检测关键 Security Hub 发现。创建一个 Amazon SNS 主题作为 EventBridge 规则的目标。将电子邮件端点订阅到 SNS 主题以接收发布的消息。

正确：EventBridge可以直接检测Security Hub的关键发现，并将事件发送到SNS。SNS支持电子邮件订阅，能够满足通知需求。

D. 创建一个 Amazon EventBridge 规则以检测关键 Security Hub 发现。创建一个 Amazon SES 主题作为 EventBridge 规则的目标。

使用 Amazon SES API 格式化消息。选择一个电子邮件地址作为消息的接收者。

错误：Amazon SES主要用于大规模电子邮件发送，而不是事件通知。使用SES API格式化消息增加了复杂性，不是最佳解决方案。

▼ 12

▼ 英文

An international company has established a new business entity in South Korea. The company also has established a new AWS account to contain the workload for the South Korean region. The company has set up the workload in the new account in the ap-northeast-2 Region. The workload consists of three Auto Scaling groups of Amazon EC2 instances. All workloads that operate in this Region must keep system logs and application logs for 7 years.

A security engineer must implement a solution to ensure that no logging data is lost for each instance during scaling activities. The solution also must keep the logs for only the required period of 7 years.

Which combination of steps should the security engineer take to meet these requirements? (Choose three.)

A. Ensure that the Amazon CloudWatch agent is installed on all the EC2 instances that the Auto Scaling groups launch. Generate a CloudWatch agent configuration file to forward the required logs to Amazon CloudWatch Logs.

B.Set the log retention for desired log groups to 7 years.

C.Attach an IAM role to the launch configuration or launch template that the Auto Scaling groups use. Configure the role to provide the necessary permissions to forward logs to Amazon CloudWatch Logs.

D.Attach an IAM role to the launch configuration or launch template that the Auto Scaling groups use. Configure the role to provide the necessary permissions to forward logs to Amazon S3.

E.Ensure that a log forwarding application is installed on all the EC2 instances that the Auto Scaling groups launch. Configure the log forwarding application to periodically bundle the logs and forward the logs to Amazon S3.

F.Configure an Amazon S3 Lifecycle policy on the target S3 bucket to expire objects after 7 years.

▼ 中文

一家跨国公司在韩国设立了新的业务实体。该公司还建立了一个新的 AWS 帐户，用于承载韩国区域的工作负载。该公司已在 ap-northeast-2 区域的新帐户中设定了工作负载。此工作负载由三个 Amazon EC2 执行个体的 Auto Scaling 群组组成。在此区域运行的所有工作负载必须将系统日志和应用程式日志保留 7 年。

安全工程师必须实施解决方案，以确保在扩展活动期间每个执行个体的日志资料不会遗失。
该解决方案还必须仅将日志保留 7 年所需的期限。

安全工程师应采取哪些步骤组合来满足这些要求？（选三个。）

A:确保Auto Scaling 群组启动的所有 EC2执行个体上都安装了 Amazon CloudWatch 代理程式。产生 CloudWatch 代理程式设定文件，以将所需日志转送至 Amazon CloudWatch Logs。

B:将所需日志组的日志保留设定为 7 年。

C:将 IAM 角色附加到 Auto Scaling 群组使用的启动设定或启动范本。配置该角色以提供将日志转送至 Amazon CloudWatch Logs 所需的权限。

D将 IAM 角色附加到 Auto Scaling 群组使用的启动设定或启动范本。配置该角色以提供将日志转送至 Amazon S3 所需的权限。

E:确保 Auto Scaling 群组启动的所有EC2 执行个体上都安装了日志转送应用程式。设定日志转送应用程序，使其定期捆绑日志并将其转送至 Amazon S3。

F:在目标 S3 储存桶上设定 Amazon S3 生命週期策略，使物件在 7 年后过期。

▼ 解答

ABC

1. 考察的知识点

Amazon CloudWatch Logs的使用与配置。

日志保留策略的设置。

IAM角色的权限配置与Auto Scaling组的集成。

2. 选项分析

A.

正确：安装CloudWatch agent并配置日志转发是确保日志数据不会丢失的关键步骤。CloudWatch Logs可以可靠地存储日志数据。

B.

正确：设置日志保留期为7年符合题目要求，确保日志不会被过早删除。

C.

正确：IAM角色需要提供EC2实例将日志转发到CloudWatch Logs的权限，这是日志转发的必要条件。

D.

错误：题目要求使用CloudWatch Logs作为日志存储，而不是Amazon S3。

E.

错误：题目没有提到使用日志转发应用程序，也没有要求将日志转发到Amazon S3。

F.

错误：题目要求使用CloudWatch Logs存储日志，而不是Amazon S3，因此S3生命周期策略不适用。

▼ 13

▼ 英文

A security engineer is designing an IAM policy to protect AWS API operations. The policy must enforce multi-factor authentication (MFA) for IAM users to access certain services in the AWS production account. Each session must remain valid for only 2 hours. The current version of the IAM policy is as follows:

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": [
      "ec2:DescribeInstances",
      "ec2:StopInstances",
      "ec2:TerminateInstances"
    ],
    "Resource": ["*"]
  }]
}
```

Which combination of conditions must the security engineer add to the IAM policy to meet these requirements? (Choose two.)

- A."Bool": {"aws:MultiFactorAuthPresent": "true"}
- B."Bool": {"aws:MultiFactorAuthPresent": "false"}
- C."NumericLessThan": {"aws:MultiFactorAuthAge": "7200"}
- D."NumericGreaterThan": {"aws:MultiFactorAuthAge": "7200"}
- E."NumericLessThan": {"MaxSessionDuration": "7200"}

▼ 中文

一位安全工程师正在设计 IAM 策略来保护 AWS API 操作。此策略必须强制执行多重身份验证 (MFA)，以便 IAM 使用者存取 AWS 生产帐户中的某些服务。每个会话的有效期限仅为 2 小时。IAM 策略的目前版本如下：

安全工程师必须为 IAM 策略新增哪些条件组合才能满足这些要求？（选两个。）

```

{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": [
      "ec2:DescribeInstances",
      "ec2:StopInstances",
      "ec2:TerminateInstances"
    ],
    "Resource": ["*"]
  }]
}

```

- A. "Bool": {"aws:MultiFactorAuthPresent": "true"}
- B. "Bool": {"aws:MultiFactorAuthPresent": "false"}
- C. "NumericLessThan": {"aws:MultiFactorAuthAge": "7200"}
- D. "NumericGreaterThan": {"aws:MultiFactorAuthAge": "7200"}
- E. "NumericLessThan": {"MaxSessionDuration": "7200"}

▼ 解答

AC

1. 考察的知识点

IAM策略条件的使用，包括多因素认证（MFA）相关条件。

如何限制会话的有效时间。

安全性最佳实践：强制MFA和限制会话时长。

2. 选项分析

A. "Bool": {"aws:MultiFactorAuthPresent": "true"}

此选项正确。此条件用于检查用户是否启用了MFA。如果MFA未启用，则用户无法执行指定的操作。符合题目要求。

B. "Bool": {"aws:MultiFactorAuthPresent": "false"}

此选项错误。此条件表示用户未启用MFA时允许操作，与题目要求强制MFA相违背。

C. "NumericLessThan": {"aws:MultiFactorAuthAge": "7200"}

此选项正确。此条件用于限制MFA会话的有效时间为2小时（7200秒）。符合题目要求。

D. "NumericGreaterThan": {"aws:MultiFactorAuthAge": "7200"}

此选项错误。此条件表示MFA会话超过2小时后允许操作，与题目要求限制会话时长相违背。

E. "NumericLessThan": {"MaxSessionDuration": "7200"}

此选项错误。MaxSessionDuration是用于角色的会话时长设置，而不是MFA相关条件，与题目要求不符。

▼ 14

▼ 英文

A company uses AWS Organizations and has production workloads across multiple AWS accounts. A security engineer needs to design a solution that will proactively monitor for suspicious behavior across all the accounts that contain production workloads.

The solution must automate remediation of incidents across the production accounts. The solution also must publish a notification to an Amazon Simple Notification Service (Amazon SNS) topic when a critical security finding is detected. In addition, the solution must send all security incident logs to a dedicated account.

Which solution will meet these requirements?

A. Activate Amazon GuardDuty in each production account. In a dedicated logging account, aggregate all GuardDuty logs from each production account. Remediate incidents by configuring GuardDuty to directly invoke an AWS Lambda function. Configure the Lambda function to also publish notifications to the SNS topic.

B. Activate AWS Security Hub in each production account. In a dedicated logging account, aggregate all Security Hub findings from each production account. Remediate incidents by using AWS Config and AWS Systems Manager. Configure Systems Manager to also publish notifications to the SNS topic.

C. Activate Amazon GuardDuty in each production account. In a dedicated logging account, aggregate all GuardDuty logs from each production account. Remediate incidents by using Amazon EventBridge to invoke a custom AWS Lambda function from the GuardDuty findings. Configure the Lambda function to also publish notifications to the SNS topic.

D. Activate AWS Security Hub in each production account. In a dedicated logging account, aggregate all Security Hub findings from each production account. Remediate incidents by using Amazon EventBridge to invoke a custom AWS Lambda function from the Security Hub findings. Configure the Lambda function to also publish notifications to the SNS topic.

▼ 中文

一家公司使用 AWS Organizations，其生产工作负载跨多个 AWS 帐户。一位安全工程师需要设计一个解决方案，用于主动监控所有包含生产工作负载的帐户中的可疑行为。

此解决方案必须能够自动修复所有生产帐户中的事件。此外，当侦测到关键安全性问题时，此解决方案也必须向 Amazon Simple Notification Service (Amazon SNS) 主题发布通知。此外，该解决方案还必须将所有安全事件日志传送到专用帐户。

哪种解决方案能够满足这些要求？

A. 在每个生产帐户中启动 Amazon GuardDuty。在专用日志记录帐户中，汇总来自每个生产帐户的所有 GuardDuty 日志。透过配置 GuardDuty 直接呼叫 AWS Lambda 函数来修复事件。配置 Lambda 函数，使其也向 SNS 主题发布通知。

B. 在每个生产帐户中启动 AWS Security Hub。在专用日志帐户中，汇总每个生产帐户的所有 Security Hub 发现结果。使用 AWS Config 和 AWS Systems Manager 修复事件。配置 Systems Manager 以将通知发布到 SNS 主题。

C. 在每个生产帐户中启动 Amazon GuardDuty。在专用日志记录帐户中，汇总来自每个生产帐户的所有 GuardDuty 日志。使用 Amazon EventBridge 从 GuardDuty 侦测结果中呼叫自订 AWS Lambda 函数来修复事件。配置 Lambda 函数，使其也向 SNS 主题发布通知。

D. 在每个生产帐户中启动 AWS Security Hub。在专用日志帐户中，汇总每个生产帐户的所有 Security Hub 发现结果。使用 Amazon EventBridge 从 Security Hub 发现结果中呼叫自订 AWS Lambda 函数来修复事件。配置 Lambda 函数，使其也向 SNS 主题发布通知。

▼ 解答

C

1. 考察的知识点

Amazon GuardDuty的功能和使用场景。

跨账户日志聚合和安全事件处理。

使用Amazon EventBridge触发AWS Lambda函数进行自动化响应。

Amazon SNS用于通知机制。

2. 选项分析

A:

正确性：激活Amazon GuardDuty是正确的，因为它是专门用于检测和响应安全威胁的服务。

错误点：GuardDuty无法直接调用AWS Lambda函数进行自动化响应，必须通过Amazon

EventBridge来实现事件驱动的自

动化处理。

B:

正确性：激活AWS Security Hub可以汇总安全发现，但它主要用于集中管理和合规性检查，而不是实时检测和响应。

错误点：AWS Config和AWS Systems Manager虽然可以用于合规性和自动化管理，但它们不是最佳选择来处理实时安全

事件。

C:

正确性：激活Amazon GuardDuty是正确的，因为它可以检测安全威胁。

正确性：使用Amazon EventBridge从GuardDuty发现中触发AWS Lambda函数是正确的，因为EventBridge可以实现事件驱动的自动化响应。

正确性：配置Lambda函数发布通知到SNS主题是正确的，因为SNS可以用于通知机制。

D:

正确性：激活AWS Security Hub是正确的，但它主要用于合规性检查和集中管理，而不是实时检测和响应。

错误点：虽然可以使用Amazon EventBridge触发Lambda函数，但Security Hub不是最佳选择来处理实时安全事件。

▼ 15

▼ 英文

A company is designing a multi-account structure for its development teams. The company is using AWS Organizations and AWS IAM Identity Center (AWS Single Sign-On). The company must implement a solution so that the development teams can use only specific AWS Regions and so that each AWS account allows access to only specific AWS services.

Which solution will meet these requirements with the LEAST operational overhead?

A. Use IAM Identity Center to set up service-linked roles with IAM policy statements that include the Condition, Resource, and NotAction elements to allow access to only the Regions and services that are needed.

B. Deactivate AWS Security Token Service (AWS STS) in Regions that the developers are not allowed to use.

C. Create SCPs that include the Condition, Resource, and NotAction elements to allow access to only the Regions and services that are needed.

D. For each AWS account, create tailored identity-based policies for IAM Identity Center. Use statements that include the Condition, Resource, and NotAction elements to allow access to only the Regions and services that are needed.

▼ 中文

一家公司正在为其开发团队设计多帐户结构。该公司正在使用 AWS Organizations 和 AWS IAM Identity Center (AWS 单一登入)。该公司必须实施一项解决方案，以便开发团队只能使用特定的 AWS 区域，而每个 AWS 帐户只能存取特定的 AWS 服务。
哪种解决方案能够以最低的营运开销满足这些要求？

- A. 使用 IAM Identity Center 设定服务相关角色，其中包含条件、资源和 NotAction 元素的 IAM 策略语句，仅允许存取所需的区域和服务。
- B. 在不允许开发人员使用的区域中停用 AWS 安全性令牌服务 (AWS STS)。
- C. 建立包含条件、资源和 NotAction 元素的 SCP，以仅允许存取所需的区域和服务。
- D. 为每个 AWS 帐户建立客製化的基于身分的 IAM Identity Center 政策。使用包含 Condition、Resource 和 NotAction 元素的语句，仅允许存取所需的区域和服务。

▼ 解答

C

1. 考察的知识点

AWS Organizations 的服务控制策略 (SCP) 的使用。
如何限制 AWS 帐户对特定区域和服务的访问。
IAM Identity Center 的功能与限制。
操作开销的优化。

2. 选项分析

- A. 使用 IAM Identity Center 设置带有 IAM 策略语句的服务关联角色：
错误：IAM Identity Center 主要用于用户身份管理和单点登录，而不是直接限制帐户对区域和服务的访问。IAM 策略无法跨帐户统一管理，且操作开销较高。
- B. 在开发人员不被允许使用的区域停用 AWS Security Token Service (AWS STS)：
错误：虽然停用 AWS STS 可以限制区域访问，但这种方法需要逐个帐户配置，操作开销较高。此外，无法限制对特定服务的访问。
- C. 创建包含 Condition、Resource 和 NotAction 元素的 SCP，以仅允许访问所需的区域和服务：
正确：SCP 是 AWS Organizations 的功能，可以跨帐户统一管理权限。通过 Condition、Resource 和 NotAction 元素，可以精确限制区域和服务访问，且操作开销最低。
- D. 为每个 AWS 帐户创建定制的基于身份的 IAM Identity Center 策略：
错误：为每个帐户单独创建策略需要大量手动操作，操作开销高。IAM Identity Center 的策略无法跨帐户统一管理。

▼ 16

▼ 英文

A company is developing an ecommerce application. The application uses Amazon EC2 instances and an Amazon RDS MySQL database. For compliance reasons, data must be secured in transit and at rest. The company needs a solution that minimizes operational overhead and minimizes cost.

Which solution meets these requirements?

- A. Use TLS certificates from AWS Certificate Manager (ACM) with an Application Load Balancer. Deploy self-signed certificates on the EC2 instances. Ensure that the database client software uses a TLS connection to Amazon RDS. Enable encryption of the RDS DB instance. Enable encryption on the Amazon Elastic Block Store (Amazon EBS) volumes that support the EC2 instances.
- B. Use TLS certificates from a third-party vendor with an Application Load Balancer. Install the same certificates on the EC2 instances. Ensure that the database client software uses

a TLS connection to Amazon RDS. Use AWS Secrets Manager for client-side encryption of application data.

C. Use AWS CloudHSM to generate TLS certificates for the EC2 instances. Install the TLS certificates on the EC2 instances. Ensure that the database client software uses a TLS connection to Amazon RDS. Use the encryption keys from CloudHSM for client-side encryption of application data.

D. Use Amazon CloudFront with AWS WAF. Send HTTP connections to the origin EC2 instances. Ensure that the database client software uses a TLS connection to Amazon RDS. Use AWS Key Management Service (AWS KMS) for client-side encryption of application data before the data is stored in the RDS database.

▼ 中文

一家公司正在开发一款电商应用程序。该应用程序使用 Amazon EC2 执行个体和 Amazon RDS MySQL 资料库。出于合规性考虑，**资料在传输过程中和静态时都必须受到保护**。该公司需要一个能够**最大限度降低营运开销和成本**的解决方案。

哪种解决方案能够满足这些要求？

A. 将 AWS 凭证管理员 (ACM) 的 TLS 凭证与应用程序负载均衡器结合使用。在 EC2 执行个体上部署自签章凭证。确保资料库客户端软件使用 TLS 连线到 Amazon RDS。启用 RDS 资料库实例的加密。在支援 EC2 执行个体的 Amazon Elastic Block Store (Amazon EBS) 磁碟区上启用加密。

B. 将来自第三方供应商的 TLS 凭证与应用程序负载均衡器结合使用。在 EC2 执行个体上安装相同的凭证。确保资料库客户端软件使用 TLS 连线到 Amazon RDS。使用 AWS Secrets Manager 对应用程序资料进行用户端加密。

C. 使用 AWS CloudHSM 为 EC2 执行个体产生 TLS 凭证。在 EC2 执行个体上安装 TLS 凭证。确保资料库客户端软件使用 TLS 连线到 Amazon RDS。使用 CloudHSM 的加密金钥对应用程序资料进行用户端加密。

D. 将 Amazon CloudFront 与 AWS WAF 结合使用。将 HTTP 连线传送到来源 EC2 执行个体。确保资料库客户端软件使用 TLS 连线到 Amazon RDS。在将应用程序资料储存在 RDS 资料库之前，使用 AWS Key Management Service (AWS KMS) 对应用程序资料进行用户端加密。

▼ 解答

A

1. 考察的知识点

数据加密：包括数据在传输中和静态存储中的加密。

使用 AWS 服务（如 ACM、RDS、EBS）实现安全性和合规性。

成本优化和减少操作复杂性。

2. 选项分析

A. 使用 TLS 证书从 AWS Certificate Manager (ACM) 与 Application Load Balancer。

正确：ACM 提供托管的 TLS 证书，减少了操作复杂性。

正确：使用 Application Load Balancer 可以集中管理 TLS 证书，降低成本。

正确：RDS 支持 TLS 连接，确保数据在传输中加密。

正确：RDS 和 EBS 都支持静态数据加密，符合合规要求。

B. 使用来自第三方供应商的 TLS 证书与 Application Load Balancer。

错误：第三方证书需要额外的管理工作，增加了操作复杂性。

错误：在 EC2 实例上安装证书增加了维护成本。

错误：AWS Secrets Manager 不适用于静态数据加密，而是用于管理密钥和凭证。

C. 使用 AWS CloudHSM 为 EC2 实例生成 TLS 证书。

错误：CloudHSM 是一种硬件安全模块，主要用于管理加密密钥，而不是生成 TLS 证书。

错误：在 EC2 实例上安装证书增加了操作复杂性。

错误：CloudHSM 的成本较高，不符合“最小化成本”的要求。

D. 使用 Amazon CloudFront 与 AWS WAF。

错误：CloudFront 和 WAF 主要用于内容分发和 Web 应用防火墙保护，与数据加密无关。

错误：发送 HTTP 连接到 EC2 实例不符合“数据必须在传输中加密”的要求。

错误：AWS KMS 主要用于密钥管理，而不是静态数据加密。

▼ 17

▼ 英文

A security engineer is working with a company to design an ecommerce application. The application will run on Amazon EC2 instances that run in an Auto Scaling group behind an Application Load Balancer (ALB). The application will use an Amazon RDS DB instance for its database.

The only required connectivity from the internet is for HTTP and HTTPS traffic to the application. The application must communicate with an external payment provider that allows traffic only from a preconfigured allow list of IP addresses. The company must ensure that communications with the external payment provider are not interrupted as the environment scales.

Which combination of actions should the security engineer recommend to meet these requirements? (Choose three.)

- A. Deploy a NAT gateway in each private subnet for every Availability Zone that is in use.
- B. Place the DB instance in a public subnet.
- C. Place the DB instance in a private subnet.
- D. Configure the Auto Scaling group to place the EC2 instances in a public subnet.
- E. Configure the Auto Scaling group to place the EC2 instances in a private subnet.
- F. Deploy the ALB in a private subnet.

▼ 中文

一位安全工程师正在与一家公司合作设计一款电子商务应用程序。该应用程序将在应用程序负载均衡器 (ALB) 后面的 Auto Scaling 群组中执行的 Amazon EC2 执行个体上执行。该应用程序将使用 Amazon RDS DB 执行个体作为其资料库。

网络上唯一需要的连线是用于应用程序的 HTTP 和 HTTPS 流量。该应用程序必须与外部支付提供者进行通信，该提供者仅允许来自预先配置的 IP 地址清单的流量。公司必须确保与外部支付提供者的通讯不会随着环境规模的扩大而中断。

安全工程师应建议采取哪些行动组合来满足这些要求？（选三个。）

- A. 在每个正在使用的可用区域的每个私人子网路中部署一个 NAT 闸道。
- B. 将资料库执行个体放置在公共子网路中。
- C. 将资料库执行个体放置在私有子网路中。
- D. 设定 Auto Scaling 群组以将 EC2 执行个体放置在公用子网路中。
- E. 设定 Auto Scaling 群组以将 EC2 执行个体放置在私有子网路中。
- F. 在私人子网路中部署 ALB。

▼ 解答

ACE

1. 考察的知识点

Amazon EC2 Auto Scaling组的网络配置（公有子网 vs 私有子网）。

Amazon RDS数据库实例的网络配置（公有子网 vs 私有子网）。

NAT网关的使用及其在私有子网中的作用。

如何确保外部服务通信的稳定性（IP白名单和NAT网关）。

2. 选项分析

A. Deploy a NAT gateway in each private subnet for every Availability Zone that is in use.

正确。NAT网关允许私有子网中的资源（如EC2实例）访问互联网，同时保持其私有IP地址。由于外部支付提供商需要

预配置的IP白名单，NAT网关可以确保通信的稳定性，即使环境扩展。

B. Place the DB instance in a public subnet.

错误。数据库实例应放置在私有子网中以增强安全性。将数据库放置在公共子网中会暴露其IP地址，增加攻击风险。

C. Place the DB instance in a private subnet.

正确。数据库实例放置在私有子网中是最佳实践，可以防止直接的互联网访问，增强安全性。

D. Configure the Auto Scaling group to place the EC2 instances in a public subnet.

错误。EC2实例应放置在私有子网中以限制直接的互联网访问。ALB可以处理来自互联网的HTTP和HTTPS流量，并将流

量转发到私有子网中的EC2实例。

E. Configure the Auto Scaling group to place the EC2 instances in a private subnet.

正确。EC2实例放置在私有子网中是最佳实践，可以通过ALB处理互联网流量，同时保持实例的安全性。

F. Deploy the ALB in a private subnet.

错误。ALB需要能够接收来自互联网的HTTP和HTTPS流量，因此应部署在公共子网中，而不是私有子网。

3. 我选的答案

A

C

E

4. 官方答案

A

C

E

5. 与官方答案比较

我的答案与官方答案一致。

没有差异，无需重新思考。

▼ 18

▼ 英文

A company uses several AWS CloudFormation stacks to handle the deployment of a suite of applications. The leader of the company's application development team notices that the stack deployments fail with permission errors when some team members try to deploy the stacks. However, other team members can deploy the stacks successfully. The team members access the account by assuming a role that has a specific set of permissions that are necessary for the job responsibilities of the team members. All team members have permissions to perform operations on the stacks.

Which combination of steps will ensure consistent deployment of the stacks MOST securely? (Choose three.)

- A. Create a service role that has a composite principal that contains each service that needs the necessary permissions. Configure the role to allow the sts:AssumeRole action.
- B. Create a service role that has cloudformation.amazonaws.com as the service principal. Configure the role to allow the sts:AssumeRole action.
- C. For each required set of permissions, add a separate policy to the role to allow those permissions. Add the ARN of each CloudFormation stack in the resource field of each policy.
- D. For each required set of permissions, add a separate policy to the role to allow those permissions. Add the ARN of each service that needs the permissions in the resource field of the corresponding policy.
- E. Update each stack to use the service role.
- F. Add a policy to each member role to allow the iam:PassRole action. Set the policy's resource field to the ARN of the service role.

▼ 中文

一家公司使用多个 AWS CloudFormation 堆叠来处理一套应用程序的部署。该公司应用程序开发团队的负责人注意到，当一些团队成员尝试部署堆叠时，堆叠部署会因权限错误而失败。然而，其他团队成员可以成功部署堆叠。团队成员透过代入一个拥有特定权限的角色来存取帐户，这些权限是团队成员履行工作职责所必需的。所有团队成员都有权对堆叠执行操作。

哪一种步骤组合能够最安全地确保堆叠的一致部署？（选三个。）

- A. 建立一个具有複合主体的服务角色，该複合主体包含需要必要权限的每个服务。配置该角色以允许 sts:AssumeRole 操作。
- B. 创建一个以 cloudformation.amazonaws.com 作为服务主体的服务角色。配置该角色以允许 sts:AssumeRole 操作。
- C. 对于每组所需的权限，请向角色新增单独的策略以允许这些权限。在每个策略的资源栏位中新增每个 CloudFormation 堆叠的 ARN。
- D. 对于每组所需的权限，请向角色新增单独的策略以允许这些权限。在对应策略的资源栏位中新增需要这些权限的每个服务的 ARN。
- E. 更新每个堆叠以使用服务角色。
- F. 为每个成员角色新增一个策略，以允许 iam:PassRole 操作。将策略的资源栏位设定为服务角色的 ARN。

▼ 解答

BDE

1. 考察的知识点

- IAM角色与权限管理，包括服务角色的使用。
- AWS CloudFormation的权限模型，尤其是如何配置服务角色以确保部署成功。
- IAM策略的资源字段配置，以及如何安全地授予权限。

2. 选项分析

- A. 创建一个服务角色，该角色具有一个包含每个需要必要权限的服务的复合主体。配置该角色以允许执行 sts:AssumeRole 操作。
错误：服务角色的主体应该是具体的服务（如 CloudFormation），而不是复合主体。复合主体的配置不符合服务角色的最佳实践。
- B. 创建一个服务角色，该角色的服务主体为 cloudformation.amazonaws.com。配置该角色以允许

执行

sts:AssumeRole 操作。

正确：这是配置 CloudFormation 服务角色的正确方法。服务主体明确指定为 CloudFormation，确保该服务可以使用该角色执行操作。

C. 对于每组所需的权限，向角色添加单独的策略以允许这些权限。在每个策略的资源字段中添加每个 CloudFormation 堆栈的 ARN。

错误：虽然可以为每个权限集添加单独的策略，但这种方法不够高效且容易出错。更好的方法是使用服务角色并集中管理权限。

D. 对于每组所需的权限，向角色添加单独的策略以允许这些权限。在对应策略的资源字段中添加需要这些权限的每个服务的 ARN。

正确：这种方法确保了权限的精细化管理，并且资源字段明确指定了需要权限的服务 ARN。

E. 更新每个堆栈以使用服务角色。为每个成员角色添加一个策略以允许 iam:PassRole 操作。将策略的资源字段设置为服务角色的 ARN。

正确：更新堆栈以使用服务角色是解决权限问题的关键步骤。iam:PassRole 操作允许成员角色将服务角色传递给

CloudFormation，确保部署成功。

▼ 19

▼ 英文

A company used a lift-and-shift approach to migrate from its on-premises data centers to the AWS Cloud. The company migrated on-premises VMs to Amazon EC2 instances. Now the company wants to replace some of components that are running on the EC2 instances with managed AWS services that provide similar functionality.

Initially, the company will transition from load balancer software that runs on EC2 instances to AWS Elastic Load Balancers. A security engineer must ensure that after this transition, all the load balancer logs are centralized and searchable for auditing. The security engineer must also ensure that metrics are generated to show which ciphers are in use.

Which solution will meet these requirements?

A. Create an Amazon CloudWatch Logs log group. Configure the load balancers to send logs to the log group. Use the CloudWatch Logs console to search the logs. Create CloudWatch Logs filters on the logs for the required metrics.

B. Create an Amazon S3 bucket. Configure the load balancers to send logs to the S3 bucket. Use Amazon Athena to search the logs that are in the S3 bucket. Create Amazon CloudWatch filters on the S3 log files for the required metrics.

C. Create an Amazon S3 bucket. Configure the load balancers to send logs to the S3 bucket. Use Amazon Athena to search the logs that are in the S3 bucket. Create Athena queries for the required metrics. Publish the metrics to Amazon CloudWatch.

D. Create an Amazon CloudWatch Logs log group. Configure the load balancers to send logs to the log group. Use the AWS Management Console to search the logs. Create Amazon Athena queries for the required metrics. Publish the metrics to Amazon CloudWatch.

▼ 中文

一家公司採用「直接迁移」的方式从其本地资料中心迁移到 AWS 云端。该公司将本地虚拟机器迁移到了 Amazon EC2 执行个体。现在，该公司希望将 EC2 执行个体上执行的部分元件替换为提供类似功能的託管 AWS 服务。

首先，该公司将从在 EC2 执行个体上执行的负载均衡器软体过渡到 AWS 弹性负载均衡器。安全工程师必须确保在过渡后，所有负载均衡器日志都集中且可供审计搜寻。安全工程师还必须确保产生指标以显示正在使用的密码。哪种解决方案能够满足这些要求？

- A.建立 Amazon CloudWatch Logs 日志组。配置负载均衡器以将日志传送到该日志组。使用 CloudWatch Logs 控制台搜寻日志。针对所需指标，在日志上建立 CloudWatch Logs 筛选条件。
- B.建立 Amazon S3 储存桶。配置负载均衡器以将日志传送到 S3 储存桶。使用 Amazon Athena 搜寻 S3 储存桶中的日志。针对 S3 日志档案建立 Amazon CloudWatch 筛选器，以取得所需指标。
- C.建立 Amazon S3 储存桶。配置负载均衡器以将日志传送到 S3 储存桶。使用 Amazon Athena 搜寻 S3 储存桶中的日志。建立 Athena 查询以取得所需指标。将指标发布到 Amazon CloudWatch。
- D.建立 Amazon CloudWatch Logs 日志组。配置负载均衡器以将日志传送到该日志组。使用 AWS 管理主控台搜寻日志。建立 Amazon Athena 查询以取得所需指标。将指标发布到 Amazon CloudWatch。

▼ 解答

C

1. 考察的知识点

了解 AWS Elastic Load Balancer 的日志功能及其配置。

熟悉 Amazon S3、Amazon Athena 和 Amazon CloudWatch 的日志处理和分析能力。

掌握如何将日志数据转化为可搜索和可视化的指标。

2. 选项分析

A.

错误原因：AWS Elastic Load Balancer 的日志无法直接发送到 CloudWatch Logs。ELB 日志只能发送到 Amazon S3。

此外，CloudWatch Logs 过滤器无法直接处理 ELB 日志中的复杂查询需求。

B.

错误原因：虽然可以使用 Amazon Athena 搜索存储在 S3 中的日志，但 CloudWatch Filters 无法直接处理 S3 日志文件。

需要通过 Athena 查询生成指标，而不是直接使用 CloudWatch Filters。

C.

正确原因：这是最佳解决方案。ELB 日志可以发送到 Amazon S3，使用 Amazon Athena 可以对日志进行复杂查询。

通过 Athena 查询生成所需的指标，并将这些指标发布到 Amazon CloudWatch 以实现可视化和监控。

D.

错误原因：与选项 A 类似，ELB 日志无法直接发送到 CloudWatch Logs。

此外，Athena 查询无法直接处理 CloudWatch Logs 中的数据。

3. 我选的答案

C

4. 官方答案

C

5. 与官方答案比较

我的答案与官方答案一致。

原因分析清晰，选项 C 是唯一符合题目要求的解决方案。

▼ 20

▼ 英文

A company uses AWS Organizations to manage a multi-account AWS environment in a single AWS Region. The organization's management account is named management-01. The company has turned on AWS Config in all accounts in the organization. The company has designated an account named security-01 as the delegated administrator for AWS Config.

All accounts report the compliance status of each account's rules to the AWS Config delegated administrator account by using an AWS Config aggregator. Each account administrator can configure and manage the account's own AWS Config rules to handle each account's unique compliance requirements.

A security engineer needs to implement a solution to automatically deploy a set of 10 AWS Config rules to all existing and future AWS accounts in the organization. The solution must turn on AWS Config automatically during account creation.

Which combination of steps will meet these requirements? (Choose two.)

- A. Create an AWS CloudFormation template that contains the 10 required AWS Config rules. Deploy the template by using CloudFormation StackSets in the security-01 account.
- B. Create a conformance pack that contains the 10 required AWS Config rules. Deploy the conformance pack from the security-01 account.
- C. Create a conformance pack that contains the 10 required AWS Config rules. Deploy the conformance pack from the management-01 account.
- D. Create an AWS CloudFormation template that will activate AWS Config. Deploy the template by using CloudFormation StackSets in the security-01 account.
- E. Create an AWS CloudFormation template that will activate AWS Config. Deploy the template by using CloudFormation StackSets in the management-01 account.

▼ 中文

一家公司使用 AWS Organizations 在单一 AWS 区域内管理多帐户 AWS 环境。组织的管理帐户名为 management-01。该公司已在组织内所有帐户中启用 AWS Config。该公司已指定一个名为 security-01 的帐户为 AWS Config 的委派管理员。

所有帐户都使用 AWS Config 聚合器向 AWS Config 委派管理员帐户报告其规则的合规性状态。每个帐户管理员都可以配置和管理帐户本身的 AWS Config 规则，以满足每个帐户独特的合规性要求。

一位安全工程师需要实施一项解决方案，将一组 10 个 AWS Config 规则自动部署到组织内所有现有和未来的 AWS 帐户。此解决方案必须在帐户建立期间自动启用 AWS Config。

哪一种步骤组合可以满足这些要求？（选两项。）

- A. 建立一个包含 10 个必需 AWS Config 规则的 AWS CloudFormation 范本。使用 security-01 帐户中的 CloudFormation StackSets 部署此范本。
- B. 建立一个包含 10 个必需 AWS Config 规则的一致性套件。从 security-01 帐户部署该一致性套件。
- C. 建立一个包含 10 个必需 AWS Config 规则的一致性套件。从 management-01 帐户部署该一致性包。
- D. 建立一个用于启动 AWS Config 的 AWS CloudFormation 范本。使用 security-01 帐户中的 CloudFormation StackSets 部署此范本。
- E. 建立一个用于启动 AWS Config 的 AWS CloudFormation 范本。使用 management-01 帐户中的 CloudFormation StackSets 部署该范本。

▼ 解答

BE

1. 考察的知识点

AWS Config的自动化部署与管理，包括规则和合规包（Conformance Pack）。

AWS Organizations中跨账户资源管理的最佳实践。

CloudFormation StackSets的使用及其在多账户环境中的应用。

如何在新创建的账户中自动启用AWS Config。

2. 选项分析

A.

错误：虽然可以使用CloudFormation StackSets部署AWS Config规则，但此选项未提及如何自动启用AWS Config，也未提到如何处理未来账户的规则部署。

B.

正确：Conformance Pack是管理多个AWS Config规则的最佳实践，可以简化规则的部署和管理。通过security-01账户（作为AWS Config的委派管理员账户）部署Conformance Pack是符合题目要求的。

C.

错误：虽然Conformance Pack是正确的工具，但题目明确指出security-01是AWS Config的委派管理员账户，因此应该从security-01账户进行部署，而不是management-01账户。

D.

错误：虽然可以使用CloudFormation StackSets激活AWS Config，但题目要求解决方案必须自动处理未来账户的AWSConfig启用，而此选项未提及如何实现这一点。

E.

正确：使用CloudFormation StackSets从管理账户（management-01）激活AWS Config是符合题目要求的，因为管理账户可以跨组织部署资源，并确保新账户自动启用AWS Config。

▼ 21

▼ 英文

A company has a legacy application that runs on a single Amazon EC2 instance. A security audit shows that the application has been using an IAM access key within its code to access an Amazon S3 bucket that is named DOC-EXAMPLE-BUCKET1 in the same AWS account. This access key pair has the s3:GetObject permission to all objects in only this S3 bucket. The company takes the application offline because the application is not compliant with the company's security policies for accessing other AWS resources from Amazon EC2.

A security engineer validates that AWS CloudTrail is turned on in all AWS Regions. CloudTrail is sending logs to an S3 bucket that is named DOC-EXAMPLE-BUCKET2. This S3 bucket is in the same AWS account as DOC-EXAMPLE-BUCKET1. However, CloudTrail has not been configured to send logs to Amazon CloudWatch Logs.

The company wants to know if any objects in DOC-EXAMPLE-BUCKET1 were accessed with the IAM access key in the past 60 days. If any objects were accessed, the company wants to know if any of the objects that are text files (.txt extension) contained personally identifiable information (PII).

Which combination of steps should the security engineer take to gather this information? (Choose two.)

A. Use Amazon CloudWatch Logs Insights to identify any objects in DOC-EXAMPLE-BUCKET1 that contain PII and that were available to the access key.

B. Use Amazon OpenSearch Service to query the CloudTrail logs in DOC-EXAMPLE-BUCKET2 for API calls that used the access key to access an object that contained PII.

C. Use Amazon Athena to query the CloudTrail logs in DOC-EXAMPLE-BUCKET2 for any API calls that used the access key to access an object that contained PII.

D. Use AWS Identity and Access Management Access Analyzer to identify any API calls that used the access key to access objects that contained PII in DOC-EXAMPLE-BUCKET1

E. Configure Amazon Macie to identify any objects in DOC-EXAMPLE-BUCKET1 that contain PII and that were available to the access key.

▼ 中文

一家公司拥有一个在单一 Amazon EC2 执行个体上执行的旧版应用程序。安全性审核显示，该应用程序一直在其程式码中使用 IAM 存取金钥存取相同 AWS 帐户中名为 DOC-EXAMPLE-BUCKET1 的 Amazon S3 储存桶。此存取金钥对仅对此 S3 储存桶中所有物件的 s3:GetObject 权限。该公司已将该应用程序下线，因为该应用程序不符合该公司关于从 Amazon EC2 存取其他 AWS 资源的安全性策略。

安全工程师验证了所有 AWS 区域是否都已启用 AWS CloudTrail。CloudTrail 正在将日志传送到名为 DOC-EXAMPLE-BUCKET2 的 S3 储存桶。此 S3 储存桶与 DOC-EXAMPLE-BUCKET1 位于相同 AWS 帐户。但是，CloudTrail 尚未设定为将日志传送到 Amazon CloudWatch Logs。

该公司想知道在过去 60 天内是否有人使用 IAM 存取金钥存取过 DOC-EXAMPLE-BUCKET1 中的任何物件。如果任何物件被访问，**公司希望知道其中是否有任何文字档案（副档名为 .txt）包含个人识别资讯 (PII)。**

安全工程师应该采取哪些步骤组合来收集这些资讯？（选两项。）

A. 使用 Amazon CloudWatch Logs Insights 识别 DOC-EXAMPLE-BUCKET1 中包含 PII 且可供存取金钥使用的任何物件。

B. 使用 Amazon OpenSearch Service 查询 DOC-EXAMPLE-BUCKET2 中的 CloudTrail 日志，寻找使用存取金钥存取包含 PII 的物件的 API 呼叫。

C. 使用 Amazon Athena 查询 DOC-EXAMPLE-BUCKET2 中的 CloudTrail 日志，寻找使用存取金钥存取包含 PII 的物件的任何 API 呼叫。

D. 使用 AWS Identity and Access Management 存取分析器来识别使用存取金钥存取 DOC-EXAMPLE-BUCKET1 中包含 PII 的物件的任何 API 呼叫。

E. 配置 Amazon Macie 以识别 DOC-EXAMPLE-BUCKET1 中包含 PII 且可供存取金钥使用的任何物件。

▼ 解答

CE

1. 考察的知识点

如何使用 AWS 服务（如 Amazon Athena 和 Amazon Macie）来分析和识别安全事件。
理解 CloudTrail 日志的查询和分析方法。
识别和保护敏感数据（如 PII）的能力。

2. 选项分析

A. Use Amazon CloudWatch Logs Insights to identify any objects in DOC-EXAMPLE-BUCKET1 that contain PII and that were available to the access key.

错误：CloudWatch Logs Insights 主要用于分析 CloudWatch 日志，而题目中明确指出 CloudTrail 日

志未配置到CloudWatch

Logs，因此无法使用此方法。

B. Use Amazon OpenSearch Service to query the CloudTrail logs in DOC-EXAMPLE-BUCKET2 for API calls that used the access key to access an object that contained PII.

错误：虽然OpenSearch可以用于日志分析，但题目中并未提到OpenSearch已配置或适合直接查询CloudTrail日志。使用

OpenSearch需要额外的配置，且不是最佳选择。

C. Use Amazon Athena to query the CloudTrail logs in DOC-EXAMPLE-BUCKET2 for any API calls that used the access key to access an object that contained PII.

正确：Athena可以直接查询存储在S3中的CloudTrail日志，能够有效地识别使用访问密钥的API调用。

D. Use AWS Identity and Access Management Access Analyzer to identify any API calls that used the access key to access objects that contained PII in DOC-EXAMPLE-BUCKET1.

错误：IAM Access Analyzer主要用于分析权限配置，而不是用于查询API调用或识别PII数据。

E. Configure Amazon Macie to identify any objects in DOC-EXAMPLE-BUCKET1 that contain PII and that were available to the access key.

正确：Amazon Macie专门用于识别存储在S3中的敏感数据（如PII），是解决此问题的最佳工具之一。

▼ 22

▼ 英文

A security engineer creates an Amazon S3 bucket policy that denies access to all users. A few days later, the security engineer adds an additional statement to the bucket policy to allow read-only access to one other employee. Even after updating the policy, the employee still receives an access denied message.

What is the likely cause of this access denial?

- A. The ACL in the bucket needs to be updated.
- B. The IAM policy does not allow the user to access the bucket.
- C. It takes a few minutes for a bucket policy to take effect.
- D. The allow permission is being overridden by the deny.

▼ 中文

一位安全工程師創建了一個 Amazon S3 儲存桶策略，用於拒絕所有使用者的存取。幾天後，這位安全工程師在該儲存桶策略中加入了一條語句，讓另一名員工擁有唯讀權限。即使在更新策略後，該員工仍然收到訪問被拒絕的訊息。

導致此訪問被拒絕的可能原因為何？

- A. 儲存桶中的 ACL 需要更新。
- B. IAM 策略不允許使用者存取該儲存桶。
- C. 儲存桶策略需要幾分鐘才能生效。

D.允許授權被拒絕權所覆寫。

▼ 解答

D

A. The ACL in the bucket needs to be updated. 存储桶中的ACL需要更新。

错误。ACL（访问控制列表）是S3的另一种权限管理机制，但题目明确提到问题是由于存储桶策略（bucket policy）导致的，因此与ACL无关。

B. The IAM policy does not allow the user to access the bucket. IAM策略不允许用户访问存储桶。

错误。虽然IAM策略也可以影响用户的权限，但题目中没有提到IAM策略的相关配置，问题的核心在于存储桶策略的配置。

C. It takes a few minutes for a bucket policy to take effect. 存储桶策略需要几分钟才能生效。

错误。S3存储桶策略的更改通常会立即生效，不需要等待几分钟。

D. The allow permission is being overridden by the deny. Most Voted 允许权限被拒绝权限覆盖。

正确。AWS权限规则中，“显式拒绝”优先级高于“显式允许”。由于存储桶策略中存在一个拒绝所有用户的声明（deny statement），即使后续添加了允许某个用户的声明，该用户仍然会被拒绝访问。

▼ 23

▼ 英文

A company is using Amazon Macie, AWS Firewall Manager, Amazon Inspector, and AWS Shield Advanced in its AWS account. The company wants to receive alerts if a DDoS attack occurs against the account.

Which solution will meet this requirement?

A. Use Macie to detect an active DDoS event. Create Amazon CloudWatch alarms that respond to Macie findings.

B. Use Amazon Inspector to review resources and to invoke Amazon CloudWatch alarms for any resources that are vulnerable to DDoS attacks.

C. Create an Amazon CloudWatch alarm that monitors Firewall Manager metrics for an active DDoS event.

D. Create an Amazon CloudWatch alarm that monitors Shield Advanced metrics for an active DDoS event.

▼ 中文

一家公司在其 AWS 帐户中使用 Amazon Macie、AWS Firewall Manager、Amazon Inspector 和 AWS Shield Advanced。该公司希望在帐户遭受 DDoS 攻击时收到警报。哪种解决方案可以满足这项需求？

A. 使用 Macie 检测活跃的 DDoS 事件。建立响应 Macie 发现结果的 Amazon CloudWatch 警报。

B. 使用 Amazon 检查器检查资源并对任何易受 DDoS 攻击的资源呼叫 Amazon CloudWatch 警报。

C. 建立 Amazon CloudWatch 警报，监控 Firewall Manager 指标中的活动 DDoS 事件。

D. 建立 Amazon CloudWatch 警报，监控活动 DDoS 事件的 Shield Advanced 指标。

▼ 解答

D

本题考察的是AWS服务的功能与用途，尤其是与安全相关的服务（Amazon Macie、AWS Firewall Manager、Amazon

Inspector、AWS Shield Advanced）的具体应用场景。

重点在于如何检测和响应DDoS攻击事件，以及如何利用AWS服务进行监控和告警。

1. 选项分析

A. 使用Macie检测活动的DDoS事件。创建响应Macie发现结果的Amazon CloudWatch警报。

错误：Amazon Macie主要用于数据安全和隐私保护，帮助识别敏感数据（如PII）并检测数据泄露风险。它不具备检测

DDoS攻击的功能。

B. 使用Amazon Inspector审查资源，并为任何易受DDoS攻击的资源触发Amazon CloudWatch警报。

错误：Amazon Inspector主要用于评估应用程序的安全性和漏洞扫描，帮助识别潜在的安全问题。

它不直接检测DDoS攻

击，也无法触发针对DDoS事件的告警。

C. 创建一个监控Firewall Manager指标以检测活动DDoS事件的Amazon CloudWatch警报。

错误：AWS Firewall Manager主要用于集中管理防火墙规则和策略，虽然可以与Shield Advanced集成，但它本身不直接

提供DDoS攻击检测功能。

D. 创建一个监控Shield Advanced指标以检测活动DDoS事件的Amazon CloudWatch警报。

正确：AWS Shield Advanced是专门设计用于保护应用程序免受DDoS攻击的服务。它提供了详细的攻击检测和响应功

能，并且可以通过CloudWatch监控其指标来触发告警。

▼ 24

▼ 英文

A company hosts a web application on an Apache web server. The application runs on Amazon EC2 instances that are in an Auto Scaling group. The company configured the EC2 instances to send the Apache web server logs to an Amazon CloudWatch Logs group that the company has configured to expire after 1 year.

Recently, the company discovered in the Apache web server logs that a specific IP address is sending suspicious requests to the web application. A security engineer wants to analyze the past week of Apache web server logs to determine how many requests that the IP address sent and the corresponding URLs that the IP address requested.

What should the security engineer do to meet these requirements with the LEAST effort?

A. Export the CloudWatch Logs group data to Amazon S3. Use Amazon Macie to query the logs for the specific IP address and the requested URL.

B. Configure a CloudWatch Logs subscription to stream the log group to an Amazon OpenSearch Service cluster. Use OpenSearch Service to analyze the logs for the specific IP address and the requested URLs.

C. Use CloudWatch Logs Insights and a custom query syntax to analyze the CloudWatch logs for the specific IP address and the requested URLs.

D. Export the CloudWatch Logs group data to Amazon S3. Use AWS Glue to crawl the S3 bucket for only the log entries that contain the specific IP address. Use AWS Glue to view the results.

▼ 中文

一家公司在 Apache Web 伺服器上託管一个 Web 應用程式。该應用程式在 Auto Scaling 群组中的 Amazon EC2 执行个体上执行。该公司配置了 EC2 实例，以将 Apache Web 伺服器日誌传送到 Amazon CloudWatch Logs 群组，并将该群组配置为 1 年后过期。

最近，该公司在 Apache Web 伺服器日志中发现，某个 IP 位址正在向该 Web 应用程序发送可疑请求。一位安全工程师想要分析过去一周的 Apache Web 伺服器日志，以确定该 IP 位址发送了多少个请求以及该 IP 位址请求的相应 URL。

这位安全工程师该如何以最少的努力来满足这些要求？

- A. 将 CloudWatch Logs 群组资料汇出到 Amazon S3。使用 Amazon Macie 查询特定 IP 位址和请求的 URL 的日志。
- B. 配置 CloudWatch Logs 订阅，将日志群组串流传输到 Amazon OpenSearch Service 丛集。使用 OpenSearch Service 分析特定 IP 位址和请求 URL 的日志。
- C. 使用 CloudWatch Logs Insights 和自订查询语法来分析特定 IP 位址和请求的 URL 的 CloudWatch 日志。
- D. 将 CloudWatch Logs 群组资料汇出到 Amazon S3。使用 AWS Glue 抓取 S3 储存桶中仅包含特定 IP 位址的日志条目。使用 AWS Glue 查看结果。

▼ 解答

C

1. 考察的知识点

CloudWatch Logs Insights的使用：如何使用CloudWatch Logs Insights进行日志查询和分析。

日志管理与分析：如何高效地分析日志数据以满足特定的安全需求。

AWS服务选择：根据需求选择最适合的AWS服务以实现目标。

2. 选项分析

A. Export the CloudWatch Logs group data to Amazon S3. Use Amazon Macie to query the logs for the specific IP address and the requested URL.

错误原因：Amazon Macie主要用于敏感数据发现和分类，而不是日志分析。使用Macie查询日志数据并不是其设计用途，因此不适合解决此问题。

途，因此不适合解决此问题。

B. Configure a CloudWatch Logs subscription to stream the log group to an Amazon OpenSearch Service cluster. Use

OpenSearch Service to analyze the logs for the specific IP address and the requested URLs.

错误原因：虽然OpenSearch Service可以用于日志分析，但设置CloudWatch Logs订阅并配置OpenSearch集群需要额外的

时间和资源，复杂度较高，不符合“最少努力”的要求。

C. Use CloudWatch Logs Insights and a custom query syntax to analyze the CloudWatch logs for the specific IP address and the requested URLs.

正确原因：CloudWatch Logs Insights是专门设计用于快速查询和分析CloudWatch日志的工具。它支持自定义查询语

法，可以直接在现有的日志组中分析数据，无需额外的配置或资源。

D. Export the CloudWatch Logs group data to Amazon S3. Use AWS Glue to crawl the S3 bucket for only the log entries that

contain the specific IP address. Use AWS Glue to view the results.

错误原因：将日志导出到S3并使用AWS Glue进行爬取和分析需要额外的步骤和配置，复杂度较高，不符合“最少努力”的要求。

▼ 25

▼ 英文

While securing the connection between a company's VPC and its on-premises data center, a security engineer sent a ping command from an on-premises host (IP address 203.0.113.12) to an

Amazon EC2 instance (IP address 172.31.16.139). The ping command did not return a response. The flow log in the VPC showed the following:

```
2 123456789010 eni-1235b8ca 203.0.113.12 172.31.16.139 0 0 1 4 336 1432917027 1432917142 ACCEPT OK
2 123456789010 eni-1235b8ca 172.31.16.139 203.0.113.12 0 0 1 4 336 1432917094 1432917142 REJECT OK
```

What action should be performed to allow the ping to work?

- A. In the security group of the EC2 instance, allow inbound ICMP traffic.
- B. In the security group of the EC2 instance, allow outbound ICMP traffic.
- C. In the VPC's NACL, allow inbound ICMP traffic.
- D. In the VPC's NACL, allow outbound ICMP traffic.

▼ 中文

在保护公司 VPC 与其本地资料中心之间的连线时，安全工程师从本机主机（IP 位址 203.0.113.12）向 Amazon EC2 执行个体（IP 位址 172.31.16.139）发送了 ping 指令。

ping 命令没有回传回应。VPC 中的流日志显示以下内容：

```
2 123456789010 eni-1235b8ca 203.0.113.12 172.31.16.139 0 0 1 4 336 1432917027 1432917142 ACCEPT OK
2 123456789010 eni-1235b8ca 172.31.16.139 203.0.113.12 0 0 1 4 336 1432917094 1432917142 REJECT OK
```

应执行什麼操作才能使 ping 正常运作？

- A. EC2 执行个体的安全性群组中，允许入站 ICMP 流量。
- B. 在 EC2 执行个体的安全性群组中，允许出站 ICMP 流量。
- C. 在 VPC 的 NACL 中，允许入站 ICMP 流量。
- D. 在 VPC 的 NACL 中，允许出站 ICMP 流量。

▼ 解答

D

1. 考察的知识点

本题考察的是AWS网络安全相关的知识点，包括VPC网络访问控制列表（NACL）和安全组的配置，以及如何排查网络连接问题。
具体涉及ICMP协议的流量控制和如何正确配置NACL以允许双向通信。

2. 选项分析

A. 在EC2实例的安全组中，允许入站ICMP流量。

- 错误。安全组是状态性的，允许入站流量后会自动允许相关的出站流量。根据流日志，入站流量已经被接受

（ACCEPT），问题出在出站流量被拒绝（REJECT）。因此修改安全组的入站规则无法解决问题。

B. 在EC2实例的安全组中，允许出站ICMP流量。

- 错误。虽然安全组控制出站流量，但流日志显示出站流量被NACL拒绝（REJECT）。安全组的出站规则已经不是问题

所在。

C. 在VPC的NACL中，允许入站ICMP流量。

- 错误。流日志显示入站流量已经被接受（ACCEPT），问题出在出站流量被拒绝（REJECT）。修改NACL的入站规则无法解决问题。

D. 在VPC的NACL中，允许出站ICMP流量。

- 正确。流日志显示出站流量被NACL拒绝（REJECT）。NACL是无状态的，需要显式允许出站ICMP流量才能解决问题。

▼ 26

▼ 英文

A company developed an application by using AWS Lambda, Amazon S3, Amazon Simple Notification Service (Amazon SNS), and Amazon DynamoDB. An external application puts objects into the company's S3 bucket and tags the objects with date and time. A Lambda function periodically pulls data from the company's S3 bucket based on date and time tags and inserts specific values into a DynamoDB table for further processing.

The data includes personally identifiable information (PII). The company must remove data that is older than 30 days from the S3 bucket and the DynamoDB table.

Which solution will meet this requirement with the MOST operational efficiency?

- A. Update the Lambda function to add a TTL S3 flag to S3 objects. Create an S3 Lifecycle policy to expire objects that are older than 30 days by using the TTL S3 flag.
- B. Create an S3 Lifecycle policy to expire objects that are older than 30 days. Update the Lambda function to add the TTL attribute in the DynamoDB table. Enable TTL on the DynamoDB table to expire entries that are older than 30 days based on the TTL attribute.
- C. Create an S3 Lifecycle policy to expire objects that are older than 30 days and to add all prefixes to the S3 bucket. Update the Lambda function to delete entries that are older than 30 days.
- D. Create an S3 Lifecycle policy to expire objects that are older than 30 days by using object tags. Update the Lambda function to delete entries that are older than 30 days.

▼ 中文

一家公司使用 AWS Lambda、Amazon S3、Amazon Simple Notification Service (Amazon SNS) 和 Amazon DynamoDB 开发了一款应用程序。外部应用程序将物件放入公司的 S3 储存桶中，并为物件新增日期和时间标籤。Lambda 函数会根据日期和时间标籤定期从公司的 S3 储存桶中提取数据，并将特定值插入 DynamoDB 表以进行进一步处理。

这些资料包含个人识别资讯 (PII)。该公司必须从 S3 储存桶和 DynamoDB 表中删除超过 30 天的资料。

哪种解决方案能够以最高的营运效率满足此要求？

- A. 更新 Lambda 函数，为 S3 物件新增 TTL S3 标誌。建立 S3 生命週期策略，使用 TTL S3 标誌使超过 30 天的物件过期。
- B. 建立 S3 生命週期策略，使超过 30 天的物件过期。更新 Lambda 函数，在 DynamoDB 表中加入 TTL 属性。在 DynamoDB 表上启用 TTL，根据 TTL 属性使超过 30 天的条目过期。

C.建立 S3 生命週期策略，使超过 30 天的物件过期，并将所有前缀新增至 S3 储存桶。更新 Lambda 函数以删除超过 30 天的条目。

D.建立 S3 生命週期策略，使用物件标籤使超过 30 天的物件过期。更新 Lambda 函数以删除超过 30 天的条目。

▼ 解答

B

1. 考察的知识点

Amazon S3 Lifecycle policies的使用和配置。

DynamoDB Time-to-Live (TTL)功能的使用。

如何设计高效的无服务器架构以满足数据生命周期管理需求。

数据隐私和合规性要求（如处理PII数据）。

2. 选项分析

A. 更新 Lambda 函数以向 S3 对象添加 TTL S3 标志。创建一个 S3 生命周期策略，通过使用 TTL S3 标志来过期超过 30 天的对象。

错误原因：

S3对象的生命周期策略不需要依赖自定义的TTL标志。S3 Lifecycle可以直接基于对象的创建日期来过期对象。

B. 创建一个 S3 生命周期策略以过期超过 30 天的对象。更新 Lambda 函数以在 DynamoDB 表中添加 TTL 属性。启

用 DynamoDB 表上的 TTL，以基于 TTL 属性过期超过 30 天的条目。

正确原因：

S3 Lifecycle策略可以直接管理S3对象的过期，无需额外的标志或复杂逻辑。

DynamoDB的TTL功能是专门设计用于自动删除过期数据的，使用TTL属性可以高效地管理数据生命周期。

此选项提供了最少的操作复杂性，同时满足了删除过期数据的需求。

C. 创建一个 S3 生命周期策略以过期超过 30 天的对象，并向 S3 bucket 添加所有前缀。更新 Lambda 函数以删除

超过 30 天的条目。

错误原因：

添加所有前缀并不必要，因为S3 Lifecycle策略可以直接基于对象的创建日期进行管理。

依赖Lambda函数来删除DynamoDB中的过期数据增加了操作复杂性，而DynamoDB TTL功能可以自动处理过期数据。

D. 创建一个 S3 生命周期策略以通过使用对象标签过期超过 30 天的对象。更新 Lambda 函数以删除超过 30 天的

条目。

错误原因：

虽然可以使用对象标签来管理S3生命周期，但这增加了额外的复杂性，因为需要确保所有对象都被正确地标记。

依赖Lambda函数来删除DynamoDB中的过期数据增加了操作复杂性，而DynamoDB TTL功能可以自动处理过期数据。

▼ 27

▼ 英文

What are the MOST secure ways to protect the AWS account root user of a recently opened AWS account? (Choose two.)

A. Use the AWS account root user access keys instead of the AWS Management Console.

- B. Enable multi-factor authentication for the AWS IAM users with the AdministratorAccess managed policy attached to them.
- C. Use AWS KMS to encrypt all AWS account root user and AWS IAM access keys and set automatic rotation to 30 days.
- D. Do not create access keys for the AWS account root user; instead, create AWS IAM users.
- E. Enable multi-factor authentication for the AWS account root user.

▼ 中文

保护最近开设的 AWS 帐户的 AWS 帐户根用户的最安全方法是什么？（选两个。）

- A. 使用 AWS 帐户根使用者存取金钥而不是 AWS 管理主控台。
- B. 为 AWS IAM 使用者启用多重验证，并附加 AdministratorAccess 託管原则。
- C. 使用 AWS KMS 加密所有 AWS 帐户根使用者和 AWS IAM 存取金钥，并将自动轮调设定为 30 天。
- D. 不要为 AWS 帐户根使用者建立存取金钥；而是建立 AWS IAM 使用者。
- E. 为 AWS 帐户根用户启用多重身份验证。

▼ 解答

DE

1. 考察的知识点

- 多重身份验证 (MFA) 的重要性。
- 使用 IAM 用户代替根用户进行日常操作的安全性。

2. 选项分析

- A. 使用 AWS 账户根用户访问密钥，而不是 AWS Management Console。
错误：根用户访问密钥的使用是一个安全风险，AWS 的最佳实践是避免为根用户创建访问密钥。根用户应仅用于账户设置或紧急情况。
- B. 为附有 AdministratorAccess 托管策略的 AWS IAM 用户启用多重身份验证。
错误：虽然为 IAM 用户启用 MFA 是一个良好的安全实践，但此选项与保护根用户无关。题目要求的是保护根用户，而不是 IAM 用户。
- C. 使用 AWS KMS 加密所有 AWS 账户根用户和 AWS IAM 访问密钥，并将自动轮换设置为 30 天。
错误：根用户不应该有访问密钥，因此加密和轮换根用户访问密钥是不必要的。此选项不符合 AWS 的最佳实践。
- D. 不要为 AWS 账户根用户创建访问密钥；相反，创建 AWS IAM 用户。
正确：AWS 的最佳实践是避免为根用户创建访问密钥，并使用 IAM 用户进行日常操作。这可以减少根用户的暴露风险。
- E. 为 AWS 账户根用户启用多重身份验证。
正确：启用 MFA 是保护根用户的关键步骤，可以显著提高账户的安全性。

▼ 28

▼ 英文

A company is expanding its group of stores. On the day that each new store opens, the company wants to launch a customized web application for that store. Each store's application will have a non-production environment and a production environment. Each environment will be deployed in a separate AWS account. The company uses AWS Organizations and has an OU that is used only

for these accounts.

The company distributes most of the development work to third-party development teams. A security engineer needs to ensure that each team follows the company's deployment plan for AWS resources. The security engineer also must limit access to the deployment plan to only the developers who need access. The security engineer already has created an AWS CloudFormation template that implements the deployment plan.

What should the security engineer do next to meet the requirements in the MOST secure way?

A. Create an AWS Service Catalog portfolio in the organization's management account. Upload the CloudFormation template. Add the template to the portfolio's product list. Share the portfolio with the OU.

B. Use the CloudFormation CLI to create a module from the CloudFormation template. Register the module as a private extension in the CloudFormation registry. Publish the extension. In the OU, create an SCP that allows access to the extension.

C. Create an AWS Service Catalog portfolio in the organization's management account. Upload the CloudFormation template. Add the template to the portfolio's product list. Create an IAM role that has a trust policy that allows cross-account access to the portfolio for users in the OU accounts. Attach the `AWSServiceCatalogEndUserFullAccess` managed policy to the role.

D. Use the CloudFormation CLI to create a module from the CloudFormation template. Register the module as a private extension in the CloudFormation registry. Publish the extension. Share the extension with the OU.

▼ 中文

一家公司正在扩张其门市集团。在每家新店开业当天，该公司都希望为其推出一个客製化的 Web 应用程序。每家门市的应用程序都将拥有一个非生产环境和一个生产环境。每个环境都将部署在一个单独的 AWS 帐户中。该公司使用 AWS Organizations，并拥有一个仅用于这些帐户的 OU。

该公司将大部分开发工作分配给第三方开发团队。安全工程师需要确保每个团队都遵循公司的 AWS 资源部署计画。此外，他还必须将部署计划的存取权限限制为仅需要存取权限的开发人员。安全工程师已经建立了一个用于实施部署计画的 AWS CloudFormation 范本。

为了以**最安全的方式满足要求**，安全工程师接下来该做什麼？

A. 在组织的主帐户中建立 AWS Service Catalog 产品组合。上传 CloudFormation 范本。将范本新增至产品组合的产品清单。与 OU 共享该产品组合。

B. 使用 CloudFormation CLI 从 CloudFormation 范本建立模组。在 CloudFormation 注册表中将该模组注册为私有扩充。发布该扩充功能。在 OU 中，建立允许存取该扩充功能的 SCP。

C. 在组织的主帐户中建立 AWS Service Catalog 产品组合。上传 CloudFormation 范本。将范本新增至产品组合的产品清单。建立一个 IAM 角色，该角色具有信任策略，允许 OU 帐户中的使用者跨帐户存取产品组合。将 `AWSServiceCatalogEndUserFullAccess` 託管策略附加到该角色。

D. 使用 CloudFormation CLI 从 CloudFormation 范本建立模组。在 CloudFormation 注册表中将该模组注册为私有扩充。发布该扩充功能。然后与 OU 共享该扩充功能。

▼ 解答

A

1. 考察的知识点

AWS Organizations的使用和管理，包括OU（组织单元）的权限管理。

AWS Service Catalog的功能和用途，特别是如何通过Service Catalog管理和分发CloudFormation模板。

安全性最佳实践，确保第三方开发团队只能访问必要的资源。

2. 选项分析

A.

正确：AWS Service Catalog允许集中管理和分发CloudFormation模板，并可以通过与OU共享组合（portfolio）来限制访问范围。

符合要求：通过Service Catalog可以确保开发团队只能访问指定的模板，同时可以限制访问权限到特定的OU。

B.

错误：虽然CloudFormation模块和私有扩展可以用于模板管理，但它不直接支持与OU共享，也无法通过SCP（Service Control Policy）实现细粒度的访问控制。不符合要求：这种方法复杂且不适合集中管理和分发模板。

C.

错误：虽然这种方法可以实现跨账户访问，但创建IAM角色并附加托管策略会增加权限范围，可能导致过度授权。

不符合要求：最安全的方式是直接通过OU共享组合，而不是通过IAM角色进行跨账户访问。

D.

错误：CloudFormation私有扩展的共享机制不支持直接与OU共享，且这种方法不适合集中管理和分发模板。

不符合要求：这种方法复杂且不符合题目要求的“最安全方式”。

▼ 29

▼ 英文

A team is using AWS Secrets Manager to store an application database password. Only a limited number of IAM principals within the account can have access to the secret. The principals who require access to the secret change frequently. A security engineer must create a solution that maximizes flexibility and scalability.

Which solution will meet these requirements?

A. Use a role-based approach by creating an IAM role with an inline permissions policy that allows access to the secret. Update the IAM principals in the role trust policy as required.

B. Deploy a VPC endpoint for Secrets Manager. Create and attach an endpoint policy that specifies the IAM principals that are allowed to access the secret. Update the list of IAM Principals as required.

C. Use a tag-based approach by attaching a resource policy to the secret. Apply tags to the secret and the IAM principals. Use the aws:PrincipalTag and aws:ResourceTag IAM condition keys to control access.

D. Use a deny-by-default approach by using IAM policies to deny access to the secret explicitly. Attach the policies to an IAM group. Add all IAM principals to the IAM group. Remove principals from the group when they need access. Add the principals to the group again when access is no longer allowed.

▼ 中文

一个团队正在使用 AWS Secrets Manager 储存应用程序资料库密码。帐户中只有有限数量的 IAM 主体可以存取该金钥。需要存取该金钥的主体经常会发生变化。安全工程师必须创建一个能够最大限度提高灵活性和可扩展性的解决方案。

哪种解决方案能够满足这些要求？

- A.使用基于角色的方法，建立一个具有内联权限策略的 IAM 角色，允许存取金钥。根据需要更新角色信任策略中的 IAM 主体。
- B.为Secrets Manager 部署VPC终端杰点。建立并附加终端节点策略，指定允许存取该金钥的IAM主体。根据需要更新IAM主体清单。
- C.使用基于标籤的方法，将资源策略附加到金钥。将标籤应用于金钥和 IAM 主体。使用 aws:PrincipalTag 和 aws:ResourceTag IAM 条件键来控制存取。
- D.使用预设拒绝方法，即使用 IAM 策略明确拒绝对金钥的存取。将政策附加到 IAM 群组。将所有 IAM 主体新增至该 IAM 群组。当主体需要存取权限时，将其从群组中删除。当不再允许存取时，将主体重新新增至群组。

▼ 解答

C

1. 考察的知识点

本题考察的是 AWS Secrets Manager 的访问控制策略，包括 IAM 策略、资源策略、标签策略等。重点在于如何设计一个灵活且可扩展的解决方案来管理对 Secrets Manager 密钥的访问权限。

2. 选项分析

A. 使用基于角色的方法，通过创建一个具有内联权限策略的 IAM 角色来允许访问密钥。根据需要更新角色信任策略中的 IAM 主体。

正确性分析：基于角色的方法可以实现访问控制，但需要频繁更新角色信任策略以添加或移除 IAM 主体。这种方法在频繁变更的场景下不够灵活和可扩展。

结论：此选项不符合题目要求。

B. 为 Secrets Manager 部署一个 VPC 端点。创建并附加一个端点策略，指定被允许访问密钥的 IAM 主体。根据需

要更新 IAM 主体列表。

正确性分析：VPC 端点策略主要用于控制网络访问，而不是直接管理 IAM 主体对 Secrets Manager 的权限。此方法无法有效解决频繁变更 IAM 主体的问题。

结论：此选项不符合题目要求。

C. 使用基于标签的方法，通过将资源策略附加到密钥上。将标签应用于密钥和 IAM 主体。使用 aws:PrincipalTag

和 aws:ResourceTag IAM 条件键来控制访问。

正确性分析：基于标签的方法非常灵活，可以通过标签动态管理访问权限。使用 aws:PrincipalTag 和 aws:ResourceTag

条件键可以实现精细化的权限控制，且无需频繁修改策略。

结论：此选项符合题目要求，是正确答案。

D. 使用默认拒绝的方法，通过使用 IAM 策略显式拒绝访问密钥。将这些策略附加到一个 IAM 组。将所有 IAM 主体添加到 IAM 组中。当主体需要访问时将其从组中移除。当不再允许访问时再次将主体添加到组中。

正确性分析：默认拒绝的方法不够灵活，频繁添加或移除 IAM 主体会增加管理复杂性。此外，显式拒绝策略可能会导致意外的权限问题。

结论：此选项不符合题目要求。

▼ 30

▼ 英文

A company is hosting a web application on Amazon EC2 instances behind an Application Load Balancer (ALB). The application has become the target of a DoS attack. Application logging shows that requests are coming from a small number of client IP addresses, but the addresses change

regularly.

The company needs to block the malicious traffic with a solution that requires the least amount of ongoing effort.

Which solution meets these requirements?

- A. Create an AWS WAF rate-based rule, and attach it to the ALB.
- B. Update the security group that is attached to the ALB to block the attacking IP addresses.
- C. Update the ALB subnet's network ACL to block the attacking client IP addresses.
- D. Create an AWS WAF rate-based rule, and attach it to the security group of the EC2 instances.

▼ 中文

一家公司在 Amazon EC2 执行个体上託管一个 Web 应用程序，该执行个体位于应用程式负载平衡器 (ALB) 后面。该应用程式已成为 DoS 攻击的目标。应用程式日誌显示，请求来自少数客户端 IP 位址，但这些位址经常变更。

该公司需要使用一种持续工作量最少的解决方案来阻止恶意流量。

哪种解决方案符合这些要求？

- A. 建立基于 AWS WAF 速率的规则，并将其附加到 ALB。
- B. 更新附加到 ALB 的安全群组以阻止攻击 IP 位置。
- C. 更新 ALB 子网路的网路 ACL 以阻止攻击用户端 IP 位址。
- D. 建立基于 AWS WAF 速率的规则，并将其附加到 EC2 执行个体的安全性群组。

▼ 解答

A

1. 考察的知识点

本题考察的是 AWS WAF (Web Application Firewall) 的功能，尤其是基于速率的规则 (Rate-based Rule) 如何帮助防御

DoS 攻击。

同时涉及到安全组和网络 ACL 的使用场景，以及它们与 WAF 的区别。

2. 选项分析

A. Create an AWS WAF rate-based rule, and attach it to the ALB.

正确：AWS WAF 可以创建基于速率的规则，用于检测和阻止来自特定 IP 地址的高频请求。将 WAF 规则附加到 ALB 可以直接保护 Web 应用免受 DoS 攻击。

最少的维护工作：WAF 规则可以自动检测和阻止恶意流量，无需手动更新 IP 地址。

B. Update the security group that is attached to the ALB to block the attacking IP addresses.

错误：安全组是静态的，需要手动更新规则以阻止攻击 IP 地址。由于攻击 IP 地址会定期变化，这种方法需要持续的人

工干预。

安全组不支持基于速率的规则，因此无法有效检测 DoS 攻击的模式。

C. Update the ALB subnet's network ACL to block the attacking client IP addresses.

错误：网络 ACL 是静态的，需要手动更新规则以阻止攻击 IP 地址。与安全组类似，这种方法需要持续的人工干预。

网络 ACL 不支持基于速率的规则，因此无法有效检测 DoS 攻击的模式。

D. Create an AWS WAF rate-based rule, and attach it to the security group of the EC2 instances.

错误：AWS WAF 无法直接附加到 EC2 实例的安全组。WAF 只能附加到支持的资源 (如 ALB、API

Gateway等)。

安全组本身不支持基于速率的规则，因此此选项不符合要求。

▼ 31

▼ 英文

A company has hundreds of AWS accounts in an organization in AWS Organizations. The company operates out of a single AWS Region. The company has a dedicated security tooling AWS account in the organization. The security tooling account is configured as the organization's delegated administrator for Amazon GuardDuty and AWS Security Hub. The company has configured the environment to automatically enable GuardDuty and Security Hub for existing AWS accounts and new AWS accounts.

The company is performing control tests on specific GuardDuty findings to make sure that the company's security team can detect and respond to security events. The security team launched an Amazon EC2 instance and attempted to run DNS requests against a test domain, example.com, to generate a DNS finding. However, the GuardDuty finding was never created in the Security Hub delegated administrator account.

Why was the finding was not created in the Security Hub delegated administrator account?

- A.VPC flow logs were not turned on for the VPC where the EC2 instance was launched.
- B.The VPC where the EC2 instance was launched had the DHCP option configured for a custom OpenDNS resolver.
- C.The GuardDuty integration with Security Hub was never activated in the AWS account where the finding was generated.
- D.Cross-Region aggregation in Security Hub was not configured.

▼ 中文

一家公司在 AWS Organizations 中的某个组织内拥有数百个 AWS 帐户。该公司在单一 AWS 区域内营运。该公司在组织内拥有一个专用的安全工具 AWS 帐户。此安全工具帐户配置为该组织的 Amazon GuardDuty 和 AWS Security Hub 委派管理员。该公司已将环境配置为自动为现有 AWS 帐户和新 AWS 帐户启用 GuardDuty 和 Security Hub。

该公司正在对特定的 GuardDuty 侦测结果执行控制测试，以确保该公司的安全团队能够侦测并回应安全事件。安全团队启动了一个 Amazon EC2 执行个体，并尝试针对测试网域 example.com 执行 DNS 请求以产生 DNS 侦测结果。但是，GuardDuty 检测结果从未在 Security Hub 委派管理员帐户中建立。

为什么未在 Security Hub 委派管理员帐户中建立该检测结果？

- A.启动 EC2 执行个体的 VPC 未启用 VPC 流日志。
- B.启动 EC2 执行个体的 VPC 已为自订 OpenDNS 解析器配置了 DHCP 选项。
- C.产生该发现的 AWS 帐户中从未启动 GuardDuty 与 Security Hub 的整合。
- D.未配置安全中心的跨区域聚合。

▼ 解答

B

1. 考察的知识点

Amazon GuardDuty的工作原理，包括如何生成DNS相关的安全发现。

VPC配置对GuardDuty发现的影响，例如DHCP选项集和自定义DNS解析器的使用。

GuardDuty与Security Hub的集成和跨账户、跨区域的配置。

2. 选项分析

A. VPC flow logs were not turned on for the VPC where the EC2 instance was launched.

错误：GuardDuty不依赖VPC流日志来生成DNS相关的发现。GuardDuty使用网络流量元数据和其他AWS服务的日志（如CloudTrail）来检测威胁。

B. The VPC where the EC2 instance was launched had the DHCP option configured for a custom OpenDNS resolver.

正确：GuardDuty依赖于AWS提供的默认DNS解析器来检测恶意活动。如果VPC配置了自定义的OpenDNS解析器，GuardDuty无法捕获DNS请求的相关元数据，因此不会生成DNS相关的发现。

C. The GuardDuty integration with Security Hub was never activated in the AWS account where the finding was generated.

错误：题目中明确提到GuardDuty和Security Hub已经在所有账户中自动启用，因此这个选项不符合题目描述。

D. Cross-Region aggregation in Security Hub was not configured.

错误：题目中没有提到跨区域配置的问题，并且跨区域聚合的配置与GuardDuty生成发现无关。即使没有跨区域聚合，发现仍然会在本地区域生成。

▼ 32

▼ 英文

An ecommerce company has a web application architecture that runs primarily on containers. The application containers are deployed on Amazon Elastic Container Service (Amazon ECS). The container images for the application are stored in Amazon Elastic Container Registry (Amazon ECR).

The company's security team is performing an audit of components of the application architecture. The security team identifies issues with some container images that are stored in the container repositories.

The security team wants to address these issues by implementing continual scanning and on-push scanning of the container images. The security team needs to implement a solution that makes any findings from these scans visible in a centralized dashboard. The security team plans to use the dashboard to view these findings along with other security-related findings that they intend to generate in the future. There are specific repositories that the security team needs to exclude from the scanning process.

Which solution will meet these requirements?

A. Use Amazon Inspector. Create inclusion rules in Amazon ECR to match repositories that need to be scanned. Push Amazon Inspector findings to AWS Security Hub.

B. Use ECR basic scanning of container images. Create inclusion rules in Amazon ECR to match repositories that need to be scanned. Push findings to AWS Security Hub.

C. Use ECR basic scanning of container images. Create inclusion rules in Amazon ECR to match repositories that need to be scanned. Push findings to Amazon Inspector.

D. Use Amazon Inspector. Create inclusion rules in Amazon Inspector to match repositories that need to be scanned. Push Amazon Inspector findings to AWS Config.

▼ 中文

一家电子商务公司拥有一个主要在容器上运行的 Web 应用程序架构。应用程序容器部署在 Amazon Elastic Container Service (Amazon ECS) 上。应用程序的容器镜像储存在 Amazon Elastic Container Registry (Amazon ECR) 中。

该公司的安全团队正在对应用程序架构的元件进行审计。安全团队发现储存在容器储存库中的某些容器镜像有问题。

安全团队希望透过对容器镜像实施持续扫描和推送扫描来解决这些问题。安全团队需要实施一种解决方案，使这些扫描的任何发现都显示在集中式控制面板中。安全团队计划使用控制面板查看这些发现以及他们打算在未来产生的其他安全相关发现。安全团队需要将某些特定的储存库排除在扫描过程之外。

哪种解决方案能够满足这些要求？

- A. 使用 Amazon Inspector。在 Amazon ECR 中建立包含规则，以符合需要扫描的储存库。将 Amazon Inspector 的发现结果推送至 AWS Security Hub。
- B. 使用 ECR 对容器镜像进行基本扫描。在 Amazon ECR 中建立包含规则，以符合需要扫描的储存库。将扫描结果推送至 AWS Security Hub。
- C. 使用 ECR 对容器镜像进行基本扫描。在 Amazon ECR 中建立包含规则，以符合需要扫描的储存库。将发现结果推送至 Amazon Inspector。
- D. 在 Amazon Inspector 中建立包含规则，以符合需要扫描的储存库。将 Amazon Inspector 的发现结果推送至 AWS Config。

▼ 解答

A

1. 考察的知识点

Amazon Inspector的功能和用途，特别是对容器镜像的扫描能力。
Amazon ECR的容器镜像扫描功能，包括基本扫描和高级扫描。
AWS Security Hub的集成能力，用于集中管理和查看安全发现。
如何创建包含规则以选择特定的仓库进行扫描。

2. 选项分析

A. Use Amazon Inspector. Create inclusion rules in Amazon ECR to match repositories that need to be scanned. Push Amazon Inspector findings to AWS Security Hub.

Amazon Inspector支持对ECR中的容器镜像进行高级扫描，包括持续扫描和推送扫描。
可以在Amazon ECR中创建包含规则以选择需要扫描的仓库。

Amazon Inspector的发现可以直接推送到AWS Security Hub，用于集中管理和查看安全发现。
此选项完全满足题目要求，因此是正确答案。

B. Use ECR basic scanning of container images. Create inclusion rules in Amazon ECR to match repositories that need to be scanned. Push findings to AWS Security Hub.

ECR基本扫描功能仅支持手动扫描，不支持持续扫描和推送扫描。

虽然可以创建包含规则，但基本扫描的功能不足以满足题目中“持续扫描”和“推送扫描”的要求。
此选项不符合题目要求，因此是错误答案。

C. Use ECR basic scanning of container images. Create inclusion rules in Amazon ECR to match repositories that need to be scanned. Push findings to Amazon Inspector.

ECR基本扫描功能仅支持手动扫描，不支持持续扫描和推送扫描。

Amazon Inspector是一个独立的服务，ECR的发现无法直接推送到Amazon Inspector。此选项在技术上不可行，因此是错误答案。

D. Use Amazon Inspector. Create inclusion rules in Amazon Inspector to match repositories that need to be scanned. Push

Amazon Inspector findings to AWS Config.

Amazon Inspector支持对ECR中的容器镜像进行高级扫描。

题目要求将发现推送到AWS Security Hub，而不是AWS Config。AWS Config主要用于资源配置合规性检查，不适合集中

管理安全发现。

此选项不符合题目要求，因此是错误答案。

▼ 33

▼ 英文

A company has a single AWS account and uses an Amazon EC2 instance to test application code. The company recently discovered that the instance was compromised. The instance was serving up malware. The analysis of the instance showed that the instance was compromised 35 days ago.

A security engineer must implement a continuous monitoring solution that automatically notifies the company's security team about compromised instances through an email distribution list for high severity findings. The security engineer must implement the solution as soon as possible.

Which combination of steps should the security engineer take to meet these requirements? (Choose three.)

A.Enable AWS Security Hub in the AWS account.

B.Enable Amazon GuardDuty in the AWS account.

C.Create an Amazon Simple Notification Service (Amazon SNS) topic. Subscribe the security team's email distribution list to the topic.

D.Create an Amazon Simple Queue Service (Amazon SQS) queue. Subscribe the security team's email distribution list to the queue.

E.Create an Amazon EventBridge rule for GuardDuty findings of high severity. Configure the rule to publish a message to the topic.

F.Create an Amazon EventBridge rule for Security Hub findings of high severity. Configure the rule to publish a message to the queue.

▼ 中文

一家公司拥有一个 AWS 帐户，并使用 Amazon EC2 执行个体测试应用程序程式码。该公司最近发现该实例遭到入侵。该实例正在提供恶意软体。对此实例的分析表明，该实例在 35 天前遭到入侵。安全工程师必须实施一套持续监控解决方案，该解决方案会透过电子邮件分发列表自动通知公司安全团队有关被入侵实例的信息，以发现高严重程度的入侵事件。安全工程师必须尽快实施该解决方案。

安全工程师应该采取哪些步骤组合来满足这些要求？（选择三项。）

- A.在 AWS 帐户中启用 AWS Security Hub。
- B.在 AWS 帐户中启用 Amazon GuardDuty。
- C.建立一个 Amazon Simple Notification Service (Amazon SNS) 主题。将安全团队的电子邮件分发清单订阅到该主题。
- D.建立 Amazon Simple Queue Service (Amazon SQS) 队列。将安全团队的电子邮件分发清单订阅到该队列。
- E.为高严重性的GuardDuty 发现建立Amazon EventBridge规则。配置该规则以向主题发布讯息。
- F.针对高严重性的 Security Hub 发现建立 Amazon EventBridge 规则。配置该规则以将讯息发布到队列。

▼ 解答

BCE

1. 考察的知识点

Amazon GuardDuty的功能和用途：检测和监控AWS账户中的恶意活动。

AWS Security Hub的功能：集中管理和分析安全事件。

Amazon SNS的功能：用于发送通知到订阅的目标，例如电子邮件分发列表。

Amazon EventBridge的功能：创建规则以自动响应事件并触发操作。

2. 选项分析

A. Enable AWS Security Hub in the AWS account.

分析：虽然Security Hub可以集中管理安全事件，但题目要求的是“尽快实现解决方案”，而GuardDuty更适合快速检测恶意活动。此选项不是必须的，因此错误。

B. Enable Amazon GuardDuty in the AWS account.

分析：GuardDuty是专门用于检测恶意活动的服务，能够快速发现被入侵的实例并生成高严重性发现。此选项正确。

C. Create an Amazon Simple Notification Service (Amazon SNS) topic. Subscribe the security team's email distribution list to the topic.

分析：SNS可以将通知发送到安全团队的电子邮件分发列表，满足题目要求的“自动通知”。此选项正确。

D. Create an Amazon Simple Queue Service (Amazon SQS) queue. Subscribe the security team's email distribution list to the queue.

分析：SQS是消息队列服务，适合异步处理消息，但不直接支持发送通知到电子邮件分发列表。此选项错误。

E. Create an Amazon EventBridge rule for GuardDuty findings of high severity. Configure the rule to publish a message to the topic.

分析：EventBridge可以根据GuardDuty的高严重性发现触发规则，并将消息发布到SNS主题，从而实现自动通知。此选项正确。

F. Create an Amazon EventBridge rule for Security Hub findings of high severity. Configure the rule to publish a message to the queue.

分析：题目要求的是GuardDuty的高严重性发现，而不是Security Hub的发现。此外，消息发布到队列不符合题目要求的“发送通知到电子邮件分发列表”。此选项错误。

▼ 英文

A company uses identity federation to authenticate users into an identity account (987654321987) where the users assume an IAM role named IdentityRole. The users then assume an IAM role named JobFunctionRole in the target AWS account (123456789123) to perform their job functions.

A user is unable to assume the IAM role in the target account. The policy attached to the role in the identity account is:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": [
        "sts:AssumeRole"
      ],
      "Resource": [
        "arn:aws:iam::*:role/JobFunctionRole"
      ],
      "Effect": "Allow"
    }
  ]
}
```

What should be done to enable the user to assume the appropriate role in the target account?

A. Update the IAM policy attached to the role in the identity account to be:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": [
        "sts:AssumeRole"
      ],
      "Resource": [
        "arn:aws:iam::123456789123:role/JobFunctionRole"
      ],
      "Effect": "Allow"
    }
  ]
}
```

B. Update the trust policy on the role in the target account to be:

C. Update the trust policy on the role in the identity account to be:

D. Update the IAM policy attached to the role in the target account to be:

▼ 中文

一家公司使用身分联合来对身分识别帐户 (987654321987) 中的使用者进行身分验证，其中使用者承担名为 IdentityRole 的 IAM 角色。然后，使用者在目标 AWS 帐户 (123456789123) 中承担名为 JobFunctionRole 的 IAM 角色来执行其工作职能。

使用者无法承担目标帐户中的 IAM 角色。身分帐户中角色所附加的策略是：

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": [
        "sts:AssumeRole"
      ],
      "Resource": [
        "arn:aws:iam::*:role/JobFunctionRole"
      ],
      "Effect": "Allow"
    }
  ]
}
```

应该怎么做才能使用户在目标帐户中承担适当的角色？

A.将身分帐户中附加到角色的 IAM 策略更新为：

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": [
        "sts:AssumeRole"
      ],
      "Resource": [
        "arn:aws:iam::123456789123:role/JobFunctionRole"
      ],
      "Effect": "Allow"
    }
  ]
}
```

B.将目标帐号中角色的信任策略更新为：

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::987654321987:role/IdentityRole"
      },
      "Action": "sts:AssumeRole"
    }
  ]
}
```

C.将身分帐户中的角色的信任策略更新为：

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": { "AWS": "arn:aws:iam::987654321987:root" },
      "Action": "sts:AssumeRole"
    }
  ]
}
```

D.将附加到目标帐户中的角色的 IAM 策略更新为：

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "Stmt1502946463000",
      "Effect": "Allow",
      "Action": "sts:AssumeRole",
      "Resource": "arn:aws:iam::123456789123:role/JobFunctionRole"
    }
  ]
}
```

▼ 解答

B

1. 考察的知识点

跨账户角色信任策略配置

STS服务的使用（AssumeRole）

IAM角色的权限与信任关系

2. 选项分析

A. Update the IAM policy attached to the role in the identity account to be:

错误。身份账户中的IAM策略已经允许用户调用 `sts:AssumeRole` 操作，并且资源指定为

`arn:aws:iam::*:role/JobFunctionRole`，这已经正确配置了权限。问题不在于身份账户的IAM策略，而在于目标账户的信任策略。

B. Update the trust policy on the role in the target account to be:

正确。目标账户中的 `JobFunctionRole` 需要信任身份账户中的 `IdentityRole`，以便允许身份账户的用户通过

`sts:AssumeRole` 来访问目标账户的资源。如果信任策略未正确配置，用户将无法跨账户访问。

C. Update the trust policy on the role in the identity account to be:

错误。身份账户中的 `IdentityRole` 的信任策略与问题无关，因为问题发生在目标账户的角色信任策略配置上。

D. Update the IAM policy attached to the role in the target account to be:

错误。目标账户中的IAM策略控制的是角色的权限，而不是信任关系。问题的核心是信任策略，而不是IAM权限策略。

▼ 35

▼ 英文

A company is using AWS Organizations to manage multiple AWS accounts for its human resources, finance, software development, and production departments. All the company's developers are part of the software development AWS account.

The company discovers that developers have launched Amazon EC2 instances that were preconfigured with software that the company has not approved for use. The company wants to implement a solution to ensure that developers can launch EC2 instances with only approved software applications and only in the software development AWS account.

Which solution will meet these requirements?

A. In the software development account, create AMIs of preconfigured instances that include only approved software. Include the AMI IDs in the condition section of an AWS CloudFormation template to launch the appropriate AMI based on the AWS Region. Provide the developers with the CloudFormation template to launch EC2 instances in the software development account.

B. Create an Amazon EventBridge rule that runs when any EC2 RunInstances API event occurs in the software development account. Specify AWS Systems Manager Run Command as a target of the rule. Configure Run Command to run a script that will install approved software onto the instances that the developers launch.

C. Use an AWS Service Catalog portfolio that contains EC2 products with appropriate AMIs that include only approved software. Grant the developers permission to access only the Service Catalog portfolio to launch a product in the software development account.

D. In the management account, create AMIs of preconfigured instances that include only approved software. Use AWS CloudFormation StackSets to launch the AMIs across any AWS account in the organization. Grant the developers permission to launch the stack sets within the management account.

▼ 中文

一家公司正在使用 AWS Organizations 管理其人力资源、财务、软件开发和生产部门的多个 AWS 帐户。该公司的所有开发人员都属于软件开发 AWS 帐户。

该公司发现，开发人员启动的 Amazon EC2 执行个体预先配置了该公司尚未批准使用的软件。该公司希望实施一项解决方案，以确保开发人员只能在软件开发 AWS 帐户中启动已批准的软件应用程序的 EC2 执行个体。

哪种解决方案能够满足这些要求？

A:在软件开发帐户中，建立预先设定执行个体的 AMI，这些执行个体仅包含已核准的软体。将 AMI ID 新增至 AWS CloudFormation 范本的条件部分，以便根据 AWS 区域启动对应的 AMI。向开发人员提供 CloudFormation 模板，以便在软件开发帐户中启动 EC2 执行个体。

B:建立一条 Amazon EventBridge 规则，当软件开发帐户中发生任何 EC2 RunInstances API 事件时执行。指定AWS Systems Manager Run Command 作为该规则的目标。配置 Run Command 以执行脚本，该脚本会将所有已批准的软体安装到开发人员启动的实例上。

C:使用包含 EC2 产品的 AWS Service Catalog 产品组合，并搭配对应的 AMI，且仅含已核准的软体。授予开发人员仅存取 Service Catalog 产品组合的权限，以便在软件开发帐户中启动产品。

D:在管理帐户中，建立预先设定执行个体的 AMI，这些执行个体仅包含已核准的软体。使用 AWS CloudFormation StackSets 在组织中的任何AWS 帐户中启动 AMI。授予开发人员在管理帐户中启动堆叠集的权限。

▼ 解答

C

1. 考察的知识点

AWS Service Catalog的使用与权限管理。

如何限制开发人员使用预配置的资源。

跨账户资源管理与部署的最佳实践。

2. 选项分析

A. 在软件开发账户中，创建仅包含批准软件的预配置实例的AMIs，并使用CloudFormation模板：

此选项提供了一种方法来限制开发人员使用特定的AMI，但它依赖开发人员正确使用CloudFormation模板。开发人员仍

然可以绕过模板直接启动未经批准的AMI，因此无法完全满足要求。

错误原因：无法强制开发人员仅使用指定的AMI。

B. 使用Amazon EventBridge规则和AWS Systems Manager Run Command：

此选项试图通过事件触发脚本来安装批准的软件，但它无法阻止开发人员启动未经批准的AMI。此方法是事后补救，而不是预防措施。

错误原因：无法确保开发人员仅启动包含批准软件的实例。

C. 使用AWS Service Catalog组合：

此选项通过Service Catalog提供了一个集中管理的解决方案，开发人员只能访问包含批准软件的EC2产品。ServiceCatalog可以强制开发人员仅使用预配置的资源。

正确原因：完全满足要求，确保开发人员只能启动包含批准软件的实例。

D. 在管理账户中创建AMIs并使用CloudFormation StackSets：

此选项试图通过管理账户集中管理资源，但开发人员需要额外的权限来操作StackSets，且此方法复杂度较高。它也无

法限制开发人员在软件开发账户中直接启动未经批准的AMI。

错误原因：无法完全满足要求，且复杂度较高。

▼ 36

▼ 英文

A company has enabled Amazon GuardDuty in all AWS Regions as part of its security monitoring strategy. In one of its VPCs, the company hosts an Amazon EC2 instance that works as an FTP server. A high number of clients from multiple locations contact the FTP server. GuardDuty identifies this activity as a brute force attack because of the high number of connections that happen every hour.

The company has flagged the finding as a false positive, but GuardDuty continues to raise

the issue. A security engineer must improve the signal-to-noise ratio without compromising the company's visibility of potential anomalous behavior.

Which solution will meet these requirements?

- A. Disable the FTP rule in GuardDuty in the Region where the FTP server is deployed.
- B. Add the FTP server to a trusted IP list. Deploy the list to GuardDuty to stop receiving the notifications.
- C. Create a suppression rule in GuardDuty to filter findings by automatically archiving new findings that match the specified criteria.
- D. Create an AWS Lambda function that has the appropriate permissions to delete the finding whenever a new occurrence is reported.

▼ 中文

一家公司已在其所有 AWS 区域启用 Amazon GuardDuty，作为其安全监控策略的一部分。在其中一个 VPC 中，该公司托管了一个用作 FTP 服务器的 Amazon EC2 执行个体。大量来自各个位置的客户端连接该 FTP 服务器。由于每小时发生的连接次数众多，GuardDuty 将此活动识别为暴力攻击。

该公司已将此发现标记为误报，但 GuardDuty 仍继续提出该问题。安全工程师必须在 **不影响公司对潜在异常行为的可见性的情况下提高讯号杂讯比**。

哪种解决方案能够满足这些要求？

- A: 在部署 FTP 服务器的区域中停用 GuardDuty 中的 FTP 规则。
- B: 将 FTP 服务器新增至受信任的 IP 清单。将该清单部署到 GuardDuty 以停止接收通知。
- C: 在 GuardDuty 中建立抑制规则，透过自动存档符合指定条件的新发现来过滤发现。
- D: 建立一个具有适当权限的 AWS Lambda 函数，以便在报告新事件时删除该发现。

▼ 解答

C

1. 考察的知识点

Amazon GuardDuty 的功能和配置，包括如何处理误报 (False Positive)。
如何优化信号与噪声比 (Signal-to-Noise Ratio) 以减少不必要的警报。
GuardDuty 的抑制规则 (Suppression Rules) 和可信 IP 列表 (Trusted IP List) 的使用场景。

2. 选项分析

A. 禁用 GuardDuty 中的 FTP 规则：

错误。禁用 FTP 规则会完全关闭对 FTP 相关活动的监控，这可能导致真正的异常行为无法被检测到，从而降低安全性。

这种方法不符合题目要求的“改善信号与噪声比，同时保持对潜在异常行为的可见性”。

B. 将 FTP 服务器添加到可信 IP 列表：

错误。可信 IP 列表的作用是忽略来自指定 IP 地址的流量，但题目中提到的是“多个位置的客户端”连接 FTP 服务器，而不是单一 IP 地址。因此，这种方法无法解决问题。

C. 创建抑制规则：

正确。抑制规则允许用户根据指定的条件自动归档 GuardDuty 的发现，从而减少噪声，同时保留对其他潜在异常行为的监控。这种方法符合题目要求。

D. 创建 AWS Lambda 函数删除发现：

错误。使用 Lambda 函数删除发现是一种被动处理方式，无法从根本上改善信号与噪声比。此外，这

种方法需要额外的
开发和维护工作，效率较低。

▼ 37

▼ 英文

A company is running internal microservices on Amazon Elastic Container Service (Amazon ECS) with the Amazon EC2 launch type. The company is using Amazon Elastic Container Registry (Amazon ECR) private repositories.

A security engineer needs to encrypt the private repositories by using AWS Key Management Service (AWS KMS). The security engineer also needs to analyze the container images for any common vulnerabilities and exposures (CVEs).

Which solution will meet these requirements?

A. Enable KMS encryption on the existing ECR repositories. Install Amazon Inspector Agent from the ECS container instances' user data. Run an assessment with the CVE rules.

B. Recreate the ECR repositories with KMS encryption and ECR scanning enabled. Analyze the scan report after the next push of images.

C. Recreate the ECR repositories with KMS encryption and ECR scanning enabled. Install AWS Systems Manager Agent on the ECS container instances. Run an inventory report.

D. Enable KMS encryption on the existing ECR repositories. Use AWS Trusted Advisor to check the ECS container instances and to verify the findings against a list of current CVEs.

▼ 中文

一家公司正在 Amazon Elastic Container Service (Amazon ECS) 上执行内部微服务，启动类型为 Amazon EC2。该公司正在使用 Amazon Elastic Container Registry (Amazon ECR) 私人储存库。一位安全工程师需要使用 AWS Key Management Service (AWS KMS) 加密这些私人储存库。此外，这位安全工程师还需要分析容器镜像中是否存在任何常见漏洞和暴露 (CVE)。

哪种解决方案能够满足这些要求？

A: 在现有的 ECR 储存库上启用 KMS 加密。从 ECS 容器执行个体的使用者资料安装 Amazon Inspector 代理程式。使用 CVE 规则运行评估。

B: 重新建立 ECR 仓库，并启用 KMS 加密和 ECR 扫描。下次推送镜像后，分析扫描报告。

C: 重新建立 ECR 储存库，并启用 KMS 加密和 ECR 扫描。在 ECS 容器执行个体上安装 AWS Systems Manager 代理程式。运行清单报告。

D: 在现有 ECR 储存库上启用 KMS 加密。使用 AWS Trusted Advisor 检查 ECS 容器实例，并根据目前 CVE 清单验证结果。

▼ 解答

B

1. 考察的知识点

Amazon Elastic Container Registry (ECR) 的加密功能，特别是使用 AWS Key Management Service (KMS) 进行加密。

ECR 扫描功能，用于检测容器镜像中的常见漏洞和暴露 (CVEs)。

如何正确配置和使用 AWS 服务以满足安全需求。

2. 选项分析

A. Enable KMS encryption on the existing ECR repositories. Install Amazon Inspector Agent

from the ECS container instances'

user data. Run an assessment with the CVE rules.

错误原因：Amazon Inspector 主要用于评估 EC2 实例的安全性，而不是直接用于扫描 ECR 容器镜像的漏洞。ECR 的漏

洞扫描功能是内置的，不需要额外安装 Amazon Inspector。

正确部分：启用 KMS 加密是满足加密需求的正确步骤。

B. Recreate the ECR repositories with KMS encryption and ECR scanning enabled. Analyze the scan report after the next push of images.

正确原因：ECR 支持通过 KMS 加密存储库，并且可以启用内置的扫描功能来检测容器镜像中的漏洞。重新创建存储库并启用这些功能是满足题目要求的正确方法。

正确部分：分析扫描报告是检测 CVE 的正确步骤。

C. Recreate the ECR repositories with KMS encryption and ECR scanning enabled. Install AWS Systems Manager Agent on the ECS container instances. Run an inventory report.

错误原因：AWS Systems Manager Agent 主要用于管理 EC2 实例或其他资源的配置，而不是用于扫描容器镜像的漏洞。

运行库存报告无法满足 CVE 分析的需求。

正确部分：重新创建存储库并启用 KMS 加密和扫描功能是正确的。

D. Enable KMS encryption on the existing ECR repositories. Use AWS Trusted Advisor to check the ECS container instances and to verify the findings against a list of current CVEs.

错误原因：AWS Trusted Advisor 主要用于提供成本优化、安全性、性能和服务限制的建议，而不是用于扫描容器镜像

的漏洞。它无法直接分析 CVE。

正确部分：启用 KMS 加密是满足加密需求的正确步骤。

▼ 38

▼ 英文

A company's security engineer has been tasked with restricting a contractor's IAM account access to the company's Amazon EC2 console without providing access to any other AWS services. The contractor's IAM account must not be able to gain access to any other AWS service, even if the IAM account is assigned additional permissions based on IAM group membership.

What should the security engineer do to meet these requirements?

A. Create an inline IAM user policy that allows for Amazon EC2 access for the contractor's IAM user.

B. Create an IAM permissions boundary policy that allows Amazon EC2 access. Associate the contractor's IAM account with the IAM permissions boundary policy.

C. Create an IAM group with an attached policy that allows for Amazon EC2 access. Associate the contractor's IAM account with the IAM group.

D. Create a IAM role that allows for EC2 and explicitly denies all other services. Instruct the contractor to always assume this role.

▼ 中文

一家公司的安全工程師接到一項任務，限制承包商的 IAM 帳戶存取公司 Amazon EC2 控制台，但不授予其存取任何其他 AWS 服務的權限。即使該 IAM 帳戶根據 IAM 群組成員身分被指派了額外權限，該承包

商的 IAM 帳戶也不得存取任何其他 AWS 服務。

安全工程師應該如何滿足這些要求？

A:建立內嵌 IAM 使用者策略，允許承包商的 IAM 使用者存取 Amazon EC2。

B:建立允許Amazon EC2 存取的 IAM 權限邊界原則。將承包商的 IAM 帳戶與 IAM 權限邊界策略關聯。

C:建立一個 IAM 群組，並附加允許 Amazon EC2 存取的政策。將承包商的 IAM 帳戶與該 IAM 群組關聯。

D:建立一個允許 EC2 存取並明確拒絕所有其他服務的 IAM 角色。指示承包商始終承擔此角色。

▼ 解答

B

1. 考察的知识点

IAM權限邊界的使用及其作用。

如何限制IAM用戶的權限以確保安全性。

IAM策略的類型（如內聯策略、權限邊界、組策略、角色）。

2. 選項分析

A.

內聯IAM用戶策略可以直接限制用戶的權限，但它無法防止用戶通過其他方式（如IAM組或其他策略）獲得額外權限。

因此，這種方法無法滿足題目要求，即“即使通過IAM組分配額外權限，也不能訪問其他服務”。

錯誤原因：無法完全限制用戶權限。

B.

權限邊界是一種高級IAM功能，用於限制用戶或角色的最大權限。

即使用戶被分配了額外的權限（例如通過IAM組），權限邊界仍然會限制用戶只能訪問Amazon EC2。這種方法完全符合題目要求。

正確原因：權限邊界可以確保用戶無法獲得超出邊界的權限。

C.

IAM組策略可以為用戶分配權限，但它無法防止用戶通過其他方式（如直接分配策略或其他組）獲得額外權限。

因此，這種方法無法滿足題目要求。

錯誤原因：無法完全限制用戶權限。

D.

IAM角色可以限制權限，但用戶仍然可以通過其他方式（如直接分配策略或IAM組）獲得額外權限。

此外，用戶必須始終假設角色，這可能不符合實際使用場景的便利性要求。

錯誤原因：無法完全限制用戶權限，且操作複雜。

▼ 39

▼ 英文

A company manages multiple AWS accounts using AWS Organizations. The company's security team notices that some member accounts are not sending AWS CloudTrail logs to a centralized Amazon S3 logging bucket. The security team wants to ensure there is at least one trail configured for all existing accounts and for any account that is created in the future.

Which set of actions should the security team implement to accomplish this?

A.Create a new trail and configure it to send CloudTrail logs to Amazon S3. Use Amazon EventBridge to send notification if a trail is deleted or stopped.

B.Deploy an AWS Lambda function in every account to check if there is an existing trail and create a new trail, if needed.

C. Edit the existing trail in the Organizations management account and apply it to the organization.

D. Create an SCP to deny the cloudtrail:Delete* and cloudtrail:Stop* actions. Apply the SCP to all accounts.

▼ 中文

一家公司使用 AWS Organizations 管理多个 AWS 帐户。该公司的安全团队注意到，一些成员帐户没有将 AWS CloudTrail 日志传送到集中式 Amazon S3 日志存储桶。安全团队希望确保所有现有帐户以及未来建立的任何帐户至少配置一个追踪。

安全团队应该采取哪些措施来实现此目标？

A: 建立新的追踪并将其配置为将 CloudTrail 日志传送到 Amazon S3。如果追踪被删除或停止，请使用 Amazon EventBridge 发送通知。

B: 在每个帐户中部署一个 AWS Lambda 函数来检查是否有现有跟踪，并在需要时建立新的追踪。

C: 编辑组织管理帐户中的现有追踪并将其应用于组织。

D: 建立一个 SCP 来拒绝 cloudtrail:Delete* 和 cloudtrail:Stop* 操作。将该 SCP 应用于所有帐户。

▼ 解答

C

1. 考察的知识点

AWS Organizations 的集中管理功能。

AWS CloudTrail 的配置与管理。

如何确保所有帐户都启用 CloudTrail 并发送日志到集中存储。

Service Control Policies (SCP) 的使用。

2. 选项分析

A. Create a new trail and configure it to send CloudTrail logs to Amazon S3. Use Amazon EventBridge to send notification if a trail is deleted or stopped.

正确性分析：创建一个新的 trail 并发送日志到 S3 是一个可行的解决方案，但它无法确保所有现有帐户和未来创建的帐户都启用 CloudTrail。

错误原因：EventBridge 只能发送通知，无法强制所有帐户启用 CloudTrail，也无法覆盖未来创建的帐户。

B. Deploy an AWS Lambda function in every account to check if there is an existing trail and create a new trail, if needed.

正确性分析：使用 Lambda 函数可以检查和创建 trail，但需要在每个帐户中部署 Lambda，管理复杂性高。

错误原因：这种方法无法自动覆盖未来创建的帐户，且需要额外的运维工作。

C. Edit the existing trail in the Organizations management account and apply it to the organization.

正确性分析：通过 Organizations 管理帐户编辑 trail 并应用到整个组织，可以确保所有现有帐户和未来创建的帐户都启用 CloudTrail。

正确原因：这是 AWS 推荐的集中管理 CloudTrail 的最佳实践，能够覆盖所有帐户。

D. Create an SCP to deny the cloudtrail:Delete* and cloudtrail:Stop* actions. Apply the SCP to all accounts.

正确性分析：SCP 可以防止删除或停止 CloudTrail，但无法确保所有帐户都启用 CloudTrail。

错误原因：SCP 只能限制操作权限，无法强制创建或启用 CloudTrail。

▼ 40

▼ 英文

A company recently had a security audit in which the auditors identified multiple potential threats. These potential threats can cause usage pattern changes such as DNS access peak, abnormal instance traffic, abnormal network interface traffic, and unusual Amazon S3 API calls. The threats can come from different sources and can occur at any time. The company needs to implement a solution to continuously monitor its system and identify all these incoming threats in near-real time.

Which solution will meet these requirements?

- A. Enable AWS CloudTrail logs, VPC flow logs, and DNS logs. Use Amazon CloudWatch Logs to manage these logs from a centralized account.
- B. Enable AWS CloudTrail logs, VPC flow logs, and DNS logs. Use Amazon Macie to monitor these logs from a centralized account.
- C. Enable Amazon GuardDuty from a centralized account. Use GuardDuty to manage AWS CloudTrail logs, VPC flow logs, and DNS logs.
- D. Enable Amazon Inspector from a centralized account. Use Amazon Inspector to manage AWS CloudTrail logs, VPC flow logs, and DNS logs.

▼ 中文

一家公司最近进行了安全审计，审计人员发现了多种潜在威胁。这些潜在威胁可能导致使用模式发生变化，例如 DNS 存取峰值、实例流量异常、网路介面流量异常以及 Amazon S3 API 呼叫异常。这些威胁可能来自不同来源，并且可能随时发生。该公司需要实施一项解决方案来持续监控系统，并近乎即时地识别所有这些传入威胁。

哪种解决方案能够满足这些要求？

- A: 启用 AWS CloudTrail 日志、VPC 流日志和 DNS 日志。使用 Amazon CloudWatch Logs 从集中帐户管理这些日志。
- B: 启用 AWS CloudTrail 日志、VPC 流日志和 DNS 日志。使用 Amazon Macie 从集中帐户监控这些日志。
- C: 从集中帐户启用 Amazon GuardDuty。使用 GuardDuty 管理 AWS CloudTrail 日志、VPC 串流日志和 DNS 日志。
- D: 从集中式帐户启用 Amazon Inspector。使用 Amazon Inspector 管理 AWS CloudTrail 日志、VPC 流程日志和 DNS 日志。

▼ 解答

C

1. 考察的知识点

本题考察的是AWS安全服务的功能和适用场景，特别是Amazon GuardDuty、CloudTrail、VPC Flow Logs、DNS Logs等服务的使用。
重点在于如何实现持续监控和近实时威胁检测。

2. 选项分析

- A. Enable AWS CloudTrail logs, VPC flow logs, and DNS logs. Use Amazon CloudWatch Logs to manage these logs from a centralized account.
CloudTrail、VPC Flow Logs和DNS Logs确实可以记录相关活动，但CloudWatch Logs主要用于日志存储和分析，而不是专门的威胁检测工具。
此选项缺乏自动化威胁检测功能，因此不符合题目要求。
- B. Enable AWS CloudTrail logs, VPC flow logs, and DNS logs. Use Amazon Macie to monitor these logs from a centralized account.

Amazon Macie主要用于敏感数据发现和保护，尤其是Amazon S3中的数据，而不是用于监控和检测网络流量或DNS活动中的威胁。此选项功能不匹配题目要求。

C. Enable Amazon GuardDuty from a centralized account. Use GuardDuty to manage AWS CloudTrail logs, VPC flow logs, and DNS logs.

Amazon GuardDuty是一种专门的威胁检测服务，可以分析CloudTrail、VPC Flow Logs和DNS Logs以检测潜在威胁。

GuardDuty支持近实时监控，并能够识别异常行为和潜在威胁，完全符合题目要求。

D. Enable Amazon Inspector from a centralized account. Use Amazon Inspector to manage AWS CloudTrail logs, VPC flow logs, and DNS logs.

Amazon Inspector主要用于评估EC2实例的安全性和漏洞，而不是用于分析日志或检测网络流量中的威胁。

此选项功能不匹配题目要求。

▼ 41

▼ 英文

A company that uses AWS Organizations is using AWS IAM Identity Center (AWS Single Sign-On) to administer access to AWS accounts. A security engineer is creating a custom permission set in IAM Identity Center. The company will use the permission set across multiple accounts. An AWS managed policy and a customer managed policy are attached to the permission set. The security engineer has full administrative permissions and is operating in the management account.

When the security engineer attempts to assign the permission set to an IAM Identity Center user who has access to multiple accounts, the assignment fails.

What should the security engineer do to resolve this failure?

A. Create the customer managed policy in every account where the permission set is assigned. Give the customer managed policy the same name and same permissions in each account.

B. Remove either the AWS managed policy or the customer managed policy from the permission set. Create a second permission set that includes the removed policy. Apply the permission sets separately to the user.

C. Evaluate the logic of the AWS managed policy and the customer managed policy. Resolve any policy conflicts in the permission set before deployment.

D. Do not add the new permission set to the user. Instead, edit the user's existing permission set to include the AWS managed policy and the customer managed policy.

▼ 中文

一家使用 AWS Organizations 的公司正在使用 AWS IAM Identity Center (AWS Single Sign-On) 来管理对 AWS 帐户的存取权。一位安全工程师正在 IAM Identity Center 中建立自定义权限集。该公司将在多个帐户中使用该权限集。一个 AWS 托管策略和一个客户托管策略已附加到该权限集。此安全工程师拥有完全管理权限，并且正在管理帐户中进行操作。

当安全工程师尝试将权限集指派给有权存取多个帐户的 IAM Identity Center 使用者时，指派失败。

安全工程师应该如何解决此失败？

A. 在每个分配了权限集的帐户中建立客户托管策略。为每个帐户中的客户托管策略指定相同的名称和相同的权限。

- B.从权限集中移除 AWS 託管策略或客户託管策略。建立包含已移除策略的第二个权限集。将权限集分别应用于使用者。
- C.评估 AWS 託管策略和客户託管策略的逻辑。在部署之前解决权限集中的任何策略冲突。
- D.不要将新的权限集新增到使用者。而是编辑使用者现有的权限集，以包含 AWS 託管策略和客户託管策略。

▼ 解答

A

1. 考察的知识点

IAM Identity Center (AWS Single Sign-On) 的权限集管理。

跨账户使用权限集时的客户托管策略要求。

AWS Organizations 的账户间权限一致性。

2. 选项分析

A.

正确。IAM Identity Center的权限集在跨账户使用时，客户托管策略必须在目标账户中存在，并且名称和权限必须一致。如果客户托管策略仅存在于管理账户，而未在其他账户中创建，则权限集分配会失败。

B.

错误。分离权限集并分别应用不会解决问题，因为问题的根本原因是客户托管策略在目标账户中不存在，而不是权限集的结构问题。

C.

错误。虽然评估策略逻辑是一个好的实践，但此问题的根本原因与策略冲突无关，而是客户托管策略在目标账户中缺失。

D.

错误。编辑现有权限集不会解决问题，因为问题的根本原因是客户托管策略在目标账户中缺失，而不是权限集的创建或分配方式。

▼ 42

▼ 英文

A company has thousands of AWS Lambda functions. While reviewing the Lambda functions, a security engineer discovers that sensitive information is being stored in environment variables and is viewable as plaintext in the Lambda console. The values of the sensitive information are only a few characters long.

What is the MOST cost-effective way to address this security issue?

A.Set up IAM policies from the Lambda console to hide access to the environment variables.

B.Use AWS Step Functions to store the environment variables. Access the environment variables at runtime. Use IAM permissions to restrict access to the environment variables to only the Lambda functions that require access.

C.Store the environment variables in AWS Secrets Manager, and access them at runtime. Use IAM permissions to restrict access to the secrets to only the Lambda functions that require access.

D.Store the environment variables in AWS Systems Manager Parameter Store as secure string parameters, and access them at runtime. Use IAM permissions to restrict access to the parameters to only the Lambda functions that require access.

▼ 中文

一家公司拥有数千个 AWS Lambda 函数。一位安全工程师在审查这些 Lambda 函数时发现，敏感资讯储存在环境变数中，并且可以在 Lambda 控制台中以纯文字形式查看。这些敏感资讯的值只有几个字元。解决此安全问题最经济有效的方法是什麼？

- A. 从 Lambda 控制台设定 IAM 策略以隐藏对环境变数的存取。
- B. 使用 AWS Step Functions 储存环境变数。在运行时存取环境变数。使用 IAM 权限将环境变数的存取权限限制为仅需要存取权限的 Lambda 函数。
- C. 将环境变数储存在 AWS Secrets Manager 中，并在执行时间存取它们。使用 IAM 权限将金钥的存取权限限制为仅需要存取权限的 Lambda 函数。
- D. 将环境变数作为安全字串参数储存在 AWS Systems Manager Parameter Store 中，并在执行时存取它们。使用 IAM 权限将参数存取权限限制为仅需要存取权限的 Lambda 函数。

▼ 解答

D

1. 考察的知识点

安全性：如何保护敏感信息（如环境变量）在 AWS Lambda 中不被明文暴露。

成本效益：选择最具成本效益的解决方案。

AWS 服务：熟悉 AWS Secrets Manager 和 AWS Systems Manager Parameter Store 的功能和使用场景。

权限管理：使用 IAM 权限限制对敏感信息的访问。

2. 选项分析

A. Set up IAM policies from the Lambda console to hide access to the environment variables.

错误原因：IAM 策略可以限制对环境变量的访问，但无法解决环境变量以明文形式存储的问题。敏感信息仍然暴露在

Lambda 控制台中。

B. Use AWS Step Functions to store the environment variables. Access the environment variables at runtime. Use IAM

permissions to restrict access to the environment variables to only the Lambda functions that require access.

错误原因：AWS Step Functions 主要用于编排工作流，而不是专门设计用于存储敏感信息。使用 Step Functions 存储环境

变量并不是最佳实践，也不具备成本效益。

C. Store the environment variables in AWS Secrets Manager, and access them at runtime. Use IAM permissions to restrict

access to the secrets to only the Lambda functions that require access.

正确但非最佳：AWS Secrets Manager 是专门设计用于存储和管理敏感信息的服务，支持加密和权限管理。然

而，Secrets Manager 的成本较高，对于短小的环境变量来说可能不是最具成本效益的选择。

D. Store the environment variables in AWS Systems Manager Parameter Store as secure string parameters, and access them

at runtime. Use IAM permissions to restrict access to the parameters to only the Lambda functions that require access.

正确且最佳：AWS Systems Manager Parameter Store 支持存储敏感信息为“安全字符串”，并提供加密和权限管理功能。

相比 Secrets Manager，Parameter Store 的成本更低，适合存储短小的环境变量。

▼ 43

▼ 英文

A security engineer is using AWS Organizations and wants to optimize SCPs. The security engineer needs to ensure that the SCPs conform to best practices.

Which approach should the security engineer take to meet this requirement?

- A. Use AWS IAM Access Analyzer to analyze the policies. View the findings from policy validation checks.
- B. Review AWS Trusted Advisor checks for all accounts in the organization.
- C. Set up AWS Audit Manager. Run an assessment for all AWS Regions for all accounts.
- D. Ensure that Amazon Inspector agents are installed on all Amazon EC2 instances in all accounts.

▼ 中文

一位安全工程师正在使用 AWS Organizations，并希望优化 SCP。这位安全工程师需要确保SCP 符合最佳实务。这位安全工程师应该采用哪一种方法来满足这项要求？

- A. 使用 AWS IAM 存取分析器分析政策。查看策略验证检查的结果。
- B. 审查组织内所有帐户的 AWS Trusted Advisor 检查。
- C. 设定 AWS 稽核管理器。针对所有帐户的所有 AWS 区域执行评估。
- D. 确保所有帐户中的所有 Amazon EC2 执行个体上都安装了 Amazon Inspector代理程式。

▼ 解答

A

1. 考察的知识点

本题考察的是AWS Organizations中的服务控制策略（SCP）的优化，以及如何使用AWS工具确保策略符合最佳实践。

涉及的知识点包括：AWS IAM Access Analyzer、AWS Trusted Advisor、AWS Audit Manager、Amazon Inspector。Community vote distribution

2. 选项分析

A. Use AWS IAM Access Analyzer to analyze the policies. View the findings from policy validation checks.

正确：AWS IAM Access Analyzer可以帮助分析IAM策略，包括SCP，提供策略验证检查的结果，确保策略符合最佳实践。

这是优化SCP的推荐工具，因为它专门设计用于分析和验证策略的安全性和有效性。

B. Review AWS Trusted Advisor checks for all accounts in the organization.

错误：AWS Trusted Advisor主要用于检查账户的成本优化、安全性、性能和服务限制，但它不专门用于分析或优化SCP。

虽然它可以提供一些安全建议，但无法直接验证SCP的最佳实践。

C. Set up AWS Audit Manager. Run an assessment for all AWS Regions for all accounts.

错误：AWS Audit Manager主要用于帮助用户自动化审计流程，并生成合规性报告，但它不适用于直接分析或优化SCP。

它的功能与SCP优化无关。

D. Ensure that Amazon Inspector agents are installed on all Amazon EC2 instances in all accounts.

错误：Amazon Inspector是一个漏洞管理工具，用于扫描EC2实例的安全性和合规性，但它与SCP优化无关。

安装Inspector代理不会帮助优化SCP。

▼ 44

▼ 英文

A company uses Amazon RDS for MySQL as a database engine for its applications. A recent security audit revealed an RDS instance that is not compliant with company policy for encrypting data at rest. A security engineer at the company needs to ensure that all

existing RDS databases are encrypted using server-side encryption and that any future deviations from the policy are detected.

Which combination of steps should the security engineer take to accomplish this?
(Choose two.)

- A. Create an AWS Config rule to detect the creation of unencrypted RDS databases. Create an Amazon EventBridge rule to trigger on the AWS Config rules compliance state change and use Amazon Simple Notification Service (Amazon SNS) to notify the security operations team.
- B. Use AWS System Manager State Manager to detect RDS database encryption configuration drift. Create an Amazon EventBridge rule to track state changes and use Amazon Simple Notification Service (Amazon SNS) to notify the security operations team.
- C. Create a read replica for the existing unencrypted RDS database and enable replica encryption in the process. Once the replica becomes active, promote it into a standalone database instance and terminate the unencrypted database instance.
- D. Take a snapshot of the unencrypted RDS database. Copy the snapshot and enable snapshot encryption in the process. Restore the database instance from the newly created encrypted snapshot. Terminate the unencrypted database instance.
- E. Enable encryption for the identified unencrypted RDS instance by changing the configurations of the existing database.

▼ 中文

一家公司使用 Amazon RDS for MySQL 作为其应用程序的数据库引擎。最近的安全审计发现一个 RDS 实例未遵守公司关于静态数据加密的政策。公司的安全工程师需要确保所有现有的 RDS 数据库都使用服务器端加密，并检测任何未来违反该政策的情况。

安全工程师应该采取哪些步骤来完成此任务?(选择两个。)

- A. 建立 AWS Config 规则以侦测未加密 RDS 资料库的建立。建立 Amazon EventBridge 规则以在 AWS Config 规则合规性状态变更时触发，并使用 Amazon Simple Notification Service (Amazon SNS) 通知安全营运团队。
- B. 使用 AWS System Manager State Manager 侦测 RDS 资料库加密配置偏差。建立 Amazon EventBridge 规则来追踪状态变化，并使用 Amazon Simple Notification Service (Amazon SNS) 通知安全营运团队。
- C. 为现有的未加密 RDS 资料库建立唯读副本，并在此过程中启用副本加密。副本启动后，将其提升为独立资料库实例，并终止未加密的资料库实例。
- D. 拍摄未加密的 RDS 资料库快照。複製快照并在此过程中启用快照加密。从新建立的加密快照还原资料库实例。终止未加密的资料库实例。
- E. 透过修改现有资料库的配置，为已识别的未加密 RDS 实例启用加密。

▼ 解答

AD

1. 考察的知识点

Amazon RDS 数据库加密机制，包括如何处理未加密的现有数据库。
AWS Config 的使用，用于检测资源是否符合安全合规性要求。
Amazon EventBridge 和 Amazon SNS 的集成，用于通知安全团队。

2. 选项分析

A. Create an AWS Config rule to detect the creation of unencrypted RDS databases. Create an

Amazon EventBridge rule to trigger on the AWS Config rules compliance state change and use Amazon Simple Notification Service (Amazon SNS) to notify the security operations team. 正确。AWS Config 可以检测资源是否符合加密要求，EventBridge 和 SNS 可以用于通知安全团队，确保未来的数据库创建符合加密策略。

B. Use AWS System Manager State Manager to detect RDS database encryption configuration drift. Create an Amazon EventBridge rule to track state changes and use Amazon Simple Notification Service (Amazon SNS) to notify the security operations team. 错误。AWS Systems Manager State Manager 主要用于管理实例配置，而不是直接检测 RDS 数据库的加密状态。

C. Create a read replica for the existing unencrypted RDS database and enable replica encryption in the process. Once the replica becomes active, promote it into a standalone database instance and terminate the unencrypted database instance. 错误。虽然可以通过创建加密的只读副本来解决未加密数据库的问题，但此方法不如选项 D 的快照方法直接且高效。

D. Take a snapshot of the unencrypted RDS database. Copy the snapshot and enable snapshot encryption in the process. Restore the database instance from the newly created encrypted snapshot. Terminate the unencrypted database instance. 正确。通过快照复制并启用加密，然后从加密快照恢复数据库，是处理现有未加密数据库的推荐方法。

E. Enable encryption for the identified unencrypted RDS instance by changing the configurations of the existing database. 错误。RDS 不支持直接对现有数据库启用加密，必须通过快照或副本的方式实现加密。

▼ 45

▼ 英文

A company has recently recovered from a security incident that required the restoration of Amazon EC2 instances from snapshots. The company uses an AWS Key Management Service (AWS KMS) customer managed key to encrypt all Amazon Elastic Block Store (Amazon EBS) snapshots.

The company performs a gap analysis of its disaster recovery procedures and backup strategies. A security engineer needs to implement a solution so that the company can recover the EC2 instances if the AWS account is compromised and the EBS snapshots are deleted.

Which solution will meet this requirement?

A. Create a new Amazon S3 bucket. Use EBS lifecycle policies to move EBS snapshots to the new S3 bucket. Use lifecycle policies to move snapshots to the S3 Glacier Instant Retrieval storage class. Use S3 Object Lock to prevent deletion of the snapshots.

B. Use AWS Systems Manager to distribute a configuration that backs up all attached disks to Amazon S3.

C. Create a new AWS account that has limited privileges. Allow the new account to access the KMS key that encrypts the EBS snapshots. Copy the encrypted snapshots to the new account on a recurring basis.

D. Use AWS Backup to copy EBS snapshots to Amazon S3. Use S3 Object Lock to prevent deletion of the snapshots.

▼ 中文

一家公司最近从一起安全事件中恢复，该事件需要从快照中恢复 Amazon EC2 执行个体。该公司使用 AWS 密钥管理服务 (AWS KMS) 客户管理密钥加密所有 Amazon Elastic Block Store (Amazon EBS) 快照。

该公司对其灾难恢复流程和备份策略进行了差距分析。一位安全工程师需要实施一项解决方案，以便在 AWS 帐户被盗用且 EBS 快照被删除时，该公司能够恢复 EC2 执行个体。

哪种解决方案能够满足这项要求？

- A. 建立新的 Amazon S3 存储桶。使用 EBS 生命周期策略将 EBS 快照移至新的 S3 存储桶。使用生命周期策略将快照移至 S3 Glacier 即时检索存储类别。使用 S3 物件锁定防止快照被删除。
- B. 使用 AWS Systems Manager 分发将所有附加磁盘备份到 Amazon S3 的配置。
- C. 建立一个具有有限权限的新 AWS 帐户。允许新帐号存取加密 EBS 快照的 KMS 密钥。定期将加密快照复制到新帐户。
- D. 使用 AWS Backup 将 EBS 快照复制到 Amazon S3。使用 S3 物件锁定来防止删除快照。

▼ 解答

C

1. 考察的知识点

Amazon EBS快照的备份与恢复策略。

使用AWS KMS加密的资源的跨账户访问与管理。

灾难恢复 (Disaster Recovery) 和数据保护 (Data Protection)。

如何防止数据在AWS账户被恶意删除的情况下仍然可恢复。

2. 选项分析

A. 创建一个新的 Amazon S3 存储桶。使用 EBS 生命周期策略将 EBS 快照移动到新的 S3 存储桶。使用生命周期策略

将快照移动到 S3 Glacier Instant Retrieval 存储类别。使用 S3 Object Lock 防止快照被删除。

错误：EBS快照无法直接通过生命周期策略移动到S3存储桶。EBS快照和S3对象是不同的存储类型，无法通过生命周期策略直接转换。

虽然S3 Object Lock可以防止对象被删除，但此方案无法解决账户被恶意删除快照的问题，因为快照本身仍然存储在原账户中。

B. 使用 AWS Systems Manager 分发一个配置，将所有附加磁盘备份到 Amazon S3。

错误：AWS Systems Manager无法直接备份EBS快照到S3。此选项未提及如何处理加密的快照，也未解决账户被恶意删除快照的问题。

此方案更适用于文件级备份，而非EBS快照级别的备份。

C. 创建一个具有有限权限的新 AWS 账户。允许新账户访问加密 EBS 快照的 KMS 密钥。定期将加密的快照复制到新账户。

正确：此方案通过创建一个新账户并定期复制快照到新账户，确保即使原账户的快照被删除，数据仍然可以从新账户恢复。

通过允许新账户访问KMS密钥，确保加密的快照可以被解密和使用。

此方案符合灾难恢复的最佳实践，提供了跨账户的数据保护。

D. 使用 AWS Backup 将 EBS 快照复制到 Amazon S3。使用 S3 Object Lock 防止快照被删除。

错误：AWS Backup可以备份EBS快照，但无法直接将快照复制到S3。EBS快照和S3对象是不同的存

储类型。

虽然S3 Object Lock可以防止对象被删除，但此方案未解决账户被恶意删除快照的问题。

▼ 46

▼ 英文

A company's security engineer is designing an isolation procedure for Amazon EC2 instances as part of an incident response plan. The security engineer needs to isolate a target instance to block any traffic to and from the target instance, except for traffic from the company's forensics team. Each of the company's EC2 instances has its own dedicated security group. The EC2 instances are deployed in subnets of a VPC. A subnet can contain multiple instances.

The security engineer is testing the procedure for EC2 isolation and opens an SSH session to the target instance. The procedure starts to simulate access to the target instance by an attacker. The security engineer removes the existing security group rules and adds security group rules to give the forensics team access to the target instance on port 22. After these changes, the security engineer notices that the SSH connection is still active and usable. When the security engineer runs a ping command to the public IP address of the target instance, the ping command is blocked.

What should the security engineer do to isolate the target instance?

A. Add an inbound rule to the security group to allow traffic from 0.0.0.0/0 for all ports.

Add an outbound rule to the security group to allow traffic to 0.0.0.0/0 for all ports. Then immediately delete these rules.

B. Remove the port 22 security group rule. Attach an instance role policy that allows AWS Systems Manager Session Manager connections so that the forensics team can access the target instance.

C. Create a network ACL that is associated with the target instance's subnet. Add a rule at the top of the inbound rule set to deny all traffic from 0.0.0.0/0. Add a rule at the top of the outbound rule set to deny all traffic to 0.0.0.0/0.

D. Create an AWS Systems Manager document that adds a host-level firewall rule to block all inbound traffic and outbound traffic. Run the document on the target instance.

▼ 中文

一家公司的安全工程师正在设计 Amazon EC2 执行个体的隔离程序，作为事件回应计划的一部分。此安全工程师需要隔离目标实例，以阻止任何进出目标执行个体的流量（来自公司取证团队的流量除外）。该公司的每个 EC2 执行个体都有其专用的安全群组。这些 EC2 执行个体部署在 VPC 的子网中。一个子网可以包含多个实例。

安全工程师正在测试 EC2 隔离程序，并开启与目标执行个体的 SSH 会话。程式开始模拟攻击者对目标实例的存取。安全工程师删除了现有的安全群组规则，并新增了安全群组规则，以便取证团队能够透过连接埠 22 存取目标实例。

完成这些变更后，安全工程师注意到 SSH 连线仍然处于活动状态且可用。当安全工程师对目标执行个体的公网 IP 位址执行 ping 指令时，ping 指令会被阻止。安全工程师应该如何隔离目标执行个体？

A. 向安全群组新增进站规则，允许所有连接埠从 0.0.0.0/0 发出的流量。向安全群组新增出站规则，允许所有连接埠到 0.0.0.0/0 的流量。然后立即删除这些规则。

B. 删除连接埠 22 安全群组规则。附加一个允许 AWS Systems Manager Session Manager 连线的实例角色策略，以便取证团队可以存取目标执行个体。

C. 建立与目标实例网关联的网路 ACL。在进站规则集顶部新增一条规则，以拒绝所有来自 0.0.0.0/0 的流量。在出站规则集顶部新增一条规则，以拒绝所有发送至 0.0.0.0/0 的流量。

D.文档，新增主机级防火牆规则以阻止所有入站流量和出站流量。在目标实例上执行该文件。

▼ 解答

B

1. 考察的知识点

EC2实例隔离的最佳实践

安全组和网络ACL的使用

AWS Systems Manager Session Manager的功能

主机级防火牆规则的应用

2. 选项分析

A. Add an inbound rule to the security group to allow traffic from 0.0.0.0/0 for all ports. Add an outbound rule to the security

group to allow traffic to 0.0.0.0/0 for all ports. Then immediately delete these rules.

分析：此选项建议临时添加允许所有流量的规则，然后删除这些规则。这种方法无法有效隔离目标实例，并且可能会导致短时间内的安全漏洞。删除规则后，现有的连接仍然可能保持活动状态，因为安全组规则的更改不会立即终止现

有连接。

结论：错误。

B. Remove the port 22 security group rule. Attach an instance role policy that allows AWS Systems Manager Session Manager

connections so that the forensics team can access the target instance.

分析：此选项建议移除端口22的安全组规则，并使用AWS Systems Manager Session Manager进行访问。Session Manager提供了一种安全的方式来管理实例，而无需依赖传统的SSH连接。这种方法可以有效隔离实例，同时允许取证团队安全访问目标实例。

结论：正确。

C. Create a network ACL that is associated with the target instance's subnet. Add a rule at the top of the inbound rule set to

deny all traffic from 0.0.0.0/0. Add a rule at the top of the outbound rule set to deny all traffic to 0.0.0.0/0.

分析：网络ACL是子网级别的控制，而不是实例级别的控制。虽然可以通过网络ACL阻止所有流量，但这会影响子网中的所有实例，而不仅仅是目标实例。这种方法不符合题目要求的“仅隔离目标实例”的需求。

结论：错误。

D. Create an AWS Systems Manager document that adds a host-level firewall rule to block all inbound traffic and outbound

traffic. Run the document on the target instance.

分析：此选项建议使用AWS Systems Manager文档来添加主机级防火牆规则。这种方法虽然可以实现隔离，但需要额外的配置和操作，复杂性较高。此外，题目中并未提到需要使用主机级防火牆规则。

结论：错误。

▼ 47

▼ 英文

A startup company is using a single AWS account that has resources in a single AWS Region. A security engineer configures an AWS CloudTrail trail in the same Region to deliver log files to an Amazon S3 bucket by using the AWS CLI.

Because of expansion, the company adds resources in multiple Regions. The security engineer notices that the logs from the new Regions are not reaching the S3 bucket.

What should the security engineer do to fix this issue with the LEAST amount of operational overhead?

- A. Create a new CloudTrail trail. Select the new Regions where the company added resources.
- B. Change the S3 bucket to receive notifications to track all actions from all Regions.
- C. Create a new CloudTrail trail that applies to all Regions.
- D. Change the existing CloudTrail trail so that it applies to all Regions.

▼ 中文

一家新创公司使用单一 AWS 帐户，该帐户的资源位于单一 AWS 区域。一位安全工程师在同一区域配置了一条 AWS CloudTrail 跟踪，以便使用 AWS CLI 将日志档案传送到 Amazon S3 储存桶。由于业务扩展，该公司在多个区域添加了资源。这位安全工程师注意到，来自新区域的日志无法到达 S3 储存桶。

这位安全工程师应该如何以最少营运开销来解决这个问题？

- A. 建立新的 CloudTrail 追踪。选择公司新增资源的新区域。
- B. 更改 S3 储存桶以接收通知来追踪来自所有区域的所有操作。
- C. 建立适用于所有区域的新 CloudTrail 追踪。
- D. 更改现有的 CloudTrail 跟踪，以便它适用于所有区域。

▼ 解答

D

1. 考察的知识点

CloudTrail 的配置与管理，特别是跨 Region 的日志记录。
如何最小化操作开销以实现全 Region 日志记录。

2. 选项分析

- A. 创建一个新的 CloudTrail trail。选择公司添加资源的新 Region。
错误：创建新的 CloudTrail trail 会增加管理复杂性和成本，不符合“最小化操作开销”的要求。
CloudTrail 支持跨 Region 的日志记录，因此不需要为每个 Region 单独创建 trail。
- B. 更改 S3 bucket 以接收通知，从而跟踪所有 Region 的所有操作。
错误：S3 bucket 的通知功能与 CloudTrail 日志记录无关。更改 S3 bucket 不会解决日志未记录的问题。
问题的核心在于 CloudTrail 的配置，而不是 S3 bucket 的设置。
- C. 创建一个适用于所有 Region 的新的 CloudTrail trail。
错误：虽然创建一个新的 CloudTrail trail 可以解决问题，但这会增加管理复杂性和成本。
现有的 CloudTrail trail 可以通过配置更改为支持所有 Region，无需创建新的 trail。
- D. 更改现有的 CloudTrail trail，使其适用于所有 Region。
正确：CloudTrail 支持跨 Region 的日志记录，只需在现有 trail 中启用“Apply trail to all Regions”选项即可。
此方法最小化了操作开销，因为不需要创建新的 trail 或更改其他资源。

▼ 48

▼ 英文

A company's public Application Load Balancer (ALB) recently experienced a DDoS attack. To mitigate this issue, the company deployed Amazon CloudFront in front of the ALB so that users would not directly access the Amazon EC2 instances behind the ALB. The company discovers that some traffic is still coming directly into the ALB and is still being handled by the EC2 instances.

Which combination of steps should the company take to ensure that the EC2 instances will receive traffic only from CloudFront? (Choose two.)

- A. Configure CloudFront to add a cache key policy to allow a custom HTTP header that CloudFront sends to the ALB.
- B. Configure CloudFront to add a custom HTTP header to requests that CloudFront sends to the ALB.
- C. Configure the ALB to forward only requests that contain the custom HTTP header.
- D. Configure the ALB and CloudFront to use the X-Forwarded-For header to check client IP addresses.
- E. Configure the ALB and CloudFront to use the same X.509 certificate that is generated by AWS Certificate Manager (ACM).

▼ 中文

一家公司的公共应用程序负载均衡器 (ALB) 最近遭受了 DDoS 攻击。为了缓解此问题，该公司在 ALB 前端部署了 Amazon CloudFront，以使用户无法直接存取 ALB 后端的 Amazon EC2 执行个体。

该公司发现仍有一些流量直接进入 ALB，并由 EC2 执行个体处理。

该公司应该采取哪些措施组合来确保 EC2 执行个体仅接收来自 CloudFront 的流量？（选两项。）

- A. 配置 CloudFront 以新增快取金钥策略，从而允许 CloudFront 传送到 ALB 的自订 HTTP 标头。
- B. 配置 CloudFront 以向 CloudFront 发送到 ALB 的请求新增自订 HTTP 标头。
- C. 配置 ALB 以仅转送包含自订 HTTP 标头的请求。
- D. 配置 ALB 和 CloudFront 以使用 X-Forwarded-For 标头来检查客户端 IP 位址。
- E. 设定 ALB 和 CloudFront 以使用由 AWS Certificate Manager (ACM) 产生的相同 X.509 凭证。

▼ 解答

BC

1. 考察的知识点

Amazon CloudFront与Application Load Balancer (ALB)的集成。

如何通过自定义HTTP头确保流量来源的验证。

防止未经授权的流量直接访问ALB。

2. 选项分析

A. Configure CloudFront to add a cache key policy to allow a custom HTTP header that CloudFront sends to the ALB.

错误：此选项提到的是“缓存键策略”，但缓存键策略的主要作用是影响CloudFront的缓存行为，而不是直接限制流量来源。此选项与题目要求无关。

B. Configure CloudFront to add a custom HTTP header to requests that CloudFront sends to the ALB.

正确：通过配置CloudFront添加自定义HTTP头，可以标识流量是从CloudFront发出的。这是确保ALB只接受来自 CloudFront流量的关键步骤之一。

C. Configure the ALB to forward only requests that contain the custom HTTP header.

正确：通过配置ALB仅转发包含特定自定义HTTP头的请求，可以确保ALB只处理来自CloudFront的流量。这是题目要求的另一个关键步骤。

D. Configure the ALB and CloudFront to use the X-Forwarded-For header to check client IP addresses.

错误：X-Forwarded-For头主要用于记录客户端的真实IP地址，与限制流量来源无关。此选项无法解决题目中提到的问题。

E. Configure the ALB and CloudFront to use the same X.509 certificate that is generated by AWS Certificate Manager (ACM).

错误：使用相同的X.509证书主要用于SSL/TLS加密通信，与限制流量来源无关。此选项无法解决题目中提到的问题。

▼ 49

▼ 英文

A company discovers a billing anomaly in its AWS account. A security consultant investigates the anomaly and discovers that an employee who left the company 30 days ago still has access to the account. The company has not monitored account activity in the past.

The security consultant needs to determine which resources have been deployed or reconfigured by the employee as quickly as possible.

Which solution will meet these requirements?

A. In AWS Cost Explorer, filter chart data to display results from the past 30 days. Export the results to a data table. Group the data table by resource.

B. Use AWS Cost Anomaly Detection to create a cost monitor. Access the detection history. Set the time frame to Last 30 days. In the search area, choose the service category.

C. In AWS CloudTrail, filter the event history to display results from the past 30 days. Create an Amazon Athena table that contains the data. Partition the table by event source.

D. Use AWS Audit Manager to create an assessment for the past 30 days. Apply a usage-based framework to the assessment. Configure the assessment to assess by resource.

▼ 中文

一家公司发现其 AWS 帐户有账单异常。一位安全顾问调查了该异常，发现一名 30 天前离职的员工仍然可以存取该帐户。该公司过去从未监控过帐户活动。安全顾问需要尽快确定该员工部署或重新配置了哪些资源。

哪种解决方案能够满足这些要求？

A. 在 AWS Cost Explorer 中，筛选图表资料以显示过去 30 天的结果。将结果汇出到数据表。依资源将资料表分组。

B. 使用 AWS 成本异常检测建立成本监控器。存取检测历史记录。将时间范围设定为过去 30 天。在搜寻区域中，选择服务类别。

C. 在 AWS CloudTrail 中，筛选事件历史记录以显示过去 30 天的结果。建立包含资料的 Amazon Athena 表。依事件来源对錶进行分区。

D. 使用 AWS Audit Manager 建立过去 30 天的评估。将基于使用情况的框架应用于评估。将评估配置为按资源进行评估。

▼ 解答

C

1. 考察的知识点

本题考察的是AWS安全审计与事件追踪的能力，尤其是如何快速定位和分析账户活动历史，以确定资源的部署或重新

配置情况。

涉及的服务包括AWS CloudTrail、Amazon Athena、AWS Cost Explorer、AWS Cost Anomaly Detection和AWS Audit Manager。

2. 选项分析

A. In AWS Cost Explorer, filter chart data to display results from the past 30 days. Export the results to a data table. Group the data table by resource.

错误原因：AWS Cost Explorer主要用于分析成本和使用情况，而不是追踪具体的资源部署或配置活动。它无法提供详细的事件历史记录，因此不适合用于审计员工的操作行为。

B. Use AWS Cost Anomaly Detection to create a cost monitor. Access the detection history. Set the time frame to Last 30 days. In the search area, choose the service category.

错误原因：AWS Cost Anomaly Detection用于检测成本异常，而不是追踪资源的具体操作或配置变更。虽然可以查看服务类别，但无法提供详细的事件级别信息。

C. In AWS CloudTrail, filter the event history to display results from the past 30 days. Create an Amazon Athena table that contains the data. Partition the table by event source.

正确原因：AWS CloudTrail记录了账户中的所有API调用和活动日志，是追踪资源部署和配置变更的最佳工具。通过

Amazon Athena，可以对CloudTrail日志进行查询和分析，快速定位相关事件。

D. Use AWS Audit Manager to create an assessment for the past 30 days. Apply a usage-based framework to the assessment.

Configure the assessment to assess by resource.

错误原因：AWS Audit Manager主要用于合规性评估，而不是实时分析账户活动或事件历史。它无法快速定位具体的资源部署或配置变更。

▼ 50

▼ 英文

A security engineer is checking an AWS CloudFormation template for vulnerabilities. The security engineer finds a parameter that has a default value that exposes an application's API key in plaintext. The parameter is referenced several times throughout the template. The security engineer must replace the parameter while maintaining the ability to reference the value in the template.

Which solution will meet these requirements in the MOST secure way?

A. Store the API key value as a SecureString parameter in AWS Systems Manager Parameter Store. In the template, replace all references to the value with `{{resolve:ssm:MySSMParameterName:1}}`.

B. Store the API key value in AWS Secrets Manager. In the template, replace all references to the value with `{{resolve:secretsmanager:MySecretId:SecretString}}`.

C. Store the API key value in Amazon DynamoDB. In the template, replace all references to the value with `{{resolve:dynamodb:MyTableName:MyPrimaryKey}}`.

D. Store the API key value in a new Amazon S3 bucket. In the template, replace all references to the value with `{{resolve:s3:MyBucketName:MyObjectName}}`.

▼ 中文

一位安全工程师正在检查 AWS CloudFormation 范本是否有漏洞。他发现一个参数的预设值会以明文形式暴露应用程序的 API 金钥。该参数在整个模板中被多次引用。安全工程师必须替换该参数，同时确保在模板中能够引用该值。

哪一种解决方案能够以最安全的方式满足这些要求？

A. 将 API 金钥值作为 SecureString 参数储存在 AWS Systems Manager Parameter Store 中。在范本中，将所有对该值的参考替换为 `{{resolve:ssm:MySSMParameterName:1}}`。

B. 将 API 金钥值储存在 AWS Secrets Manager 中。在模板中，将所有对该值的引用替换为 `{{resolve:secretsmanager:MySecretId:SecretString}}`。

C. 将 API 金钥值储存在 Amazon DynamoDB 中。在范本中，将所有对该值的参考替换为 `{{resolve:dynamodb:MyTableName:MyPrimaryKey}}`。

D. 将 API 金钥值储存在新的 Amazon S3 储存桶中。在范本中，将所有对该值的参考替换为 `{{resolve:s3:MyBucketName:MyObjectName}}`。

▼ 解答

B

1. 考察的知识点

本题考察的是 AWS 资源的安全管理，尤其是如何安全地存储和引用敏感信息（如 API 密钥）。

涉及的服务包括 AWS Secrets Manager、AWS Systems Manager Parameter Store、Amazon DynamoDB 和 Amazon S3。

重点在于选择最安全且符合最佳实践的方式来存储和引用敏感信息。

2. 选项分析

A. Store the API key value as a SecureString parameter in AWS Systems Manager Parameter Store.

正确性：AWS Systems Manager Parameter Store 支持 SecureString 类型，可以安全地存储敏感信息。

缺点：虽然 SecureString 是安全的，但 AWS Secrets Manager 是专门设计用于存储和管理敏感信息（如 API 密钥、数据库凭

证等），并提供更丰富的功能（如自动轮换）。

结论：此选项是安全的，但不是最佳实践。

B. Store the API key value in AWS Secrets Manager.

正确性：AWS Secrets Manager 是专门设计用于存储和管理敏感信息的服务，支持加密存储、访问控制和自动轮换。

优势：提供了更高级的功能，如自动轮换和集成支持，符合最佳实践。

结论：此选项是最佳答案。

C. Store the API key value in Amazon DynamoDB.

正确性：Amazon DynamoDB 是一个 NoSQL 数据库服务，虽然可以存储数据，但它不是专门设计用于存储敏感信息。

缺点：缺乏专门的加密和管理敏感信息的功能，安全性较低。

结论：此选项不适合存储 API 密钥。

D. Store the API key value in a new Amazon S3 bucket.

正确性：Amazon S3 可以存储数据，但它不是专门设计用于存储敏感信息。

缺点：需要额外的配置（如加密和访问控制）来确保安全，管理复杂性较高。

结论：此选项不适合存储 API 密钥。

▼ 英文

A company's AWS CloudTrail logs are all centrally stored in an Amazon S3 bucket. The security team controls the company's AWS account. The security team must prevent unauthorized access and tampering of the CloudTrail logs.

Which combination of steps should the security team take? (Choose three.)

- A. Configure server-side encryption with AWS KMS managed encryption keys (SSE-KMS).
- B. Compress log files with secure gzip.
- C. Create an Amazon EventBridge rule to notify the security team of any modifications on CloudTrail log files.
- D. Implement least privilege access to the S3 bucket by configuring a bucket policy.
- E. Configure CloudTrail log file integrity validation.
- F. Configure Access Analyzer for S3.

▼ 中文

一家公司的 AWS CloudTrail 日志全部集中储存在 Amazon S3 存储桶中。安全团队负责控制该公司的 AWS 帐户。安全团队必须防止未经授权的存取和篡改 CloudTrail 日志。

安全团队应该采取哪些措施组合？（选择三项。）

- A. 使用 AWS KMS 托管加密密钥 (SSE-KMS) 设定伺服器端加密。
- B. 使用安全 gzip 压缩日志档。
- C. 建立 Amazon EventBridge 规则以通知安全团队 CloudTrail 日志档案的任何修改。
- D. 透过配置存储桶策略实现对 S3 存储桶的最小权限存取。
- E. 配置 CloudTrail 日志档案完整性验证。
- F. 为 S3 配置存取分析器。

▼ 解答

ADE

1. 考察的知识点

CloudTrail 日志的安全性，包括防止未经授权的访问和篡改。

Amazon S3 存储桶的安全配置。

日志文件的完整性验证。

2. 选项分析

A. Configure server-side encryption with AWS KMS managed encryption keys (SSE-KMS). 分析：正确。使用 SSE-KMS 可以确

保日志文件在存储时被加密，从而防止未经授权的访问。这是保护数据的一项重要措施。

B. Compress log files with secure gzip. 分析：错误。虽然压缩日志文件可以节省存储空间，但它与防止未经授权的访问和篡改无关，也不是 CloudTrail 日志安全性的核心要求。

C. Create an Amazon EventBridge rule to notify the security team of any modifications on CloudTrail log files. 分析：错误。

虽然通知机制可以帮助监控日志文件的修改，但它无法直接防止未经授权的访问或篡改。此选项不是最佳实践的一部分。

D. Implement least privilege access to the S3 bucket by configuring a bucket policy. 分析：正确。通过配置存储桶策略并实施最小权限原则，可以限制对日志文件的访问，从而防止未经授权的访问。

- E. Configure CloudTrail log file integrity validation. 分析：正确。CloudTrail日志文件完整性验证可以检测日志文件是否被篡改，是确保日志文件安全性的重要步骤。
- F. Configure Access Analyzer for S3. 分析：错误。Access Analyzer for S3主要用于分析存储桶的访问权限，但它无法直接防止日志文件的篡改或未经授权的访问。

▼ 52

▼ 英文

A company has several petabytes of data. The company must preserve this data for 7 years to comply with regulatory requirements. The company's compliance team asks a security officer to develop a strategy that will prevent anyone from changing or deleting the data.

Which solution will meet this requirement MOST cost-effectively?

- A. Create an Amazon S3 bucket. Configure the bucket to use S3 Object Lock in compliance mode. Upload the data to the bucket. Create a resource-based bucket policy that meets all the regulatory requirements.
- B. Create an Amazon S3 bucket. Configure the bucket to use S3 Object Lock in governance mode. Upload the data to the bucket. Create a user-based IAM policy that meets all the regulatory requirements.
- C. Create a vault in Amazon S3 Glacier. Create a Vault Lock policy in S3 Glacier that meets all the regulatory requirements. Upload the data to the vault.
- D. Create an Amazon S3 bucket. Upload the data to the bucket. Use a lifecycle rule to transition the data to a vault in S3 Glacier. Create a Vault Lock policy that meets all the regulatory requirements.

▼ 中文

一家公司拥有数PB的数据。为了符合监管要求，该公司必须将这些数据保存7年。该公司的合规团队要求安全官员制定一项策略，以防止任何人更改或删除这些资料。

哪一种解决方案能够以最具成本效益的方式满足这项要求？

- A. 建立 Amazon S3 储存桶。配置储存桶以在合规模式下使用 S3 物件锁定。将资料上传到储存桶。建立符合所有监管要求的基于资源的储存桶策略。
- B. 建立 Amazon S3 储存桶。配置储存桶以在治理模式下使用 S3 物件锁定。将资料上传到储存桶。建立符合所有监管要求的基于使用者的 IAM 策略。
- C. 在 Amazon S3 Glacier 中建立文件库。在 S3 Glacier 中建立符合所有监管要求的文件库锁定策略。将数据上传到文件库。
- D. 建立 Amazon S3 储存桶。将资料上传到储存桶。使用生命周期规则将资料转换到 S3 Glacier 中的文件库。建立符合所有监管要求的文件库锁定策略。

▼ 解答

C

1. 考察的知识点

- Amazon S3 Object Lock的合规模式与治理模式的区别。
- Amazon S3 Glacier Vault Lock的功能及其适用场景。

数据保留策略的成本效益分析。
如何满足监管要求（防止数据被修改或删除）。

2. 选项分析

A. Create an Amazon S3 bucket. Configure the bucket to use S3 Object Lock in compliance mode. Upload the data to the

bucket. Create a resource-based bucket policy that meets all the regulatory requirements.

正确性分析：使用S3 Object Lock的合规模式可以防止数据被修改或删除，符合监管要求。但S3存储成本较高，尤其是

对于需要长期保存的数据（7年）。

成本效益分析：相比S3 Glacier，S3的存储成本更高，因此不是最具成本效益的解决方案。

结论：虽然技术上可行，但不是最具成本效益的选项。

B. Create an Amazon S3 bucket. Configure the bucket to use S3 Object Lock in governance mode. Upload the data to the

bucket. Create a user-based IAM policy that meets all the regulatory requirements.

正确性分析：治理模式允许特定用户通过权限解除锁定，这可能导致数据被修改或删除，不完全符合监管要求。

成本效益分析：与选项A类似，S3存储成本较高，且治理模式不适合严格的合规需求。

结论：不符合监管要求，且成本较高。

C. Create a vault in Amazon S3 Glacier. Create a Vault Lock policy in S3 Glacier that meets all the regulatory requirements.

Upload the data to the vault.

正确性分析：Amazon S3 Glacier Vault Lock允许创建不可更改的策略，确保数据无法被修改或删除，完全符合监管要求。

成本效益分析：S3 Glacier是专为长期数据存储设计的，成本远低于S3，适合存储大规模数据（如几PB）并满足7年的

保留要求。

结论：技术上可行且成本效益最高，是最佳选项。

D. Create an Amazon S3 bucket. Upload the data to the bucket. Use a lifecycle rule to transition the data to a vault in S3

Glacier. Create a Vault Lock policy that meets all the regulatory requirements.

正确性分析：虽然可以通过生命周期规则将数据转移到S3 Glacier，但初始存储在S3中会增加不必要的成本。最终仍需

在S3 Glacier中创建Vault Lock策略。

成本效益分析：相比直接使用S3 Glacier（选项C），此选项增加了额外的S3存储成本，且流程更复杂。

结论：技术上可行，但成本效益较低，不是最佳选项。

▼ 53

▼ 英文

A-company uses a third-party identity provider and SAML-based SSO for its AWS accounts. After the third-party identity provider renewed an expired signing certificate, users saw the following message when trying to log in:

Error: Response Signature Invalid (Service: AWSSecurityTokenService; Status Code: 400; Error Code: InvalidIdentityToken)

A security engineer needs to provide a solution that corrects the error and minimizes operational overhead.

Which solution meets these requirements?

A.Upload the third-party signing certificate's new private key to the AWS identity provider entity defined in AWS Identity and Access Management (IAM) by using the AWS Management Console.

B.Sign the identity provider's metadata file with the new public key. Upload the signature to the AWS identity provider entity defined in AWS Identity and Access Management (IAM) by using the AWS CLI.

C.Download the updated SAML metadata file from the identity service provider. Update the file in the AWS identity provider entity defined in AWS Identity and Access Management (IAM) by using the AWS CLI.

D.Configure the AWS identity provider entity defined in AWS Identity and Access Management (IAM) to synchronously fetch the new public key by using the AWS Management Console.

▼ 中文

A 公司为其 AWS 帐户使用第三方身份提供者及基于 SAML 的单一登入 (SSO)。第三方身份提供者续订了过期的签名凭证后，使用者在尝试登入时看到以下讯息：

错误：回应签章无效（服务：AWSSecurityTokenService；状态码：400；错误代码：InvalidIdentityToken）

安全工程师需要提供一个解决方案来纠正错误并最大限度地降低营运成本。

哪种解决方案符合这些要求？

A.使用 AWS 管理主控台将第三方签章凭证的新私钥上传至 AWS Identity and Access Management (IAM) 中定义的 AWS 身份提供者实体。

B.使用新的公钥对身份提供者的元资料档案进行签署。使用AWS CLI 将签章上传到 AWS Identity and Access Management (IAM) 中定义的 AWS 身份提供者实体。

C.从身份识别服务提供者下载更新后的 SAML 元资料档。使用 AWS CLI 更新 AWS Identity and Access Management (IAM) 中定义的 AWS 身份提供者实体中的档案。

D.设定 AWS Identity and Access Management (IAM) 中定义的AWS 身份提供者实体，以使用 AWS 管理控制台同步取得新的公钥。

▼ 解答

C

1. 选项分析

A.

错误原因：私钥是敏感信息，不能上传到AWS。AWS只需要验证签名的公钥，而不是私钥。

B.

错误原因：公钥不能用于签名操作。签名是由私钥完成的，公钥用于验证签名。此选项的描述不符合实际操作流程。

C.

正确原因：当第三方身份提供商更新了签名证书后，SAML元数据文件会包含新的证书信息。下载更新后的元数据文件并上传到AWS IAM中的身份提供商实体是解决问题的正确方法。

D.

错误原因：AWS IAM中的身份提供商实体不支持自动同步或动态获取第三方身份提供商的公钥。需要手动更新元数据文件。

2. 考察的知识点

本题考察的是AWS与第三方身份提供商（Identity Provider, IdP）集成时的SAML配置管理，特别是如何处理签名证书更新后的问题。

涉及AWS Identity and Access Management (IAM)中定义的身份提供商实体的配置和操作。

▼ 英文

A company has several workloads running on AWS. Employees are required to authenticate using on-premises ADFS and SSO to access the AWS Management Console. Developers migrated an existing legacy web application to an Amazon EC2 instance. Employees need to access this application from anywhere on the internet, but currently, there is no authentication system built into the application.

How should the security engineer implement employee-only access to this system without changing the application?

A. Place the application behind an Application Load Balancer (ALB). Use Amazon Cognito as authentication for the ALB. Define a SAML-based Amazon Cognito user pool and connect it to ADFS.

B. Implement AWS IAM Identity Center (AWS Single Sign-On) in the management account and link it to ADFS as an identity provider. Define the EC2 instance as a managed resource, then apply an IAM policy on the resource.

C. Define an Amazon Cognito identity pool, then install the connector on the Active Directory server. Use the Amazon Cognito SDK on the application instance to authenticate the employees using their Active Directory user names and passwords.

D. Create an AWS Lambda custom authorizer as the authenticator for a reverse proxy on Amazon EC2. Ensure the security group on Amazon EC2 only allows access from the Lambda function.

▼ 中文

一家公司在 AWS 上运行多个工作负载。员工需要使用本机 ADFS 和 SSO 进行身份验证才能存取 AWS 管理控制台。开发人员将现有的旧版 Web 应用程序移转到了 Amazon EC2 执行个体。员工需要[从互联网上的任何地方访问此应用程序，但目前该应用程序尚未内建身份验证系统。](#)

安全工程师应[如何在更不改变应用程序的情况下实现仅限员工存取此系统的权限？](#)

A. 将应用程序置于应用程序负载均衡器 (ALB) 之后。使用 Amazon Cognito 作为 ALB 的身份验证。定义基于 SAML 的 Amazon Cognito 使用者池并将其连接到 ADFS。

B. 在管理帐户中实作 AWS IAM Identity Center (AWS Single Sign-On)，并将其作为身份提供者连接到 ADFS。将 EC2 执行个体定义为託管资源，然后在该资源上套用 IAM 策略。

C. 定义一个 Amazon Cognito 身分池，然后在 Active Directory 伺服器上安装连接器。使用应用程序实例上的 Amazon Cognito SDK，透过 Active Directory 使用者名称和密码对员工进行身份验证。

D. 建立 AWS Lambda 自订授权器作为 Amazon EC2 上反向代理程式的身份验证器。确保 Amazon EC2 上的安全性群组仅允许来自 Lambda 函数的存取。

▼ 解答

A

1. 考察的知识点

Amazon Cognito的功能与使用场景，特别是与SAML集成的能力。

Application Load Balancer (ALB)的身份验证功能。

如何在更不修改应用程序的情况下实现安全访问控制。与ADFS集成的身份验证机制。

2. 选项分析

A.

正确：ALB支持身份验证功能，可以通过Amazon Cognito集成SAML身份提供者（如ADFS）。这种方法无需修改应用程序

源代码，只需配置ALB和Cognito即可实现员工身份验证。

符合题目要求：员工可以通过ADFS进行身份验证，并通过ALB访问应用程序。

B.

错误：AWS IAM Identity Center (AWS SSO)主要用于管理AWS账户和服务的访问权限，而不是直接用于保护EC2实例上的应用程序。

IAM策略无法直接控制EC2实例上的应用程序访问权限。

C.

错误：此选项需要修改应用程序代码以集成Amazon Cognito SDK，这与题目要求的“不改变应用程序”相矛盾。

此外，题目中并未提到需要使用Amazon Cognito身份池，而是更适合使用用户池与SAML集成。

D.

错误：此选项需要开发自定义Lambda函数和反向代理，增加了复杂性，并且需要修改应用程序的访问架构。

题目要求的是一种简单的解决方案，而不是复杂的自定义实现。

▼ 55

▼ 英文

A company is using AWS to run a long-running analysis process on data that is stored in Amazon S3 buckets. The process runs on a fleet of Amazon EC2 instances that are in an Auto Scaling group. The EC2 instances are deployed in a private subnet of a VPC that does not have internet access. The EC2 instances and the S3 buckets are in the same AWS account. The EC2 instances access the S3 buckets through an S3 gateway endpoint that has the default access policy. Each EC2 instance is associated with an instance profile role that has a policy that explicitly allows the s3:GetObject action and the s3:PutObject action for only the required S3 buckets.

The company learns that one or more of the EC2 instances are compromised and are exfiltrating data to an S3 bucket that is outside the company's organization in AWS Organizations. A security engineer must implement a solution to stop this exfiltration of data and to keep the EC2 processing job functional.

Which solution will meet these requirements?

A. Update the policy on the S3 gateway endpoint to allow the S3 actions only if the values of the aws:ResourceOrgID and aws:PrincipalOrgID condition keys match the company's values.

B. Update the policy on the instance profile role to allow the S3 actions only if the value of the aws:ResourceOrgID condition key matches the company's value.

C. Add a network ACL rule to the subnet of the EC2 instances to block outgoing connections on port 443.

D. Apply an SCP on the AWS account to allow the S3 actions only if the values of the aws:ResourceOrgID and aws:PrincipalOrgID condition keys match the company's values.

▼ 中文

一家公司正在使用 AWS 对储存在 Amazon S3 储存桶中的资料运行长期运行的分析流程。此流程在 Auto Scaling 群组中的一组 Amazon EC2 执行个体上执行。这些 EC2 执行个体部署在无法存取 Internet 的 VPC 的私有子网路中。EC2 执行个体和 S3 储存桶位于同一个 AWS 帐户。

EC2 执行个体透过具有预设存取策略的 S3 闸道终端节点存取 S3 储存桶。每个 EC2 执行个体都与一个执行个体设定档角色关联，该角色的策略明确允许仅对所需的 S3 储存桶执行 s3:GetObject 操作和 s3:PutObject 操作。

该公司发现一个或多个 EC2 执行个体遭到入侵，并且正在将资料外洩到 AWS Organizations 中公司组织外部的 S3 储存桶中。安全工程师必须实施解决方案来阻止这种资料洩露，并确保 EC2 处理作业正常运行。

哪种解决方案能够满足这些要求？

- A.更新 S3 网关终端节点上的策略，以便仅当 aws:ResourceOrgID 和 aws:PrincipalOrgID 条件键的值与公司值相符时才允许 S3 操作。
- B.更新实例设定档角色上的策略，以便仅当 aws:ResourceOrgID 条件键的值与公司值相符时才允许 S3 操作。
- C.在 EC2 执行个体的子网路新增网路 ACL 规则，以封锁 连接埠 443 上的传出连线。
- D.在 AWS 帐户上套用 SCP，仅当 aws:ResourceOrgID 和 aws:PrincipalOrgID 条件键的值与公司值相符时才允许 S3 操作。

▼ 解答

A

1. 考察的知识点

Amazon S3 访问控制与安全策略

使用 S3 网关端点的访问策略

条件键 (aws:ResourceOrgID 和 aws:PrincipalOrgID) 的使用

阻止数据泄露的安全措施

2. 选项分析

A.

分析：此选项正确。通过更新 S3 网关端点的策略，可以限制只有属于公司组织的资源和主体才能访问 S3。这种方法直接在网关端点层面控制访问，确保数据不会被泄露到外部组织的 S3 存储桶，同时保持 EC2 实例的正常功能。

B.

分析：此选项错误。虽然可以通过实例配置文件角色限制访问，但这无法阻止被攻击的实例直接通过网关端点访问外部 S3 存储桶。实例角色的策略仅适用于实例本身的权限，而网关端点的默认策略仍然允许访问。

C.

分析：此选项错误。阻止端口 443 上的出站连接会影响 EC2 实例的正常功能，因为 S3 使用 HTTPS (端口 443) 进行通信。这种方法会导致分析任务无法正常运行。

D.

分析：此选项错误。SCP (服务控制策略) 适用于整个账户的权限管理，但它无法直接控制网关端点的行为。此外，SCP 的应用可能会影响其他资源的正常运行，导致不必要的权限问题。

▼ 56

▼ 英文

A company that operates in a hybrid cloud environment must meet strict compliance requirements. The company wants to create a report that includes evidence from on-premises workloads alongside evidence from AWS resources. A security engineer must implement a solution to collect, review, and manage the evidence to demonstrate compliance with company policy.

Which solution will meet these requirements?

- A. Create an assessment in AWS Audit Manager from a prebuilt framework or a custom framework. Upload manual evidence from the on-premises workloads. Add the evidence to the

assessment. Generate an assessment report after Audit Manager collects the necessary evidence from the AWS resources.

B. Install the Amazon CloudWatch agent on the on-premises workloads. Use AWS Config to deploy a conformance pack from a sample conformance pack template or a custom YAML template. Generate an assessment report after AWS Config identifies noncompliant workloads and resources.

C. Set up the appropriate security standard in AWS Security Hub. Upload manual evidence from the on-premises workloads. Wait for Security Hub to collect the evidence from the AWS resources. Download the list of controls as a .csv file.

D. Install the Amazon CloudWatch agent on the on-premises workloads. Create a CloudWatch dashboard to monitor the on-premises workloads and the AWS resources. Run a query on the workloads and resources. Download the results.

▼ 中文

在混合雲環境中營運的公司必須滿足嚴格的合規性要求。該公司希望建立一份報告，其中包含來自本地工作負載和 AWS 資源的證據。安全工程師必須實施一項解決方案來收集、審查和管理這些證據，以證明其符合公司政策。

哪種解決方案能夠滿足這些要求？

A. 在 AWS Audit Manager 中，使用預先建置框架或自訂框架建立評估。上傳本地工作負載的手動證據。將證據添加到評估中。在 Audit Manager 從 AWS 資源收集必要的證據後，產生評估報告。

B. 在本機工作負載上安裝 Amazon CloudWatch 代理程式。使用 AWS Config 從範例一致性套件範本或自訂 YAML 範本部署一致性套件。在 AWS Config 識別出不合規的工作負載和資源後，產生評估報告。

C. 在 AWS Security Hub 中設定適當的安全標準。上傳本地工作負載的手動證據。等待 Security Hub 從 AWS 資源收集證據。下載控制列表(.csv檔案)

D. 在本機工作負載上安裝 Amazon CloudWatch 代理程式。建立 CloudWatch 儀表板來監控本機工作負載和 AWS 資源。對工作負載和資源執行查詢。下載結果。

▼ 解答

A

1. 考察的知识点

本题考察的是AWS Audit Manager的功能及其在混合云环境中用于合规性报告的能力。同时涉及如何处理来自本地工作负载的手动证据，以及如何生成合规性评估报告。

2. 选项分析

A. Create an assessment in AWS Audit Manager from a prebuilt framework or a custom framework. Upload manual evidence from the on-premises workloads. Add the evidence to the assessment. Generate an assessment report after Audit Manager collects the necessary evidence from the AWS resources.

正确：此选项准确描述了AWS Audit Manager的功能。Audit Manager允许用户创建评估，上传手动证据（例如来自本地

工作负载的证据），并结合AWS资源的自动收集证据生成合规性报告。这完全符合题目要求。

B. Install the Amazon CloudWatch agent on the on-premises workloads. Use AWS Config to deploy a conformance pack from a sample conformance pack template or a custom YAML template. Generate an assessment report after AWS Config identifies noncompliant workloads and resources.

错误：AWS Config主要用于资源配置的合规性检查，而不是生成合规性报告。虽然可以使用合规包（Conformance

Pack）来检查资源是否符合标准，但它无法处理手动证据，也无法生成综合的合规性报告。

C. Set up the appropriate security standard in AWS Security Hub. Upload manual evidence from the on-premises workloads.

Wait for Security Hub to collect the evidence from the AWS resources. Download the list of controls as a .csv file.

错误：AWS Security Hub主要用于集中管理和查看安全警报，并评估资源的安全性。它不支持上传手动证据，也无法生成合规性报告。

D. Install the Amazon CloudWatch agent on the on-premises workloads. Create a CloudWatch dashboard to monitor the onpremises

workloads and the AWS resources. Run a query on the workloads and resources. Download the results.

错误：Amazon CloudWatch主要用于监控和日志管理，而不是用于合规性报告。虽然可以通过仪表板查看资源状态，但

它无法处理手动证据，也无法生成合规性报告。

▼ 57

▼ 英文

To meet regulatory requirements, a security engineer needs to implement an IAM policy that restricts the use of AWS services to the us-east-1 Region.

What policy should the engineer implement?

A.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "*",
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "aws:RequestedRegion": "us-east-1"
        }
      }
    }
  ]
}
```

B.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "*",
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "ec2:Region": "us-east-1"
        }
      }
    }
  ]
}
```

C.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Deny",
      "Action": "*",
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": "us-east-1"
        }
      }
    }
  ]
}
```

D.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Deny",
      "NotAction": "*",
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "aws:RequestedRegion": "us-east-1"
        }
      }
    }
  ]
}
```

▼ 中文

为了满足监管要求，安全工程师需要实施 IAM 策略，将 AWS 服务的使用限制在 us-east-1 区域。工程师应该实施什么政策？

A.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "*",
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "aws:RequestedRegion": "us-east-1"
        }
      }
    }
  ]
}
```

B.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "*",
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "ec2:Region": "us-east-1"
        }
      }
    }
  ]
}
```

C.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Deny",
      "Action": "*",
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": "us-east-1"
        }
      }
    }
  ]
}
```

D.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Deny",
      "NotAction": "*",
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "aws:RequestedRegion": "us-east-1"
        }
      }
    }
  ]
}
```

▼ 解答

C

1. 考察的知识点

IAM策略的编写与应用

如何使用条件语句限制AWS服务的区域

理解AWS服务的区域性限制和IAM策略的作用

2. 选项分析

A: 无法判断正确或错误，因为选项内容未提供。

B: 无法判断正确或错误，因为选项内容未提供。

C: Most Voted。根据题目要求，C选项可能包含一个正确的IAM策略，使用了条件语句限制服务只能在us-east-1区域运

行。

D: 无法判断正确或错误，因为选项内容未提供。

3. 我选的答案

▼ 58

▼ 英文

A company has a web server in the AWS Cloud. The company will store the content for the web server in an Amazon S3 bucket. A security engineer must use an Amazon CloudFront distribution to speed up delivery of the content. None of the files can be publicly accessible from the S3 bucket directly.

Which solution will meet these requirements?

A. Configure the permissions on the individual files in the S3 bucket so that only the CloudFront distribution has access to them.

B. Create an origin access control (OAC). Associate the OAC with the CloudFront distribution. Configure the S3 bucket permissions so that only the OAC can access the files in the S3 bucket.

C. Create an S3 role in AWS Identity and Access Management (IAM). Allow only the CloudFront distribution to assume the role to access the files in the S3 bucket.

D. Create an S3 bucket policy that uses only the CloudFront distribution ID as the principal and the Amazon Resource Name (ARN) as the target.

▼ 中文

一家公司在 AWS 云端中拥有一台 Web 伺服器。该公司将 Web 伺服器的内容储存在 Amazon S3 储存桶中。一位安全工程师必须使用 Amazon CloudFront 发行版来加快内容的交付速度。所有文件都无法从 S3 储存桶直接公开存取。哪种解决方案可以满足这些要求？

A. 配置 S3 储存桶中各个档案的权限，以便只有 CloudFront 分发可以存取它们。

B. 建立来源存取控制 (OAC)。将 OAC 与 CloudFront 分配关联。配置 S3 储存桶权限，确保只有 OAC 可以存取 S3 储存桶中的档案。

C. 在 AWS Identity and Access Management (IAM) 中建立 S3 角色。仅允许 CloudFront 发行版代入该角色来存取 S3 储存桶中的档案。

D. 建立一个 S3 储存桶策略，该策略仅使用 CloudFront 分发 ID 作为主体，并使用 Amazon 资源名称 (ARN) 作为目标。

▼ 解答

B

1. 考察的知识点

Amazon S3 与 Amazon CloudFront 的集成。

如何确保 S3 bucket 内容不直接公开访问。

使用 Origin Access Control (OAC) 来限制访问。

2. 选项分析

A. Configure the permissions on the individual files in the S3 bucket so that only the CloudFront distribution has access to them.

错误：逐个配置文件权限的方式效率低下，且不符合最佳实践。AWS 提供了更好的方法（如 OAC）来实现这种需求。

B. Create an origin access control (OAC). Associate the OAC with the CloudFront distribution. Configure the S3 bucket

permissions so that only the OAC can access the files in the S3 bucket.

正确：OAC 是 AWS 推荐的方式，用于确保 CloudFront 可以安全地访问 S3 bucket，而 S3 bucket 内容不会被直接公开访问。

OAC 是 CloudFront 的新功能，取代了之前的 Origin Access Identity (OAI)。

C. Create an S3 role in AWS Identity and Access Management (IAM). Allow only the CloudFront distribution to assume the role to access the files in the S3 bucket.

错误：IAM 角色通常用于服务之间的权限管理，但 CloudFront 无法直接假设 IAM 角色来访问 S3 bucket。

D. Create an S3 bucket policy that uses only the CloudFront distribution ID as the principal and the Amazon Resource Name (ARN) as the target.

错误：S3 bucket policy 无法直接使用 CloudFront distribution ID 作为主体。需要使用 OAC 或 OAI 来实现这种限制。

▼ 59

▼ 英文

A security engineer logs in to the AWS Lambda console with administrator permissions. The security engineer is trying to view logs in Amazon CloudWatch for a Lambda function that is named myFunction. When the security engineer chooses the option in the Lambda console to view logs in CloudWatch, an "error loading Log Streams" message appears.

The IAM policy for the Lambda function's execution role contains the following:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "logs:CreateLogGroup",
      "Resource": "arn:aws:logs:us-east-1:111111111111:*"
    },
    {
      "Effect": "Allow",
      "Action": ["logs:PutLogEvents"],
      "Resource": ["arn:aws:logs:us-east-1:111111111111:log-group:/aws/lambda/myFunction:*"]
    }
  ]
}
```

How should the security engineer correct the error?

A. Move the logs:CreateLogGroup action to the second Allow statement.

B. Add the logs:PutDestination action to the second Allow statement.

C. Add the logs:GetLogEvents action to the second Allow statement.

D. Add the logs:CreateLogStream action to the second Allow statement.

▼ 中文

安全工程师以管理员权限登入 AWS Lambda 控制台。安全工程师正在尝试查看 Amazon CloudWatch 中名为 myFunction 的 Lambda 函数的日志。当安全工程师在 Lambda 控制台中选择查看 CloudWatch 中的日志的选项时，会出现「载入日志流时发生错误」讯息。

Lambda 函数执行角色的 IAM 策略包含以下内容：
安全工程师该如何修正这个错误？

- A. 将 logs:CreateLogGroup 运算移至第二个 Allow 语句。
- B. 将 logs:PutDestination 运算加入第二个 Allow 语句。
- C. 将 logs:GetLogEvents 作业加入第二个 Allow 语句。
- D. 将 logs:CreateLogStream 作业加入第二个 Allow 语句。

▼ 解答

D

1. 考察的知识点

IAM 权限管理：理解如何配置 IAM 策略以支持 AWS 服务的操作。

CloudWatch 日志权限：了解 Lambda 函数如何与 CloudWatch 日志集成，以及所需的权限。

2. 选项分析

A. Move the logs:CreateLogGroup action to the second Allow statement.

错误：logs:CreateLogGroup 的作用是创建日志组，但问题并不是日志组无法创建，而是日志流（Log Stream）无法加载。

将 logs:CreateLogGroup 移动到第二个语句不会解决问题，因为问题的根本原因是缺少 logs:CreateLogStream 权限。

B. Add the logs:PutDestination action to the second Allow statement.

错误：logs:PutDestination 的作用是管理日志目标（Log Destination），通常用于跨账户日志传输，而不是创建或管理日志流。

此操作与当前问题无关，无法解决“error loading Log Streams”问题。

C. Add the logs:GetLogEvents action to the second Allow statement.

错误：logs:GetLogEvents 的作用是读取日志事件，但问题并不是读取日志事件，而是日志流无法加载。

此操作与当前问题无关，无法解决“error loading Log Streams”问题。

D. Add the logs:CreateLogStream action to the second Allow statement.

正确：logs:CreateLogStream 的作用是创建日志流（Log Stream），这是 Lambda 函数在写入日志到 CloudWatch 时所需的权限。

当前 IAM 策略缺少 logs:CreateLogStream 权限，导致日志流无法加载，添加此权限可以解决问题。

▼ 60

▼ 英文

A company has a new partnership with a vendor. The vendor will process data from the company's customers. The company will upload data files as objects into an Amazon S3 bucket. The vendor will download the objects to perform data processing. The objects will contain sensitive data.

A security engineer must implement a solution that prevents objects from residing in the S3 bucket for longer than 72 hours.

Which solution will meet these requirements?

- A. Use Amazon Macie to scan the S3 bucket for sensitive data every 72 hours. Configure Macie to delete the objects that contain sensitive data when they are discovered.
- B. Configure an S3 Lifecycle rule on the S3 Bucket to expire objects that have been in the S3 bucket for 72 hours.
- C. Create an Amazon EventBridge scheduled rule that invokes an AWS Lambda function every day. Program the Lambda function to remove any objects that have been in the S3 bucket for 72 hours.
- D. Use the S3 Intelligent-Tiering storage class for all objects that are uploaded to the S3 bucket. Use S3 Intelligent-Tiering to expire objects that have been in the S3 bucket for 72 hours.

▼ 中文

一家公司与一家供应商建立了新的合作关系。该供应商将处理来自该公司客户的资料。该公司将资料档案作为物件上传到 Amazon S3 储存桶。供应商将下载这些物件以进行资料处理。这些物件将包含敏感资料。

安全工程师必须实施一项解决方案，以防止物件在 S3 储存桶中驻留超过 72 小时。
哪种解决方案能够满足这些要求？

- A. 每 72 小时扫描一次 S3 储存桶中的敏感资料。配置 Macie，以便在发现包含敏感资料的物件时将其删除。
- B. S3 储存桶上设定 S3 生命周期规则，以使已在 S3 储存桶中 72 小时的物件过期。
- C. 建立一条 Amazon EventBridge 计划规则，每天呼叫一次 AWS Lambda 函数。对 Lambda 函数进行编程，使其删除 S3 储存桶中已储存 72 小时的所有物件。
- D. 对上传到 S3 储存桶的所有物件使用 S3 智慧分层储存类别。使用 S3 智慧分层使已在 3 美元储存桶中储存 72 小时的物件过期。

▼ 解答

B

1. 考察的知识点

Amazon S3 Lifecycle 规则的使用与配置。
数据生命周期管理和自动化删除机制。
安全性与敏感数据的管理。

2. 选项分析

- A. 使用 Amazon Macie 每 72 小时扫描一次 S3 bucket 中的敏感数据。配置 Macie 在发现包含敏感数据的对象时删除这些对象。
错误：Amazon Macie 是一种数据分类和安全性服务，用于识别敏感数据，但它并不具备自动删除对象的功能。
此外，题目要求的是删除所有对象，而不是仅删除敏感数据。
- B. 在 S3 bucket 上配置一个 S3 Lifecycle 规则，使在 S3 bucket 中存留超过 72 小时的对象过期。
正确：S3 Lifecycle 规则可以自动管理对象的生命周期，包括设置过期时间以删除对象。
这是最直接、最符合题目要求的解决方案。
- C. 创建一个 Amazon EventBridge 定时规则，每天调用一个 AWS Lambda 函数。编写 Lambda 函数以删除在 S3 bucket 中存留超过 72 小时的对象。
错误：虽然这种方法可以实现目标，但它需要额外的开发和维护工作。
相比于直接使用 S3 Lifecycle 规则，这种方法显得复杂且不必要。
- D. 对上传到 S3 bucket 的所有对象使用 S3 Intelligent-Tiering 存储类别。使用 S3 Intelligent-Tiering 使在 S3 bucket 中存留超过 72 小时的对象过期。

错误：S3 Intelligent-Tiering 是一种存储优化服务，用于根据访问模式自动移动对象到不同的存储层，但它不支持设置对象过期时间。
因此，这个选项无法满足题目要求。

▼ 61

▼ 英文

A company accidentally deleted the private key for an Amazon Elastic Block Store (Amazon EBS)-backed Amazon EC2 instance. A security engineer needs to regain access to the instance. Which combination of steps will meet this requirement? (Choose two.)

- A. Stop the instance. Detach the root volume. Generate a new key pair.
- B. Keep the instance running. Detach the root volume. Generate a new key pair.
- C. When the volume is detached from the original instance, attach the volume to another instance as a data volume. Modify the `authorized_keys` file with a new public key. Move the volume back to the original instance. Start the instance.
- D. When the volume is detached from the original instance, attach the volume to another instance as a data volume. Modify the `authorized_keys` file with a new private key. Move the volume back to the original instance. Start the instance.
- E. When the volume is detached from the original instance, attach the volume to another instance as a data volume. Modify the `authorized_keys` file with a new public key. Move the volume back to the original instance that is running.

▼ 中文

一家公司意外删除了由 Amazon Elastic Block Store (Amazon EBS) 支援的 Amazon EC2 执行个体的私钥。一位安全工程师需要重新取得该实例的存取权限。
哪种步骤组合可以满足此要求？（选两项。）

- A. 停止实例。分离根卷。产生新的密钥对。
- B. 保持实例运行。分离根卷。产生新的密钥对。
- C. 当磁碟区从原始实例分离后，将其作为资料卷附加到另一个实例。使用新的公钥修改 `authorized_keys` 档案。将磁碟区移回原始实例。启动实例。
- D. 当磁碟区与原始实例分离后，将其作为资料卷附加到另一个实例。使用新的私钥修改 `authorized_keys` 档案。将磁碟区移回原始实例。启动实例。
- E. 当磁碟区从原始实例分离后，将其作为资料卷附加到另一个实例。使用新的公钥修改 `authorized_keys` 档案。将磁碟区移回正在运行的原始实例。

▼ 解答

AC

1. 考察的知识点

Amazon EC2实例的访问恢复方法。
Amazon EBS卷的操作，包括卸载和重新挂载。
SSH密钥对的管理和授权文件（`authorized_keys`）的修改。

2. 选项分析

A. Stop the instance. Detach the root volume. Generate a new key pair.
正确：停止实例并卸载根卷是恢复访问的必要步骤，因为需要修改根卷上的 `authorized_keys` 文件。
生成新的密钥对是恢复访问的关键步骤，新的公钥将被添加到 `authorized_keys` 文件中。

B. Keep the instance running. Detach the root volume. Generate a new key pair.

错误：无法在实例运行时卸载根卷，AWS要求实例必须停止才能卸载根卷。

C. When the volume is detached from the original instance, attach the volume to another instance as a data volume. Modify the authorized_keys file with a new public key. Move the volume back to the original instance. Start the instance.

正确：将卷附加到另一个实例作为数据卷，可以访问文件系统并修改authorized_keys文件。

使用新的公钥更新authorized_keys文件是恢复访问的正确方法。

将卷移回原始实例并启动实例是恢复访问的最后步骤。

D. When the volume is detached from the original instance, attach the volume to another instance as a data volume. Modify the authorized_keys file with a new private key. Move the volume back to the original instance. Start the instance.

错误：authorized_keys文件中存储的是公钥，而不是私钥。修改为私钥是错误的操作。

E. When the volume is detached from the original instance, attach the volume to another instance as a data volume. Modify the authorized_keys file with a new public key. Move the volume back to the original instance that is running.

错误：无法在实例运行时重新挂载根卷，AWS要求实例必须停止才能挂载根卷。

▼ 62

▼ 英文

A company purchased a subscription to a third-party cloud security scanning solution that integrates with AWS Security Hub. A security engineer needs to implement a solution that will remediate the findings from the third-party scanning solution automatically. Which solution will meet this requirement?

A. Set up an Amazon EventBridge rule that reacts to new Security Hub findings. Configure an AWS Lambda function as the target for the rule to remediate the findings.

B. Set up a custom action in Security Hub. Configure the custom action to call AWS Systems Manager Automation runbooks to remediate the findings.

C. Set up a custom action in Security Hub. Configure an AWS Lambda function as the target for the custom action to remediate the findings.

D. Set up AWS Config rules to use AWS Systems Manager Automation runbooks to remediate the findings.

▼ 中文

一家公司购买了与 AWS Security Hub 整合的第三方云端安全扫描解决方案。一位安全工程师需要实施一项解决方案，以自动修复第三方扫描解决方案发现的问题。

哪种解决方案可以满足这项要求？

A. 设定一条 Amazon EventBridge 规则，用于回应新的 Security Hub 发现。配置一个 AWS Lambda 函数作为规则的目标，以修复发现的问题。

B. 在 Security Hub 中设定自订操作。配置自订操作以呼叫 AWS Systems Manager Automation Runbook 来修复发现的问题。

C. 在 Security Hub 中设定自订操作。将 AWS Lambda 函数配置为自订操作的目标，以修复发现的问题。

D. 设定 AWS Config 规则以使用 AWS Systems Manager Automation 运行手册来修复发现的问题。

▼ 解答

A

1. 考察的知识点

本题考察的是AWS Security Hub与其他AWS服务(如Amazon EventBridge、AWS Lambda、AWS Systems Manager Automation等)的集成能力，以及自动化处理安全发现的能力。
重点在于如何实现自动化的安全发现修复。

2. 选项分析

A.

正确:Amazon EventBridge可以订阅Security Hub的发现事件，并触发AWS Lambda函数来执行自动化修复操作。这种方式是AWS推荐的最佳实践之一，能够实现实时响应和自动化处理。

B.

错误:虽然Security Hub支持自定义操作，但自定义操作通常是手动触发的，而不是自动化的。这不符合题目要求的“自动修复”需求。

C.

错误:与选项B类似，自定义操作需要手动触发，无法实现自动化修复。这不符合题目要求。

D.

错误:AWS Config规则主要用于资源合规性检查，而不是直接处理Security Hub的发现。虽然可以间接实现修复，但这不是最直接的解决方案。

▼ 63

▼ 英文

An application is running on an Amazon EC2 instance that has an IAM role attached. The IAM role provides access to an AWS Key Management Service (AWS KMS) customer managed key and an Amazon S3 bucket. The key is used to access 2 TB of sensitive data that is stored in the S3 bucket.

A security engineer discovers a potential vulnerability on the EC2 instance that could result in the compromise of the sensitive data. Due to other critical operations, the security engineer cannot immediately shut down the EC2 instance for vulnerability patching.

What is the FASTEST way to prevent the sensitive data from being exposed?

A.Download the data from the existing S3 bucket to a new EC2 instance. Then delete the data from the S3 bucket. Re-encrypt the data with a client-based key. Upload the data to a new S3 bucket.

B.Block access to the public range of S3 endpoint IP addresses by using a host-based firewall. Ensure that internet-bound traffic from the affected EC2 instance is routed through the host-based firewall.

C.Revoke the IAM role's active session permissions. Update the S3 bucket policy to deny access to the IAM role. Remove the IAM role from the EC2 instance profile.

D.Disable the current key. Create a new KMS key that the IAM role does not have access to, and re-encrypt all the data with the new key. Schedule the compromised key for deletion.

▼ 中文

一个应用程序正在一个附加了 IAM 角色的 Amazon EC2 执行个体上执行。此 IAM 角色提供 AWS Key Management Service (AWS KMS) 客户管理金钥和 Amazon S3 储存桶的存取权。此金钥用于存取存储在 S3 储存桶中的 2 TB 敏感资料。

一位安全工程师发现 EC2 执行个体上存在一个潜在漏洞，该漏洞可能导致敏感资料外洩。由于其他关键操作正在进行，安全工程师无法立即关闭 EC2 执行个体进行漏洞修补。

防止敏感资料外洩最快的方法是什么？

A. 将资料从现有的 S3 储存桶下载到新的 EC2 执行个体。然后从 S3 储存桶中删除资料。使用基于客户端的金钥重新加密资料。将资料上传到新的 S3 储存桶。

B. 使用基于主机的防火墙阻止对 S3 终端节点 IP 位址的公共范围的存取。确保受影响的 EC2 执行个体的 Internet 绑定流量透过基于主机的防火墙进行路由。

C. 撤销 IAM 角色的活动会话权限。更新 S3 储存桶策略以拒绝 IAM 角色的存取。从 EC2 执行个体设定档移除 IAM 角色。

D. 禁用当前密钥。建立一个 IAM 角色无权存取的新 KMS 金钥，并使用新金钥重新加密所有资料。安排删除已洩漏的密钥。

▼ 解答

C

1. 考察的知识点

IAM角色的权限管理与撤销

S3存储桶策略的访问控制

如何快速响应安全事件以保护敏感数据

AWS Key Management Service (KMS)的使用与管理

2. 选项分析

A. 将现有 S3 存储桶中的数据下载到一个新的 EC2 实例。然后从 S3 存储桶中删除数据。使用基于客户端的密钥

重新加密数据。将数据上传到一个新的 S3 存储桶。

错误：此选项涉及多个复杂操作，包括下载、删除、重新加密和上传数据。这些操作需要较长时间，无法快速阻止数

据泄露。

B. 使用基于主机的防火墙阻止对 S3 端点 IP 地址公共范围的访问。确保受影响的 EC2 实例的互联网流量通过基

于主机的防火墙进行路由。

错误：虽然可以通过防火墙限制流量，但这并不能完全阻止 EC2 实例对 S3 存储桶的访问，因为 IAM 角色仍然有效。

C. 撤销 IAM 角色的活动会话权限。更新 S3 存储桶策略以拒绝 IAM 角色的访问权限。从 EC2 实例配置文件中移除

IAM 角色。

正确：此选项直接解决问题，通过撤销 IAM 角色权限和更新存储桶策略，可以立即阻止 EC2 实例访问敏感数据。

D. 禁用当前密钥。创建一个 IAM 角色无法访问的新 KMS 密钥，并使用新密钥重新加密所有数据。安排删除受损的密钥。

错误：禁用 KMS 密钥和重新加密数据是一个耗时的过程，无法快速阻止数据泄露。

▼ 64

▼ 英文

A company is building an application on AWS that will store sensitive information. The company has a support team with access to the IT infrastructure, including databases. The company's security engineer must introduce measures to protect the sensitive data against any data breach while minimizing management overhead. The credentials must be regularly rotated.

What should the security engineer recommend?

A. Enable Amazon RDS encryption to encrypt the database and snapshots. Enable Amazon Elastic Block Store (Amazon EBS) encryption on Amazon EC2 instances. Include the database credential in the EC2 user data field. Use an AWS Lambda function to rotate database credentials. Set up TLS for the connection to the database.

B. Install a database on an Amazon EC2 instance. Enable third-party disk encryption to encrypt the Amazon Elastic Block Store (Amazon EBS) volume. Store the database credentials in AWS CloudHSM with automatic rotation. Set up TLS for the connection to the database.

C. Enable Amazon RDS encryption to encrypt the database and snapshots. Enable Amazon Elastic Block Store (Amazon EBS) encryption on Amazon EC2 instances. Store the database credentials in AWS Secrets Manager with automatic rotation. Set up TLS for the connection to the RDS hosted database.

D. Set up an AWS CloudHSM cluster with AWS Key Management Service (AWS KMS) to store KMS keys. Set up Amazon RDS encryption using AWS KMS to encrypt the database. Store database credentials in the AWS Systems Manager Parameter Store with automatic rotation. Set up TLS for the connection to the RDS hosted database.

▼ 中文

一家公司正在 AWS 上建立一个用于储存敏感资讯的应用程式。该公司拥有一个可以存取 IT 基础设施（包括资料库）的支援团队。该公司的安全工程师必须采取措施保护敏感资料免遭洩露，同时最大限度地降低管理开销。凭证必须定期轮换。安全工程师该提出什麼建议？

A. 启用 Amazon RDS 加密来加密资料库和快照。在 Amazon EC2 执行个体上启用 Amazon Elastic Block Store (Amazon EBS) 加密。在 EC2 使用者资料栏位中包含资料库凭证。使用 AWS Lambda 函数轮换资料库凭证。为资料库连线设定 TLS。

B. 在 Amazon EC2 执行个体上安装资料库。启用第三方磁碟加密来加密 Amazon Elastic Block Store (Amazon EBS) 磁碟区。将资料库凭证储存在 AWS CloudHSM 中并自动轮换。设定 TLS 以连接资料库。

C. 启用 Amazon RDS 加密来加密资料库和快照。在 Amazon EC2 执行个体上启用 Amazon Elastic Block Store (Amazon EBS) 加密。将资料库凭证储存在 AWS Secrets Manager 中并自动轮调。设定 TLS 以连接到 RDS 託管资料库。

D. 使用 AWS Key Management Service (AWS KMS) 设定 AWS CloudHSM 丛集以储存 KMS 金钥。使用 AWS KMS 设定 Amazon RDS 加密以加密资料库。将资料库凭证储存在 AWS Systems Manager 参数储存中并自动轮换。设定 TLS 以连接 RDS 託管资料库。

▼ 解答

C

1. 考察的知识点

数据加密：如何使用 AWS 服务对数据进行加密以保护敏感信息。

凭证管理：如何安全存储和自动轮换数据库凭证。

传输安全：如何使用 TLS 确保数据传输的安全性。

管理开销：选择最小化管理开销的解决方案。

2. 选项分析

A:

启用 Amazon RDS 加密和 Amazon EBS 加密是正确的做法，可以保护数据存储的安全。

将数据库凭证包含在 EC2 用户数据字段中是不安全的，因为用户数据可能被其他人访问，存在泄露风险。

使用 AWS Lambda 函数轮换数据库凭证是可行的，但 AWS Secrets Manager 提供了更简单的自动轮换功能。

设置 TLS 是正确的做法，可以保护数据传输的安全。

总体来说，此选项在凭证管理方面不够安全，因此不推荐。

B:

在 EC2 实例上安装数据库增加了管理开销，不符合最小化管理开销的要求。

启用第三方磁盘加密增加了复杂性，AWS 原生的加密功能更适合。

将数据库凭证存储在 AWS CloudHSM 中并自动轮换是可行的，但 AWS Secrets Manager 更适合此场景。

设置 TLS 是正确的做法，可以保护数据传输的安全。

总体来说，此选项增加了管理复杂性，不是最佳选择。

C:

启用 Amazon RDS 加密和 Amazon EBS 加密是正确的做法，可以保护数据存储的安全。

将数据库凭证存储在 AWS Secrets Manager 中并自动轮换是最佳实践，提供了安全性和最小化管理开销的功能。

设置 TLS 是正确的做法，可以保护数据传输的安全。

此选项全面满足题目要求，是最佳选择。

D:

设置 AWS CloudHSM 集群增加了管理开销，不符合最小化管理开销的要求。

使用 AWS KMS 设置 Amazon RDS 加密是正确的做法，可以保护数据存储的安全。

将数据库凭证存储在 AWS Systems Manager Parameter Store 中并自动轮换是可行的，但 AWS Secrets Manager 更适合此

场景。

设置 TLS 是正确的做法，可以保护数据传输的安全。

总体来说，此选项增加了管理复杂性，不是最佳选择。

▼ 65

▼ 英文

A company is using Amazon Route 53 Resolver for its hybrid DNS infrastructure. The company has set up Route 53 Resolver forwarding rules for authoritative domains that are hosted on on-premises DNS servers.

A new security mandate requires the company to implement a solution to log and query DNS traffic that goes to the on-premises DNS servers. The logs must show details of the source IP address of the instance from which the query originated. The logs also must show the DNS name that was requested in Route 53 Resolver.

Which solution will meet these requirements?

A. Use VPC Traffic Mirroring. Configure all relevant elastic network interfaces as the traffic source, include amazon-dns in the mirror filter, and set Amazon CloudWatch Logs as the mirror target. Use CloudWatch Insights on the mirror session logs to run queries on the source IP address and DNS name.

B. Configure VPC flow logs on all relevant VPCs. Send the logs to an Amazon S3 bucket. Use Amazon Athena to run SQL queries on the source IP address and DNS name.

C. Configure Route 53 Resolver query logging on all relevant VPCs. Send the logs to Amazon CloudWatch Logs. Use CloudWatch Insights to run queries on the source IP address and DNS name.

D. Modify the Route 53 Resolver rules on the authoritative domains that forward to the on-premises DNS servers. Send the logs to an Amazon S3 bucket. Use Amazon Athena to run SQL queries on the source IP address and DNS name.

▼ 中文

一家公司正在使用 Amazon Route 53 Resolver 作为其混合 DNS 基础设施。该公司已为託管在本地 DNS 伺服器上的权威网域设定了 Route 53 Resolver 转送规则。

一项新的安全性需求要求该公司实施一项解决方案，用于记录 and 查询流向本地 DNS 伺服器的 DNS 流量。日志必须显示发起查询的执行个体的来源 IP 地址的详细资讯。日志也必须显示在 Route 53 Resolver 中请求的 DNS 名称。

哪种解决方案能够满足这些要求？

A. 使用 VPC 流量镜像。将所有相关的弹性网路介面配置为流量来源，在镜像筛选器中包含 amazon-dns，并将 Amazon CloudWatch Logs 设定为镜像目标。使用镜像会话日志中的 CloudWatch Insights 对来源 IP 地址和 DNS 名称执行查询。

B. 在所有相关 VPC 上设定 VPC 流日志。将日志传送到 Amazon S3 储存桶。使用 Amazon Athena 对来源 IP 地址和 DNS 名称执行 SQL 查询。

C. 在所有相关 VPC 上设定 Route 53 Resolver 查询日志记录。将日志传送到 Amazon CloudWatch Logs。使用 CloudWatch Insights 对来源 IP 地址和 DNS 名称执行查询。

D. 修改转送至本机 DNS 伺服器的权威域上的 Route 53 解析器规则。将日志传送到 Amazon S3 储存桶。使用 Amazon Athena 对来源 IP 地址和 DNS 名称执行 SQL 查询。

▼ 解答

C

1. 考察的知识点

Route 53 Resolver 的查询日志功能。

如何记录和分析 DNS 流量，包括源 IP 地址和 DNS 查询名称。

使用 Amazon CloudWatch Logs 和 CloudWatch Insights 进行日志分析。

2. 选项分析

A. 使用 VPC Traffic Mirroring。

错误：VPC Traffic Mirroring 主要用于捕获网络流量包，而不是专门用于 DNS 查询日志记录。虽然可以捕获流量，但需要

额外的复杂配置来解析 DNS 流量，且无法直接满足题目要求的 DNS 查询日志功能。

B. 配置 VPC Flow Logs。

错误：VPC Flow Logs 记录的是网络流量元数据（如源 IP、目标 IP、端口等），但不包含 DNS 查询的具体内容（如 DNS 名

称）。因此无法满足题目要求。

C. 配置Route 53 Resolver查询日志。

正确：Route 53 Resolver支持查询日志功能，可以记录DNS查询的详细信息，包括源IP地址和DNS名称。将日志发送到

CloudWatch Logs后，可以使用CloudWatch Insights进行查询分析，完全满足题目要求。

D. 修改Route 53 Resolver规则。

错误：修改Route 53 Resolver规则并不能直接实现DNS查询日志记录功能。虽然可以将日志发送到S3并使用Athena进行

查询，但这不是实现DNS查询日志的正确方法。

▼ 66

▼ 英文

A security engineer is configuring account-based access control (ABAC) to allow only specific principals to put objects into an Amazon S3 bucket. The principals already have access to Amazon S3.

The security engineer needs to configure a bucket policy that allows principals to put objects into the S3 bucket only if the value of the Team tag on the object matches the value of the Team tag that is associated with the principal. During testing, the security engineer notices that a principal can still put objects into the S3 bucket when the tag values do not match.

Which combination of factors are causing the PutObject operation to succeed when the tag values are different? (Choose two.)

- A.The principal's identity-based policy grants access to put objects into the S3 bucket with no conditions.
- B.The principal's identity-based policy overrides the condition because the identity-based policy contains an explicit allow.
- C.The S3 bucket's resource policy does not deny access to put objects.
- D.The S3 bucket's resource policy cannot allow actions to the principal.
- E.The bucket policy does not apply to principals in the same zone of trust.

▼ 中文

一位安全工程师正在配置基于帐户的存取控制 (ABAC)，以仅允许特定主体将物件放入Amazon S3 储存桶。这些主体已经拥有 Amazon S3 的存取权。

安全工程师需要配置一个储存桶策略，该策略仅允许主体在物件上的 Team 标籤值与主体关联的 Team 标籤值相符时，将物件放入 S3 储存桶。在测试过程中，安全工程师注意到，即使标籤值不匹配，主体仍可将物件放入 S3 储存桶。

当标籤值不同时，哪些因素组合会导致 PutObject 操作成功？（选两项。）

- A.委託人的基于身分的策略授予将物件无条件放入 S3 储存桶的权限。
- B.主体的基于身份的策略复盖该条件，因为基于身份的策略包含明确的允许。
- C.S3 储存桶的资源策略不会拒绝存取放置物件。
- D.S3 储存桶的资源策略不能允许对主体执行操作。
- E.储存桶策略不适用于相同信任区域中的主体。

▼ 解答

AC

1. 考察的知识点

Amazon S3 Bucket Policy的配置与条件逻辑。

基于身份的策略（Identity-based Policy）与资源策略（Resource-based Policy）的交互。

ABAC（Account-Based Access Control）的实现与条件匹配。

2. 选项分析

A. The principal's identity-based policy grants access to put objects into the S3 bucket with no conditions.

正确。基于身份的策略可以直接授予权限，而不依赖资源策略的条件。如果主体的身份策略中明确允许PutObject操

作，并且没有附加条件，那么即使资源策略中有条件限制，主体仍然可以执行操作。

B. The principal's identity-based policy overrides the condition because the identity-based policy contains an explicit allow.

错误。基于身份的策略不会“覆盖”资源策略的条件，而是两者共同作用。如果资源策略中有明确的拒绝（explicit deny），则拒绝优先。

C. The S3 bucket's resource policy does not deny access to put objects.

正确。如果资源策略没有明确拒绝PutObject操作，那么基于身份的策略中的允许（allow）将生效。这是导致操作成功的一个关键因素。

D. The S3 bucket's resource policy cannot allow actions to the principal.

错误。资源策略可以允许或拒绝主体执行操作，具体取决于策略的配置。

E. The bucket policy does not apply to principals in the same zone of trust.

错误。S3存储桶策略适用于所有主体，无论是否在同一信任区域内。

▼ 67

▼ 英文

A company is hosting multiple applications within a single VPC in its AWS account. The applications are running behind an Application Load Balancer that is associated with an AWS WAF web ACL. The company's security team has identified that multiple port scans are originating from a specific range of IP addresses on the internet. A security engineer needs to deny access from the offending IP addresses. Which solution will meet these requirements?

A. Modify the AWS WAF web ACL with an IP set match rule statement to deny incoming requests from the IP address range.

B. Add a rule to all security groups to deny the incoming requests from the IP address range.

C. Modify the AWS WAF web ACL with a rate-based rule statement to deny the incoming requests from the IP address range.

D. Configure the AWS WAF web ACL with regex match conditions. Specify a pattern set to deny the incoming requests based on the match condition.

▼ 中文

一家公司在其 AWS 帐户的单一 VPC 内托管多个应用程序。这些应用程序在与 AWS WAF Web ACL 关联的应用程序负载均衡器 (ALB) 后运行。该公司的安全团队发现，多个连接扫描源自互联网上特定范围的 IP 地址。

安全工程师需要拒绝来自违规 IP 地址的存取。
哪种解决方案可以满足这些要求？

- A.使用 IP 集符合规则语句修改 AWS WAF Web ACL 以拒绝来自 IP 地址范围的传入请求。
- B.向所有安全组新增规则以拒绝来自该 IP 地址范围的传入请求。
- C.使用基于速率的规则语句修改 AWS WAF Web ACL以拒绝来自 IP 地址范围的传入请求。
- D.使用正规表示式符合条件设定 AWS WAF Web ACL。指定一个模式集，以根据符合条件拒绝传入请求。

▼ 解答

A

1. 考察的知识点

本题考察的是AWS WAF（Web Application Firewall）的功能和配置，特别是如何使用IP set match rule来阻止特定IP地址范围的访问。
同时涉及安全组的功能和限制，以及AWS WAF的其他规则类型（如rate-based rule和regex match conditions）。

2. 选项分析

A. Modify the AWS WAF web ACL with an IP set match rule statement to deny incoming requests from the IP address range.

正确。AWS WAF支持IP set match rule，可以直接定义一个IP地址范围并设置为拒绝规则。这是最直接、最有效的方法来阻止特定IP地址范围的访问。

B. Add a rule to all security groups to deny the incoming requests from the IP address range.
错误。安全组不支持“拒绝”规则，只能允许或拒绝流量。安全组的规则是基于允许列表的，因此无法通过安全组直接阻止特定IP地址范围的访问。

C. Modify the AWS WAF web ACL with a rate-based rule statement to deny the incoming requests from the IP address range.

错误。Rate-based rule是用于限制请求速率的规则，适用于防止DDoS攻击或异常流量，但不适合直接阻止特定IP地址范围的访问。

D. Configure the AWS WAF web ACL with regex match conditions. Specify a pattern set to deny the incoming requests based on the match condition. 错误。Regex match conditions是用于匹配请求内容（如URL、头信息等）的规则，无法直接用于匹配和阻止IP地址范围。

▼ 68

▼ 英文

A company has contracted with a third party to audit several AWS accounts. To enable the audit, cross-account IAM roles have been created in each account targeted for audit. The auditor is having trouble accessing some of the accounts.

Which of the following may be causing this problem? (Choose three.)

- A.The external ID used by the auditor is missing or incorrect.
- B.The auditor is using the incorrect password.

- C.The auditor has not been granted sts:AssumeRole for the role in the destination account.
- D.The Amazon EC2 role used by the auditor must be set to the destination account role.
- E.The secret key used by the auditor is missing or incorrect.
- F.The role ARN used by the auditor is missing or incorrect.

▼ 中文

一家公司已与第三方签订合同，以审计多个 AWS 帐户。为了启用稽核功能，公司在每个目标帐户中建立了跨帐户 IAM 角色。审计员在存取某些帐户时遇到了问题。
下列哪一项可能是导致此问题的原因？（选择三项。）

- A.审计员使用的外部 ID 缺失或不正确。
- B.审计员使用的密码不正确。
- C.审计员尚未被授予目标帐户中该角色的 sts:AssumeRole。
- D.审计员使用的 Amazon EC2 角色必须设定为目标帐户角色。
- E.审计员使用的密钥遗失或不正确。
- F.审计员使用的角色 ARN 缺失或不正确。

▼ 解答

ACF

1. 考察的知识点

IAM角色的跨账户访问配置，包括外部ID的使用。
权限策略中对sts:AssumeRole的授权。
角色ARN的正确性及其在跨账户访问中的重要性。

2. 选项分析

- A. The external ID used by the auditor is missing or incorrect.
正确。外部ID是跨账户访问中常用的安全机制。如果外部ID缺失或不正确，审计员将无法成功假设角色。
- B. The auditor is using the incorrect password.
错误。IAM角色的假设不涉及密码，而是基于临时凭证和权限策略。
- C. The auditor has not been granted sts:AssumeRole for the role in the destination account.
正确。如果目标账户中的IAM角色未授予审计员sts:AssumeRole权限，审计员将无法假设该角色。
- D. The Amazon EC2 role used by the auditor must be set to the destination account role.
错误。EC2角色与跨账户访问无关，审计员假设角色时不需要使用EC2角色。
- E. The secret key used by the auditor is missing or incorrect.
错误。IAM角色的假设不直接依赖于访问密钥，而是基于临时凭证和权限策略。
- F. The role ARN used by the auditor is missing or incorrect.
正确。如果审计员使用的角色ARN缺失或不正确，审计员将无法定位目标角色并假设它。

▼ 69

▼ 英文

A security engineer needs to configure an Amazon S3 bucket policy to restrict access to an S3 bucket that is named DOC-EXAMPLE-BUCKET. The policy must allow access to only DOC-EXAMPLE-BUCKET from only the following endpoint: vpce-1a2b3c4d. The policy must deny all access to DOC-EXAMPLE-BUCKET if the specified endpoint is not used. Which bucket policy statement meets these requirements?

A.

```
"Statement": [  
  {  
    "Sid": "Access-to-specific-VPCE-only",  
    "Principal": "*",  
    "Action": "s3:*",  
    "Effect": "Allow",  
    "Resource": ["arn:aws:s3::DOC-EXAMPLE-BUCKET",  
                 "arn:aws:s3::DOC-EXAMPLE-BUCKET/*"],  
    "Condition": {  
      "StringNotEquals": {  
        "aws:sourceVpce": "vpce-1a2b3c4d"  
      }  
    }  
  }  
]
```

B.

```
"Statement": [  
  {  
    "Sid": "Access-to-specific-VPCE-only",  
    "Principal": "*",  
    "Action": "s3:*",  
    "Effect": "Deny",  
    "Resource": ["arn:aws:s3::DOC-EXAMPLE-BUCKET",  
                 "arn:aws:s3::DOC-EXAMPLE-BUCKET/*"],  
    "Condition": {  
      "StringNotEquals": {  
        "aws:sourceVpce": "vpce-1a2b3c4d"  
      }  
    }  
  }  
]
```

C.

```

"Statement": [
  {
    "Sid": "Access-to-specific-VPCE-only",
    "Principal": "*",
    "Action": "s3:*",
    "Effect": "Deny",
    "Resource": ["arn:aws:s3:::DOC-EXAMPLE-BUCKET",
                  "arn:aws:s3:::DOC-EXAMPLE-BUCKET/*"],
    "Condition": {
      "StringEquals": {
        "aws:sourceVpce": "vpce-1a2b3c4d"
      }
    }
  }
]

```

D.

```

"Statement": [
  {
    "Sid": "Access-to-specific-VPCE-only",
    "Principal": "*",
    "Action": "s3:*",
    "Effect": "Allow",
    "Resource": "*",
    "Condition": {
      "StringEquals": {
        "aws:sourceVpce": "vpce-1a2b3c4d"
      }
    }
  }
]

```

▼ 中文

安全工程师需要配置 Amazon S3 储存桶策略来限制对名为 DOC-EXAMPLE-BUCKET 的 S3 储存桶的存取。此策略必须仅允许从下列端点存取 DOC-EXAMPLE-BUCKET：

vpce-1a2b3c4d。如果未使用指定的端点，则政策必须拒绝 DOC-EXAMPLE-BUCKET 的所有存取。
哪个存储桶策略声明满足这些要求？

A.

```

"Statement": [
  {
    "Sid": "Access-to-specific-VPCE-only",
    "Principal": "*",
    "Action": "s3:*",
    "Effect": "Allow",
    "Resource": ["arn:aws:s3:::DOC-EXAMPLE-BUCKET",
                 "arn:aws:s3:::DOC-EXAMPLE-BUCKET/*"],
    "Condition": {
      "StringNotEquals": {
        "aws:sourceVpce": "vpce-1a2b3c4d"
      }
    }
  }
]

```

B.

```

"Statement": [
  {
    "Sid": "Access-to-specific-VPCE-only",
    "Principal": "*",
    "Action": "s3:*",
    "Effect": "Deny",
    "Resource": ["arn:aws:s3:::DOC-EXAMPLE-BUCKET",
                 "arn:aws:s3:::DOC-EXAMPLE-BUCKET/*"],
    "Condition": {
      "StringNotEquals": {
        "aws:sourceVpce": "vpce-1a2b3c4d"
      }
    }
  }
]

```

C.

```

"Statement": [
  {
    "Sid": "Access-to-specific-VPCE-only",
    "Principal": "*",
    "Action": "s3:*",
    "Effect": "Deny",
    "Resource": ["arn:aws:s3:::DOC-EXAMPLE-BUCKET",
                  "arn:aws:s3:::DOC-EXAMPLE-BUCKET/*"],
    "Condition": {
      "StringEquals": {
        "aws:sourceVpce": "vpce-1a2b3c4d"
      }
    }
  }
]

```

D.

```

"Statement": [
  {
    "Sid": "Access-to-specific-VPCE-only",
    "Principal": "*",
    "Action": "s3:*",
    "Effect": "Allow",
    "Resource": "*",
    "Condition": {
      "StringEquals": {
        "aws:sourceVpce": "vpce-1a2b3c4d"
      }
    }
  }
]

```

▼ 解答

B

1. 考察的知识点

Amazon S3 Bucket Policy的配置与使用。

如何使用条件语句（Condition）限制访问，例如基于VPC Endpoint。

IAM策略的语法和逻辑，包括允许和拒绝规则的优先级。

2. 选项分析

A: 未提供具体内容，无法分析。

B: Most Voted。此选项可能包含正确的策略语法，允许通过指定的VPC Endpoint访问，同时拒绝其他访问。

C: 未提供具体内容，无法分析。

D: 未提供具体内容，无法分析。

▼ 70

▼ 英文

A company has a group of Amazon EC2 instances in a single private subnet of a VPC with no internet gateway attached. A security engineer has installed the Amazon CloudWatch agent on all instances in that subnet to capture logs from a specific application. To ensure that the logs flow securely, the company's networking team has created VPC endpoints for CloudWatch monitoring and CloudWatch logs. The networking team has attached the endpoints to the VPC.

The application is generating logs. However, when the security engineer queries CloudWatch, the logs do not appear.

Which combination of steps should the security engineer take to troubleshoot this issue? (Choose three.)

- A. Ensure that the EC2 instance profile that is attached to the EC2 instances has permissions to create log streams and write logs.
- B. Create a metric filter on the logs so that they can be viewed in the AWS Management Console.
- C. Check the CloudWatch agent configuration file on each EC2 instance to make sure that the CloudWatch agent is collecting the proper log files.
- D. Check the VPC endpoint policies of both VPC endpoints to ensure that the EC2 instances have permissions to use them.
- E. Create a NAT gateway in the subnet so that the EC2 instances can communicate with CloudWatch.
- F. Ensure that the security groups allow all the EC2 instances to communicate with each other to aggregate logs before sending.

▼ 中文

一家公司在 VPC 的单一私人子网中拥有一组 Amazon EC2 实例，且未连接任何网路闸道。一位安全工程师在该子网中的所有执行个体上安装了 Amazon CloudWatch 代理，用于撷取特定应用程序的日志。为了确保日志安全传输，该公司的网路团队创建了用于 CloudWatch 监控和 CloudWatch 日志的 VPC 终端节点。网路团队已将这些终端节点连接到 VPC。

应用程序正在产生日志，但是，当安全工程师查询 CloudWatch 时，日志并未显示。
安全工程师应该采取哪些步骤组合来排查此问题？（选三个。）

- A. 确保附加到 EC2 执行个体的 EC2 执行个体设定档具有建立日志流和写入日志的权限
- B. 在日志上建立指标过滤器，以便可以在 AWS 管理主控台中查看它们。
- C. 检查每个 EC2 执行个体上的 CloudWatch 代理程式设定文件，以确保 CloudWatch 代理程式正在收集正确的日志档案。
- D. 检查两个 VPC 端点的 VPC 端点策略，以确保 EC2 执行个体有权使用它们。
- E. 在子网中建立 NAT 网关，以便 EC2 执行个体可以与 CloudWatch 通讯。
- F. 确保安全群组允许所有 EC2 执行个体相互通讯以在传送之前聚合日志。

▼ 解答

ACD

1. 考察的知识点
Amazon CloudWatch Logs 的配置与权限管理。

VPC Endpoint的使用与策略配置。
CloudWatch Agent的配置与日志收集。

2. 选项分析

A. Ensure that the EC2 instance profile that is attached to the EC2 instances has permissions to create log streams and write logs.

正确。EC2实例需要通过IAM角色拥有足够的权限来创建日志流并写入日志到CloudWatch Logs。如果没有正确的权限，日志无法上传。

B. Create a metric filter on the logs so that they can be viewed in the AWS Management Console.

错误。创建metric filter是用于分析日志数据的操作，与日志是否成功上传到CloudWatch无关。

C. Check the CloudWatch agent configuration file on each EC2 instance to make sure that the CloudWatch agent is collecting the proper log files.

正确。如果CloudWatch Agent配置文件中未正确指定日志路径或格式，日志将无法被收集和上传。

D. Check the VPC endpoint policies of both VPC endpoints to ensure that the EC2 instances have permissions to use them.

正确。VPC Endpoint的策略需要允许EC2实例访问CloudWatch Logs和CloudWatch Monitoring服务。如果策略配置错误，日志无法上传。

E. Create a NAT gateway in the subnet so that the EC2 instances can communicate with CloudWatch.

错误。题目中明确提到已经创建了VPC Endpoint用于与CloudWatch服务通信，因此不需要NAT网关。

F. Ensure that the security groups allow all the EC2 instances to communicate with each other to aggregate logs before sending.

错误。日志上传到CloudWatch是由每个实例独立完成的，不需要实例之间的通信。

▼ 71

▼ 英文

A company uses AWS Signer with all of the company's AWS Lambda functions. A developer recently stopped working for the company. The company wants to ensure that all the code that the developer wrote can no longer be deployed to the Lambda functions.

Which solution will meet this requirement?

A.Revoke all versions of the signing profile assigned to the developer.

B.Examine the developer's IAM roles. Remove all permissions that grant access to Signer.

C.Re-encrypt all source code with a new AWS Key Management Service (AWS KMS) key.

D.Use Amazon CodeGuru to profile all the code that the Lambda functions use.

▼ 中文

一家公司将 AWS Signer 与该公司的所有 AWS Lambda 函数一起使用。一位开发人员最近停止了该公司的工作。该公司希望确保该开发人员编写的所有程式码都不再部署到 Lambda 函数中。哪种解决方案可以满足此要求？

A.撤销指派给开发人员的签章设定档的所有版本。

B.检查开发人员的IAM角色。删除所有授予Signer存取权限的权限。

C.使用新的AWS Key Management Service(AWS KMS) 金钥重新加密所有原始程式码。

D.使用 Amazon CodeGuru 分析 Lambda 函数所使用的所有程式码。

▼ 解答

A

1. 考察的知识点

本题考察的是 AWS Signer 的使用和管理，特别是如何撤销签名配置文件以确保代码的安全性。涉及到 AWS Lambda 函数的代码签名机制，以及如何防止未经授权的代码部署。

2. 选项分析

A. Revoke all versions of the signing profile assigned to the developer.

正确：撤销签名配置文件的所有版本会使得开发人员的代码无法通过 AWS Signer 的验证，从而无法部署到 Lambda 函数。

这是直接解决问题的最佳方法，因为签名配置文件是代码签名的核心。

B. Examine the developer's IAM roles. Remove all permissions that grant access to Signer.

错误：移除 IAM 权限只会阻止开发人员访问 AWS Signer，但无法阻止已经签名的代码被部署到 Lambda 函数。

此选项无法解决问题的核心，即阻止开发人员的代码被部署。

C. Re-encrypt all source code with a new AWS Key Management Service (AWS KMS) key.

错误：重新加密源代码与代码签名无关，无法阻止开发人员的代码被部署到 Lambda 函数。

此选项与题目要求不匹配。

D. Use Amazon CodeGuru to profile all the code that the Lambda functions use.

错误：Amazon CodeGuru 是用于代码质量分析和性能优化的工具，与代码签名或阻止代码部署无关。

此选项无法解决问题的核心。

▼ 72

▼ 英文

A company plans to use AWS Key Management Service (AWS KMS) to implement an encryption strategy to protect data at rest. The company requires client-side encryption for company projects. The company is currently conducting multiple projects to test the company's use of AWS KMS. These tests have led to a sudden increase in the company's AWS resource consumption. The test projects include applications that issue multiple requests each second to KMS endpoints for encryption activities.

The company needs to develop a solution that does not throttle the company's ability to use AWS KMS. The solution must improve key usage for client-side encryption and must be cost optimized. Which solution will meet these requirements?

A. Use keyrings with the AWS Encryption SDK. Use each keyring individually or combine keyrings into a multi-keyring. Decrypt the data by using a keyring that has the primary key in the multi-keyring.

B. Use data key caching. Use the local cache that the AWS Encryption SDK provides with a caching cryptographic materials manager.

C. Use KMS key rotation. Use a local cache in the AWS Encryption SDK with a caching cryptographic materials manager.

D. Use keyrings with the AWS Encryption SDK. Use each keyring individually or combine keyrings into a multi-keyring. Use any of the wrapping keys in the multi-keyring to decrypt the data.

▼ 中文

一家公司计划使用 AWS Key Management Service (AWS KMS) 实施加密策略来保护静态资料。该公司需要为公司专案提供客户端加密。该公司目前正在进行多个专案来测试公司对 AWS KMS 的使用情况。这些测试导致公司的 AWS 资源消耗量突然增加。测试项目包含每秒向 KMS 终端节点发出多个加密活动请求的应用程式。

该公司需要开发一种不会限制公司使用 AWS KMS 能力的解决方案。此解决方案必须改善客户端加密的金钥使用情况，并且必须进行成本最佳化。

哪种解决方案能够满足这些要求？

- A. 将金钥环与 AWS 加密 SDK 结合使用。您可以单独使用每个金钥环，也可以将多个金钥环组合成多重金钥环。使用多重金钥环中具有主金钥的金钥环来解密资料。
- B. 使用资料密钥快取。使用 AWS 加密 SDK 提供的本机快取和快取加密材料管理器。
- C. 使用 KMS 金钥轮换。使用 AWS 加密 SDK 中的本机快取和快取加密材料管理器。
- D. 将金钥环与 AWS 加密 SDK 结合使用。您可以单独使用每个金钥环，也可以将多个金钥环组合成多重金钥环。使用多重金钥环中的任何包装金钥即可解密资料。

▼ 解答

B

1. 考察的知识点

本题考察的是 AWS KMS 的使用场景，特别是如何优化加密操作以避免资源消耗过高和请求被限制 (throttling)。

涉及 AWS Encryption SDK 的功能，包括数据密钥缓存和 keyrings 的使用。

2. 选项分析

A. 使用 keyrings 与 multi-keyring 解密数据：

此选项提到使用 keyrings 和 multi-keyring，但没有解决高频请求导致的资源消耗问题。虽然 keyrings 是 AWS Encryption SDK 的功能之一，但它主要用于管理多个密钥，而不是优化请求频率。因此此选项不符合题目要求。

B. 使用数据密钥缓存：

此选项提到使用 AWS Encryption SDK 提供的本地缓存与缓存加密材料管理器。数据密钥缓存可以减少对 KMS 的频繁请求，因为加密操作可以使用缓存的密钥，而不是每次都请求新的密钥。这直接解决了资源消耗和请求限制问题，同时也是成本优化的有效方法。因此此选项是正确答案。

C. 使用 KMS 密钥轮换与本地缓存：

密钥轮换是一个安全最佳实践，但它与解决高频请求问题无关。虽然提到使用本地缓存，但密钥轮换的重点是定期更换密钥以提高安全性，而不是优化请求频率。因此此选项不完全符合题目要求。

D. 使用 keyrings 与 multi-keyring 解密数据：

此选项与选项 A 类似，提到使用 keyrings 和 multi-keyring，但没有解决高频请求导致的资源消耗问题。虽然 keyrings 是 AWS Encryption SDK 的功能之一，但它主要用于管理多个密钥，而不是优化请求频率。因此此选项不符合题目要求。

▼ 73

▼ 英文

A security team is working on a solution that will use Amazon EventBridge to monitor new Amazon S3 objects. The solution will monitor for public access and for changes to any S3 bucket policy or setting that result in public access. The security team configures EventBridge to watch for specific API calls that are logged from AWS CloudTrail. EventBridge has an action to send an email notification through Amazon Simple Notification Service (Amazon SNS) to the security team

immediately with details of the API call.

Specifically, the security team wants EventBridge to watch for the s3:PutObjectAcl, s3:DeleteBucketPolicy, and s3:PutBucketPolicy API invocation logs from CloudTrail. While developing the solution in a single account, the security team discovers that the s3:PutObjectAcl API call does not invoke an EventBridge event. However, the s3:DeleteBucketPolicy API call and the s3:PutBucketPolicy API call do invoke an event.

The security team has enabled CloudTrail for AWS management events with a basic configuration in the AWS Region in which EventBridge is being tested. Verification of the EventBridge event pattern indicates that the pattern is set up correctly. The security team must implement a solution so that the s3:PutObjectAcl API call will invoke an EventBridge event. The solution must not generate false notifications.

Which solution will meet these requirements?

- A. Modify the EventBridge event pattern by selecting Amazon S3. Select All Events as the event type.
- B. Modify the EventBridge event pattern by selecting Amazon S3. Select Bucket Level Operations as the event type.
- C. Enable CloudTrail Insights to identify unusual API activity.
- D. Enable CloudTrail to monitor data events for read and write operations to S3 buckets. Most Voted.

▼ 中文

一个安全团队正在开发一个解决方案，该解决方案将使用 Amazon EventBridge 来监控新的 Amazon S3 物件。该解决方案将监控公开存取以及任何导致公开存取的 S3 储存桶策略或设定的变更。安全团队将 EventBridge 配置为监控从 AWS CloudTrail 记录的特定 API 呼叫。EventBridge 有一个操作，就是透过 Amazon Simple Notification Service (Amazon SNS) 立即向安全团队发送电子邮件通知，其中包含 API 呼叫的详细资讯。

具体来说，安全团队希望 EventBridge 监控来自 CloudTrail 的 s3:PutObjectAcl、s3:DeleteBucketPolicy 和 s3:PutBucketPolicy API 呼叫日志。在使用单一帐户开发解决方案时，安全团队发现 s3:PutObjectAcl API 呼叫不会呼叫 EventBridge 事件，但 s3:DeleteBucketPolicy API 呼叫和 s3:PutBucketPolicy API 呼叫会呼叫事件。

安全团队已在正在测试 EventBridge 的 AWS 区域中启用 CloudTrail 的 AWS 管理事件功能，并进行了基本设定。对 EventBridge 事件模式的验证表示该模式已正确设定。安全团队必须实作解决方案，以确保 s3:PutObjectAcl API 呼叫能够触发 EventBridge 事件。该解决方案不得产生错误通知。

哪种解决方案能够满足这些要求？

- A. 修改 EventBridge 事件模式，选择 Amazon S3。将事件类型设置为 All Events。
- B. 修改 EventBridge 事件模式，选择 Amazon S3。将事件类型设置为 Bucket Level Operations。
- C. 启用 CloudTrail Insights 以识别异常的 API 活动。
- D. 启用 CloudTrail 监控 S3 bucket 的数据事件，包括读写操作。

▼ 解答

D

题目分析与解答

1. 考察的知识点

Amazon EventBridge与AWS CloudTrail的集成。

CloudTrail管理事件与数据事件的区别。

如何监控S3操作并触发EventBridge事件。

2. 选项分析

A. 修改 EventBridge 事件模式，选择 Amazon S3，将事件类型设置为 All Events。

错误：虽然选择“所有事件”可能会捕获更多事件，但它会导致生成大量不相关的事件，可能会产生误报。

此外，问题明确要求避免生成错误通知，因此此选项不符合要求。

B. 修改 EventBridge 事件模式，选择 Amazon S3，将事件类型设置为 Bucket Level Operations。

错误：Bucket Level Operations仅监控与桶级别相关的操作，例如创建、删除或修改桶，而不会捕获对象级别的操作

（如s3:PutObjectAcl）。

此选项无法解决问题中提到的s3:PutObjectAcl事件未触发的问题。

C. 启用 CloudTrail Insights 以识别异常的 API 活动。

错误：CloudTrail Insights用于检测异常的API活动，例如突然的流量激增或模式变化，但它不会直接解决问题中提到的

s3:PutObjectAcl事件未触发的问题。

此选项与问题要求无关。

D. 启用 CloudTrail 监控 S3 bucket 的数据事件，包括读写操作。

正确：CloudTrail默认仅记录管理事件（例如创建或删除资源），而数据事件（例如对象级别的操作，如

s3:PutObjectAcl）需要单独启用。

启用数据事件后，s3:PutObjectAcl操作将被记录，并可以触发EventBridge事件。

此选项符合问题要求，并避免生成错误通知。

▼ 74

▼ 英文

A company uses Amazon GuardDuty. The company's security team wants all High severity findings to automatically generate a ticket in a third-party ticketing system through email integration. Which solution will meet this requirement?

A. Create a verified identity for the third-party ticketing email system in Amazon Simple Email Service (Amazon SES).

Create an Amazon EventBridge rule that includes an event pattern that matches High severity GuardDuty findings. Specify the SES identity as the target for the EventBridge rule.

B. Create an Amazon Simple Notification Service (Amazon SNS) topic. Subscribe the third-party ticketing email system to the SNS topic. Create an Amazon EventBridge rule that includes an event pattern that matches High severity GuardDuty findings. Specify the SNS topic as the target for the EventBridge rule.

C. Use the GuardDuty CreateFilter API operation to build a filter in GuardDuty to monitor for High severity findings. Export the results of the filter to an Amazon Simple Notification Service (Amazon SNS) topic. Subscribe the third-party ticketing email system to the SNS topic.

D. Use the GuardDuty CreateFilter API operation to build a filter in GuardDuty to monitor for High severity findings. Create an Amazon Simple Notification Service (Amazon SNS) topic. Subscribe the third-party ticketing email system to the SNS topic. Create an Amazon EventBridge rule that includes an event pattern that matches GuardDuty findings that are selected by the filter. Specify the SNS topic as the target for the EventBridge rule.

▼ 中文

一家公司使用 Amazon GuardDuty。该公司的安全团队希望所有高严重性发现能够通过电子邮件集成自动在第三方工单系统中生成工单。哪种解决方案可以满足此要求？

A.在 Amazon Simple Email Service (Amazon SES) 中为第三方工单电子邮件系统创建一个经过验证的身份。创建一个Amazon EventBridge 规则，其中包含一个与高严重性 GuardDuty 发现匹配的事件模式。将 SES 身份指定为EventBridge 规则的目标。

B.创建一个 Amazon Simple Notification Service (Amazon SNS) 主题。将第三方工单电子邮件系统订阅到 SNS 主题。创建一个 Amazon EventBridge 规则，其中包含一个与高严重性 GuardDuty 发现匹配的事件模式。将 SNS 主题指定为EventBridge 规则的目标。

C.使用 GuardDuty CreateFilter API 操作在 GuardDuty 中构建一个过滤器，以监控高严重性发现。将过滤器的结果导出到一个 Amazon Simple Notification Service (Amazon SNS) 主题。将第三方工单电子邮件系统订阅到 SNS 主题。

D.使用 GuardDuty CreateFilter API 操作在 GuardDuty 中构建一个过滤器，以监控高严重性发现。创建一个 Amazon Simple Notification Service (Amazon SNS) 主题。将第三方工单电子邮件系统订阅到 SNS 主题。创建一个 Amazon EventBridge 规则，其中包含一个与过滤器选择的 GuardDuty 发现匹配的事件模式。将 SNS 主题指定为 EventBridge规则的目标。

▼ 解答

B

1. 考察的知识点

Amazon GuardDuty的功能和事件处理机制。

Amazon EventBridge规则的使用和事件模式匹配。

Amazon SNS的功能及其与第三方系统的集成。

如何通过AWS服务实现自动化流程。

2. 选项分析

A. Create a verified identity for the third-party ticketing email system in Amazon Simple Email Service (Amazon SES)...

分析：虽然Amazon SES可以发送电子邮件，但它需要额外的配置来验证身份，并且不直接支持事件模式匹配。相比之下，Amazon SNS更适合与第三方系统集成。

结论：错误。

B. Create an Amazon Simple Notification Service (Amazon SNS) topic...

分析：此选项正确地使用了Amazon SNS来订阅第三方系统，并通过Amazon EventBridge规则匹配高严重性GuardDuty发现。SNS是处理通知和与外部系统集成的最佳选择。

结论：正确。

C. Use the GuardDuty CreateFilter API operation...

分析：虽然CreateFilter API可以创建过滤器，但它并不直接支持将过滤器结果导出到SNS。此选项未及如何将过滤器

与EventBridge规则集成，因此流程不完整。

结论：错误。

D. Use the GuardDuty CreateFilter API operation...

分析：此选项试图结合CreateFilter API和EventBridge规则，但CreateFilter API的使用在此场景中并非必要。直接使用EventBridge规则匹配GuardDuty事件更简单有效。

结论：错误。

3. 我选的答案

▼ 75

▼ 英文

company is using AWS Organizations to implement a multi-account strategy. The company does not have on-premises infrastructure. All workloads run on AWS. The company currently has eight member accounts. The company anticipates that it will have no more than 20 AWS accounts total at any time.

The company issues a new security policy that contains the following requirements:

- No AWS account should use a VPC within the AWS account for workloads.
- The company should use a centrally managed VPC that all AWS accounts can access to launch workloads in subnets.
- No AWS account should be able to modify another AWS account's application resources within the centrally managed VPC.
- The centrally managed VPC should reside in an existing AWS account that is named Account-A within an organization.

The company uses an AWS CloudFormation template to create a VPC that contains multiple subnets in Account-A. This template exports the subnet IDs through the CloudFormation Outputs section.

Which solution will complete the security setup to meet these requirements?

- A. Use a CloudFormation template in the member accounts to launch workloads. Configure the template to use the Fn::ImportValue function to obtain the subnet ID values.
- B. Use a transit gateway in the VPC within Account-A. Configure the member accounts to use the transit gateway to access the subnets in Account-A to launch workloads.
- C. Use AWS Resource Access Manager (AWS RAM) to share Account-A's VPC subnets with the remaining member accounts.
Configure the member accounts to use the shared subnets to launch workloads.
- D. Create a peering connection between Account-A and the remaining member accounts.
Configure the member accounts to use the subnets in Account-A through the VPC peering connection to launch workloads.

▼ 中文

一家公司正在使用AWS Organizations实施多账户策略。该公司没有本地基础设施。所有工作负载都运行在AWS上。该公司目前有八个成员账户。该公司预计任何时候最多拥有20个AWS账户。

该公司发布了一项新的安全策略，其中包含以下要求：

- 任何AWS账户都不应在其AWS账户内使用VPC来运行工作负载。
- 该公司应该使用一个集中管理的VPC，所有AWS账户都可以访问该VPC以在子网中启动工作负载。
- 任何AWS账户都不应能够修改集中管理的VPC中的其他AWS账户的应用资源。
- 集中管理的VPC应该位于组织内一个名为Account-A的现有AWS账户中。

该公司使用一个AWS CloudFormation模板在Account-A中创建一个包含多个子网的VPC。该模板通过CloudFormation Outputs部分导出子网ID。

哪种解决方案可以完成安全设置以满足这些要求？

- A. 使用成员账户中的CloudFormation模板来启动工作负载。配置模板以使用Fn::ImportValue函数获取子网ID值。
- B. 在Account-A中的VPC中使用一个transit gateway。配置成员账户使用transit gateway访问Account-A中的子网以启动工作负载。
- C. 使用AWS Resource Access Manager (AWS RAM) 将Account-A的VPC子网与剩余的成员账户共享。配置成员账户使用共享子网启动工作负载。

D.在Account-A与剩余的成员账户之间创建一个peering connection。配置成员账户通过VPC peering connection使用 Account-A中的子网来启动工作负载。

▼ 解答

C

1. 考察的知识点

AWS Organizations的多账户架构设计。

跨账户资源共享的实现方式，包括AWS Resource Access Manager (AWS RAM)、VPC Peering、Transit Gateway等。

安全性要求：确保各账户之间的资源隔离和权限控制。

2. 选项分析

A. 使用CloudFormation模板和Fn::ImportValue函数：

正确性分析：虽然可以通过CloudFormation模板导入子网ID，但这并不能实现跨账户资源共享。

Fn::ImportValue函数仅

适用于同一账户内的CloudFormation栈之间的资源共享。

错误原因：无法满足跨账户访问的需求，因此不符合题目要求。

B. 使用Transit Gateway：

正确性分析：Transit Gateway可以实现跨账户网络连接，但它主要用于网络路由和连接，而不是直接共享子网资源。

错误原因：虽然可以通过Transit Gateway连接账户，但无法直接满足“共享子网”的需求。此外，Transit Gateway的设置

复杂度较高，不适合题目中提到的简单架构需求。

C. 使用AWS Resource Access Manager (AWS RAM)：

正确性分析：AWS RAM允许跨账户共享资源，包括VPC子网。通过RAM共享的子网，成员账户可以直接使用这些子网来启动工作负载，同时保持资源隔离和权限控制。

正确原因：完全符合题目要求，包括跨账户资源共享和安全性需求。

D. 使用VPC Peering：

正确性分析：VPC Peering可以实现跨账户网络连接，但它无法直接共享子网资源。成员账户需要额外配置路由表和安

全组才能访问子网。

错误原因：设置复杂且无法直接满足“共享子网”的需求。此外，VPC Peering的点对点连接方式不适合多账户架构。

Community vote distribution

社区投票分布

C (100%)

<https://shop542998714.m.taobao.com> [https://www.goofish.com/personal?](https://www.goofish.com/personal?userId=2645260430)

[userId=2645260430](https://www.goofish.com/personal?userId=2645260430)

错误原因：设置复杂且无法直接满足“共享子网”的需求。此外，VPC Peering的点对点连接方式不适合多账户架构。

▼ 76

▼ 英文

A company's security team needs to receive a notification whenever an AWS access key has not been rotated in 90 or more days. A security engineer must develop a solution that provides these notifications automatically.

Which solution will meet these requirements with the LEAST amount of effort?

A. Deploy an AWS Config managed rule to run on a periodic basis of 24 hours. Select the access-keys-rotated managedrule, and set the maxAccessKeyAge parameter to 90 days. Create an Amazon EventBridge rule with an event pattern that matches the compliance type of NON_

COMPLIANT from AWS Config for the managed rule. Configure EventBridge to send an Amazon Simple Notification Service (Amazon SNS) notification to the security team.

B. Create a script to export a .csv file from the AWS Trusted Advisor check for IAM access key rotation. Load the script into an AWS Lambda function that will upload the .csv file to an Amazon S3 bucket. Create an Amazon Athena table query that runs when the .csv file is uploaded to the S3 bucket. Publish the results for any keys older than 90 days by using an invocation of an Amazon Simple Notification Service (Amazon SNS) notification to the security team.

C. Create a script to download the IAM credentials report on a periodic basis. Load the script into an AWS Lambda function that will run on a schedule through Amazon EventBridge. Configure the Lambda script to load the report into memory and to filter the report for records in which the key was last rotated at least 90 days ago. If any records are detected, send an Amazon Simple Notification Service (Amazon SNS) notification to the security team.

D. Create an AWS Lambda function that queries the IAM API to list all the users. Iterate through the users by using the ListAccessKeys operation. Verify that the value in the CreateDate field is not at least 90 days old. Send an Amazon Simple Notification Service (Amazon SNS) notification to the security team if the value is at least 90 days old. Create an Amazon EventBridge rule to schedule the Lambda function to run each day.

▼ 中文

公司的安全团队需要在 AWS 访问密钥未在 90 天或更长时间内进行轮换时收到通知。安全工程师必须开发一个能够自动提供这些通知的解决方案。

哪种解决方案能够以最少的工作量满足这些要求？

A.部署一个 AWS Config 托管规则以每 24 小时定期运行。选择 access-keys-rotated 托管规则，并将 maxAccessKeyAge 参数设置为 90 天。创建一个 Amazon EventBridge 规则，其事件模式与 AWS Config 的托管规则中符合类型为NON_COMPLIANT 的事件匹配。配置 EventBridge 以向安全团队发送 Amazon Simple Notification Service (Amazon SNS)通知。

B.创建一个脚本以从 AWS Trusted Advisor 检查中导出一个 .csv 文件，用于 IAM 访问密钥轮换。将脚本加载到一个AWS Lambda 函数中，该函数会将 .csv 文件上传到 Amazon S3 存储桶。创建一个 Amazon Athena 表查询，当 .csv 文件上传到 S3 存储桶时运行。使用 Amazon Simple Notification Service (Amazon SNS) 通知的调用将任何超过 90 天的密钥结果发布给安全团队。

C.创建一个脚本以定期下载 IAM 凭证报告。将脚本加载到一个 AWS Lambda 函数中，该函数将通过 Amazon EventBridge 按计划运行。配置 Lambda 脚本以将报告加载到内存中，并过滤报告中密钥最后轮换时间至少为 90 天的记录。如果检测到任何记录，则向安全团队发送 Amazon Simple Notification Service (Amazon SNS) 通知。

D.创建一个 AWS Lambda 函数以查询 IAM API 以列出所有用户。通过使用 ListAccessKeys 操作迭代用户。验证 CreateDate 字段中的值是否至少为 90 天。如果值至少为 90 天，则向安全团队发送 Amazon Simple Notification Service (Amazon SNS) 通知。创建一个 Amazon EventBridge 规则以每天调度 Lambda 函数运行。

▼ 解答

A

1. 考察的知识点

本题考察的是AWS Config的托管规则、Amazon EventBridge事件规则、Amazon SNS通知的集成使用，以及如何实现自动

化安全监控。

重点在于选择最简便、自动化程度最高的解决方案。

2. 选项分析

A. Deploy an AWS Config managed rule...

正确：AWS Config提供了托管规则access-keys-rotated，可以直接设置maxAccessKeyAge参数为90天，自动检测未轮换的访问密钥。

正确：通过Amazon EventBridge规则，可以捕获AWS Config的NON_COMPLIANT事件，并触发Amazon SNS通知。

正确：此方案完全基于AWS托管服务，自动化程度高，配置简单，符合“最少努力”的要求。

B. Create a script to export a .csv file...

错误：依赖AWS Trusted Advisor检查导出的.csv文件，增加了手动脚本开发和维护的复杂性。

错误：需要额外配置Amazon Athena查询和S3事件触发器，步骤繁琐，不符合“最少努力”的要求。

C. Create a script to download the IAM credentials report...

错误：依赖IAM凭证报告，需要开发和维护脚本，增加了复杂性。

错误：虽然可以通过Amazon EventBridge调度，但仍需手动处理报告数据，不如选项A自动化程度高。

D. Create an AWS Lambda function that queries the IAM API...

错误：需要开发Lambda函数以查询IAM API并处理数据，增加了开发和维护成本。

错误：虽然可以通过Amazon EventBridge调度，但此方案完全依赖自定义代码，不如选项A简便。

▼ 77

▼ 英文

A company maintains an open-source application that is hosted on a public GitHub repository. While creating a new commit to the repository, an engineer uploaded their AWS access key and secret access key. The engineer reported the mistake to a manager, and the manager immediately disabled the access key.

The company needs to assess the impact of the exposed access key. A security engineer must recommend a solution that requires the least possible managerial overhead.

Which solution meets these requirements?

A. Analyze an AWS Identity and Access Management (IAM) use report from AWS Trusted Advisor to see when the access key was last used.

B. Analyze Amazon CloudWatch Logs for activity by searching for the access key.

C. Analyze VPC flow logs for activity by searching for the access key.

D. Analyze a credential report in AWS Identity and Access Management (IAM) to see when the access key was last used.

▼ 中文

一家公司维护一个托管在公共 GitHub 仓库中的开源应用程序。在向仓库创建新的提交时，一名工程师上传了他们的AWS access key 和 secret access key。工程师将错误报告给了经理，经理立即禁用了该 access key。

公司需要评估暴露的 access key 的影响。一名安全工程师必须推荐一个解决方案，该解决方案需要尽可能少的管理开销。

哪个解决方案满足这些要求？

A.分析 AWS Trusted Advisor 中的 AWS Identity and Access Management (IAM) 使用报告，以查看该 access key 上次使用的时间。

B.分析 Amazon CloudWatch Logs 中的活动，通过搜索该 access key。

C.分析 VPC flow logs 中的活动，通过搜索该 access key。

D.分析 AWS Identity and Access Management (IAM) 中的凭证报告，以查看该 access key 上次使用的时间。

▼ 解答

D

1. 考察的知识点

本题考察的是AWS安全管理中的访问密钥泄露后的影响评估方法。

涉及的服务包括AWS Identity and Access Management (IAM)、AWS Trusted Advisor、Amazon CloudWatch Logs和VPC Flow Logs。

2. 选项分析

A. Analyze an AWS Identity and Access Management (IAM) use report from AWS Trusted Advisor to see when the access key was last used.

错误：AWS Trusted Advisor的IAM使用报告主要用于检查账户的安全配置和最佳实践，但它无法直接提供访问密钥的使用时间。

Trusted Advisor的功能更偏向于安全建议，而不是具体的密钥使用分析。

B. Analyze Amazon CloudWatch Logs for activity by searching for the access key.

错误：CloudWatch Logs可以记录应用程序和服务的日志，但它无法直接搜索访问密钥的使用情况。此外，CloudWatch Logs需要事先配置日志记录，且搜索访问密钥的活动可能非常复杂且不可靠。

C. Analyze VPC flow logs for activity by searching for the access key.

错误：VPC Flow Logs记录的是网络流量数据，无法直接关联到访问密钥的使用情况。

搜索访问密钥的活动不适用于VPC Flow Logs，因为它们记录的是网络层信息，而不是身份验证或访问密钥的使用。

D. Analyze a credential report in AWS Identity and Access Management (IAM) to see when the access key was last used.

正确：IAM凭证报告提供了账户中所有用户的访问密钥使用情况，包括上次使用时间。

这是评估访问密钥泄露影响的最直接和有效的方法，且不需要额外的配置或复杂的搜索。

▼ 78

▼ 英文

A company plans to create individual child accounts within an existing organization in AWS Organizations for each of its DevOps teams. AWS CloudTrail has been enabled and configured on all accounts to write audit logs to an Amazon S3 bucket in a centralized AWS account. A security engineer needs to ensure that DevOps team members are unable to modify or disable this configuration.

How can the security engineer meet these requirements?

A. Create an IAM policy that prohibits changes to the specific CloudTrail trail and apply the policy to the AWS account root user.

B. Create an S3 bucket policy in the specified destination account for the CloudTrail trail that prohibits configuration changes from the AWS account root user in the source account.

C. Create an SCP that prohibits changes to the specific CloudTrail trail and apply the SCP to the appropriate organizational unit or account in Organizations.

D. Create an IAM policy that prohibits changes to the specific CloudTrail trail and apply the policy to a new IAM group.

Have team members use individual IAM accounts that are members of the new IAM group.

▼ 中文

一家公司计划在现有的 AWS Organizations 组织中为每个 DevOps 团队创建独立的子账户。AWS CloudTrail 已在所有账户中启用并配置为将审计日志写入集中式 AWS 账户中的 Amazon S3 存储桶。安全工程师需要确保 DevOps 团队成员无法修改或禁用此配置。

安全工程师如何满足这些要求？

- A. 创建一个 IAM 策略，禁止对特定的 CloudTrail 路径进行更改，并将该策略应用于 AWS 账户的根用户。
- B. 在指定的目标账户中为 CloudTrail 路径创建一个 S3 存储桶策略，禁止源账户中的 AWS 账户根用户进行配置更改。
- C. 创建一个 SCP，禁止对特定的 CloudTrail 路径进行更改，并将 SCP 应用于 Organizations 中的适当组织单元或账户。
- D. 创建一个 IAM 策略，禁止对特定的 CloudTrail 路径进行更改，并将该策略应用于一个新的 IAM 组。让团队成员使用属于该新 IAM 组的个人 IAM 账户。

▼ 解答

C

1. 考察的知识点本题主要考察AWS Organizations中的服务控制策略（SCP）的使用，以及如何通过SCP来限制对AWS资源的修改权限。
同时涉及CloudTrail的集中化日志管理和安全性配置。
2. 选项分析
 - A. Create an IAM policy that prohibits changes to the specific CloudTrail trail and apply the policy to the AWS account root user.
错误：IAM策略无法直接限制账户根用户的权限，因为根用户拥有所有权限，IAM策略无法覆盖或限制根用户的操作。
 - B. Create an S3 bucket policy in the specified destination account for the CloudTrail trail that prohibits configuration changes from the AWS account root user in the source account.
错误：S3存储桶策略仅用于控制对存储桶的访问权限，无法直接限制CloudTrail的配置更改。此外，存储桶策略无法限制源账户的根用户对CloudTrail的操作。
 - C. Create an SCP that prohibits changes to the specific CloudTrail trail and apply the SCP to the appropriate organizational unit or account in Organizations.
正确：SCP（服务控制策略）是AWS Organizations中的一种策略，可以限制组织内账户的权限，包括根用户的权限。
通过SCP，可以禁止对CloudTrail的修改操作，从而满足题目要求。
 - D. Create an IAM policy that prohibits changes to the specific CloudTrail trail and apply the policy to a new IAM group. Have team members use individual IAM accounts that are members of the new IAM group.
错误：虽然IAM策略可以限制IAM用户的权限，但无法限制账户根用户的权限。
此外，题目要求是确保DevOps团队成员无法修改CloudTrail配置，而不是仅限制IAM用户。

▼ 79

▼ 英文

A company's policy requires that all API keys be encrypted and stored separately from source code in a centralized security account. This security account is managed by the company's security team. However, an audit revealed that an API key is stored with the source code of an

AWS Lambda function in an AWS CodeCommit repository in the DevOps account.
How should the security team securely store the API key?

- A. Create a CodeCommit repository in the security account using AWS Key Management Service (AWS KMS) for encryption.
Require the development team to migrate the Lambda source code to this repository.
- B. Store the API key in an Amazon S3 bucket in the security account using server-side encryption with Amazon S3 managed encryption keys (SSE-S3) to encrypt the key. Create a presigned URL for the S3 key, and specify the URL in a Lambda environmental variable in the AWS CloudFormation template. Update the Lambda function code to retrieve the key using the URL and call the API.
- C. Create a secret in AWS Secrets Manager in the security account to store the API key using AWS Key Management Service (AWS KMS) for encryption. Grant access to the IAM role used by the Lambda function so that the function can retrieve the key from Secrets Manager and call the API.
- D. Create an encrypted environment variable for the Lambda function to store the API key using AWS Key Management Service (AWS KMS) for encryption. Grant access to the IAM role used by the Lambda function so that the function can decrypt the key at runtime.

▼ 中文

一家公司规定所有的 API 密钥必须加密，并与源代码分开存储在一个集中化的安全账户中。该安全账户由公司的安全团队管理。然而，一次审计发现，一个 API 密钥与 AWS Lambda 函数的源代码一起存储在 DevOps 账户的 AWS CodeCommit 仓库中。
安全团队应该如何安全地存储 API 密钥？

- A.在安全账户中使用 AWS Key Management Service (AWS KMS) 创建一个 CodeCommit 仓库。要求开发团队将 Lambda源代码迁移到该仓库。
- B.将 API 密钥存储在安全账户的 Amazon S3 存储桶中，使用服务器端加密和 Amazon S3 管理的加密密钥 (SSE-S3) 对密钥进行加密。为 S3 密钥创建一个预签名 URL，并在 AWS CloudFormation 模板中的 Lambda 环境变量中指定该URL。更新 Lambda 函数代码以使用该 URL 检索密钥并调用 API。
- C.在安全账户的 AWS Secrets Manager 中创建一个密钥来存储 API 密钥，使用 AWS Key Management Service (AWS KMS)进行加密。授予 Lambda 函数使用的 IAM 角色访问权限，以便函数可以从 Secrets Manager 检索密钥并调用 API。
- D.为 Lambda 函数创建一个加密的环境变量以存储 API 密钥，使用 AWS Key Management Service (AWS KMS) 进行加密。授予 Lambda 函数使用的 IAM 角色访问权限，以便函数可以在运行时解密密钥。

▼ 解答

C

题目分析与解答

- 1. 考察的知识点
安全存储敏感信息（如API密钥）的最佳实践。
AWS Secrets Manager的使用及其与AWS Key Management Service (KMS)的集成。
IAM权限管理和Lambda函数如何安全地访问敏感信息。
- 2. 选项分析
A. 创建一个 CodeCommit 仓库并迁移代码：

错误。虽然使用AWS KMS加密CodeCommit仓库是安全的，但这并没有解决API密钥与源代码分离存储的要求。将代码迁

移到安全账户的CodeCommit仓库并不能满足“集中存储API密钥”的需求。

B. 使用S3存储API密钥并通过预签名URL访问：

错误。虽然S3支持加密和预签名URL，但这种方法增加了复杂性，并且预签名URL可能会暴露敏感信息。Secrets

Manager是更适合存储和管理API密钥的服务。

C. 使用AWS Secrets Manager存储API密钥：

正确。AWS Secrets Manager专门设计用于安全存储和管理敏感信息（如API密钥），并支持与AWS KMS集成进行加密。

通过IAM角色授予Lambda函数访问权限，可以安全地检索密钥。

D. 使用加密的环境变量存储API密钥：

错误。虽然环境变量可以加密，但它们仍然存储在Lambda函数的配置中，与源代码紧密耦合。这不符合“集中存储API密钥”的要求。

▼ 80

▼ 英文

A security engineer is asked to update an AWS CloudTrail log file prefix for an existing trail. When attempting to save the change in the CloudTrail console, the security engineer receives the following error message: "There is a problem with the bucket policy."

What will enable the security engineer to save the change?

A. Create a new trail with the updated log file prefix, and then delete the original trail. Update the existing bucket policy in the Amazon S3 console with the new log file prefix, and then update the log file prefix in the CloudTrail console.

B. Update the existing bucket policy in the Amazon S3 console to allow the security engineer's principal to perform PutBucketPolicy, and then update the log file prefix in the CloudTrail console.

C. Update the existing bucket policy in the Amazon S3 console with the new log file prefix, and then update the log file prefix in the CloudTrail console.

D. Update the existing bucket policy in the Amazon S3 console to allow the security engineer's principal to perform GetBucketPolicy, and then update the log file prefix in the CloudTrail console.

▼ 中文

一名安全工程师被要求更新现有 AWS CloudTrail 的日志文件前缀。当尝试在 CloudTrail 控制台中保存更改时，安全工程师收到以下错误消息：“存储桶策略存在问题。”

如何使安全工程师能够保存更改？

A. 创建一个具有更新日志文件前缀的新 trail，然后删除原来的 trail。在 Amazon S3 控制台中更新现有存储桶策略以包含新的日志文件前缀，然后在 CloudTrail 控制台中更新日志文件前缀。

B. 在 Amazon S3 控制台中更新现有存储桶策略，以允许安全工程师的主体执行PutBucketPolicy，然后在 CloudTrail 控制台中更新日志文件前缀。

C. 在 Amazon S3 控制台中更新现有存储桶策略以包含新的日志文件前缀，然后在 CloudTrail 控制台中更新日志文件前缀。

D. 在 Amazon S3 控制台中更新现有存储桶策略，以允许安全工程师的主体执行 GetBucketPolicy，然后在 CloudTrail 控制台中更新日志文件前缀。

▼ 解答

C

1. 考察的知识点

本题考察的是AWS CloudTrail与Amazon S3存储桶策略的交互，以及如何正确配置存储桶策略以支持CloudTrail日志存储。

涉及的知识点包括：CloudTrail日志文件前缀更新、S3存储桶策略的权限配置。

2. 选项分析

A. 创建一个具有更新日志文件前缀的新 trail，然后删除原来的 trail。在 Amazon S3 控制台中更新现有存储桶策略

以包含新的日志文件前缀，然后在 CloudTrail 控制台中更新日志文件前缀。

错误：创建新trail并删除原trail是多余的操作，更新现有trail的日志文件前缀即可，无需创建新trail。

正确部分：更新S3存储桶策略以包含新的日志文件前缀是必要的。

B. 在 Amazon S3 控制台中更新现有存储桶策略，以允许安全工程师的主体执行 PutBucketPolicy，然后在

CloudTrail 控制台中更新日志文件前缀。

错误：PutBucketPolicy权限是用于修改存储桶策略的权限，与CloudTrail日志文件前缀更新无关。

正确部分：更新存储桶策略是必要的，但不需要赋予安全工程师PutBucketPolicy权限。

C. 在 Amazon S3 控制台中更新现有存储桶策略以包含新的日志文件前缀，然后在 CloudTrail 控制台中更新日志文件前缀。

正确：这是解决问题的正确步骤。首先更新存储桶策略以允许新的日志文件前缀，然后在CloudTrail中更新前缀。

D. 在 Amazon S3 控制台中更新现有存储桶策略，以允许安全工程师的主体执行 GetBucketPolicy，然后在

CloudTrail 控制台中更新日志文件前缀。

错误：GetBucketPolicy权限是用于读取存储桶策略的权限，与CloudTrail日志文件前缀更新无关。

正确部分：更新存储桶策略是必要的，但不需要赋予安全工程师GetBucketPolicy权限。

▼ 81

▼ 英文

A company uses AWS Organizations. The company wants to implement short-term credentials for third-party AWS accounts to use to access accounts within the company's organization. Access is for the AWS Management Console and third-party software-as-a-service (SaaS) applications. Trust must be enhanced to prevent two external accounts from using the same credentials. The solution must require the least possible operational effort.

Which solution will meet these requirements?

A. Use a bearer token authentication with OAuth or SAML to manage and share a central Amazon Cognito user pool across multiple Amazon API Gateway APIs.

B. Implement AWS IAM Identity Center (AWS Single Sign-On), and use an identity source of choice. Grant access to users and groups from other accounts by using permission sets that are assigned by account.

C. Create a unique IAM role for each external account. Create a trust policy Use AWS Secrets Manager to create a random external key.

D. Create a unique IAM role for each external account. Create a trust policy that includes a condition that uses the sts:ExternalId condition key.

▼ 中文

一家公司使用 AWS Organizations。该公司希望为第三方 AWS 账户实施短期凭证，以便访问公司组织内的账户。访问包括 AWS Management Console 和第三方软件即服务 (SaaS) 应用程序。必须增强信任以防止两个外部账户使用相同的凭证。解决方案**必须要求尽可能少的操作工作量**。

哪种解决方案可以满足这些要求？

A. 使用带有 OAuth 或 SAML 的 bearer token 身份验证来管理和共享跨多个 Amazon API Gateway API 的中央 Amazon Cognito 用户池。

B. 实施 AWS IAM Identity Center (AWS Single Sign-On)，并使用所选的身份源。通过使用账户分配的权限集，为其他账户中的用户和组授予访问权限。

C. 为每个外部账户创建一个唯一的 IAM 角色。创建一个信任策略。使用 AWS Secrets Manager 创建一个随机外部密钥。

D. 为每个外部账户创建一个唯一的 IAM 角色。创建一个信任策略，其中包含使用 sts:ExternalId 条件键的条件。

▼ 解答

D

1. 考察的知识点

本题考察的是 AWS 身份与访问管理 (IAM) 中的跨账户访问机制，特别是如何使用短期凭证 (STS) 和信任策略来增强安全性。

重点知识包括：IAM 角色、信任策略、sts:ExternalId 条件键的使用，以及如何防止凭证被多个外部账户共享。

2. 选项分析

A. 使用带有 OAuth 或 SAML 的 bearer token 身份验证来管理和共享跨多个 Amazon API Gateway API 的中央 Amazon Cognito 用户池。

错误：Amazon Cognito 主要用于管理用户池和身份池，适合应用程序用户认证，而不是跨账户访问的场景。

此外，题目要求的是短期凭证，而不是长期用户池管理。

B. 实施 AWS IAM Identity Center (AWS Single Sign-On)，并使用所选的身份源。通过使用账户分配的权限集，为其他账户中的用户和组授予访问权限。

错误：AWS IAM Identity Center (AWS SSO) 适用于集中式身份管理，但题目要求的是短期凭证的解决方案，而不是长期用户组管理。

此外，AWS SSO 的设置和管理复杂度较高，不符合“最少的操作努力”要求。

C. 为每个外部账户创建一个唯一的 IAM 角色。创建一个信任策略。使用 AWS Secrets Manager 创建一个随机外部密钥。

错误：虽然创建唯一的 IAM 角色是正确的方向，但使用 AWS Secrets Manager 生成随机密钥并不符合题目要求。

题目明确要求增强信任以防止凭证共享，而 Secrets Manager 的随机密钥无法直接实现这一点。

D. 为每个外部账户创建一个唯一的 IAM 角色。创建一个信任策略，其中包含使用 sts:ExternalId 条件键的条件。

正确：使用 sts:ExternalId 条件键可以防止凭证被多个外部账户共享，从而增强信任。

创建唯一的 IAM 角色并结合信任策略是实现短期凭证的最佳实践。

此解决方案操作简单，符合“最少的操作努力”要求。

▼ 82

▼ 英文

A company is evaluating its security posture. In the past, the company has observed issues with specific hosts and host header combinations that affected the company's business. The company has configured AWS WAF web ACLs as an initial step to mitigate these issues.

The company must create a log analysis solution for the AWS WAF web ACLs to monitor problematic activity. The company wants to process all the AWS WAF logs in a central location. The company must have the ability to filter out requests based on specific hosts.

A security engineer starts to enable access logging for the AWS WAF web ACLs.

What should the security engineer do next to meet these requirements with the MOST operational efficiency?

- A. Specify Amazon Redshift as the destination for the access logs. Deploy the Amazon Athena Redshift connector. Use Athena to query the data from Amazon Redshift and to filter the logs by host.
- B. Specify Amazon CloudWatch as the destination for the access logs. Use Amazon CloudWatch Logs Insights to design a query to filter the logs by host.
- C. Specify Amazon CloudWatch as the destination for the access logs. Export the CloudWatch logs to an Amazon S3 bucket. Use Amazon Athena to query the logs and to filter the logs by host.
- D. Specify Amazon CloudWatch as the destination for the access logs. Use Amazon Redshift Spectrum to query the logs and to filter the logs by host.

▼ 中文

一家公司正在评估其安全状况。过去，该公司观察到特定主机和主机头组合的问题，这些问题影响了公司的业务。该公司已配置了AWS WAF web ACLs作为缓解这些问题的初步措施。

该公司必须为AWS WAF web ACLs创建一个日志分析解决方案，以监控有问题的活动。公司希望在一个集中位置处理所有AWS WAF日志。公司必须能够基于特定主机过滤请求。

一名安全工程师开始为AWS WAF web ACLs启用访问日志记录。

为了以最高的操作效率满足这些要求，安全工程师接下来应该做什么？

- A.指定Amazon Redshift作为访问日志的目标位置。部署Amazon Athena Redshift连接器。使用Athena从Amazon Redshift 查询数据，并按主机过滤日志。
- B.指定Amazon CloudWatch作为访问日志的目标位置。使用Amazon CloudWatch Logs Insights设计一个查询以按主机过滤日志。
- C.指定Amazon CloudWatch作为访问日志的目标位置。将CloudWatch日志导出到Amazon S3桶。使用Amazon Athena查询日志并按主机过滤日志。
- D.指定Amazon CloudWatch作为访问日志的目标位置。使用Amazon Redshift Spectrum查询日志并按主机过滤日志。

▼ 解答

B

1. 考察的知识点

本题考察AWS WAF日志分析与监控的最佳实践。

涉及AWS服务包括：Amazon CloudWatch Logs、Amazon Athena、Amazon Redshift、Amazon

S3等。

重点在于选择最具操作效率的解决方案来处理和过滤AWS WAF日志。

2. 选项分析

A. 指定Amazon Redshift作为访问日志的目标位置。部署Amazon Athena Redshift连接器。使用Athena从Amazon

Redshift查询数据，并按主机过滤日志。

错误：AWS WAF日志无法直接写入Amazon Redshift，必须通过中间步骤（如S3或CloudWatch）。

错误：使用Amazon Athena Redshift连接器增加了复杂性，降低了操作效率。

B. 指定Amazon CloudWatch作为访问日志的目标位置。使用Amazon CloudWatch Logs Insights设计一个查询以按主机

过滤日志。

正确：AWS WAF可以直接将日志写入Amazon CloudWatch Logs。

正确：CloudWatch Logs Insights是专门设计用于查询和分析日志的工具，支持高效的过滤和查询操作。

正确：此选项提供了最直接和高效的解决方案，符合题目要求的“最高操作效率”。

C. 指定Amazon CloudWatch作为访问日志的目标位置。将CloudWatch日志导出到Amazon S3桶。使用Amazon Athena

查询日志并按主机过滤日志。

错误：虽然可以通过CloudWatch导出日志到S3并使用Athena查询，但这增加了额外的步骤（导出到S3），降低了操作

效率。

错误：相比直接使用CloudWatch Logs Insights，此方法复杂且不符合“最高操作效率”的要求。

D. 指定Amazon CloudWatch作为访问日志的目标位置。使用Amazon Redshift Spectrum查询日志并按主机过滤日志。

错误：AWS WAF日志无法直接写入Amazon Redshift Spectrum，必须通过中间步骤（如S3）。

错误：使用Redshift Spectrum查询日志增加了复杂性，降低了操作效率。

▼ 83

▼ 英文

A security engineer is trying to use Amazon EC2 Image Builder to create an image of an EC2 instance. The security engineer has configured the pipeline to send logs to an Amazon S3 bucket. When the security engineer runs the pipeline, the build fails with the following error:

"AccessDenied: Access Denied status code: 403".

The security engineer must resolve the error by implementing a solution that complies with best practices for least privilege access.

Which combination of steps will meet these requirements? (Choose two.)

A. Ensure that the following policies are attached to the IAM role that the security engineer is using: EC2InstanceProfileForImageBuilder, EC2InstanceProfileForImageBuilderECRContainerBuilds, and AmazonSSMManagedInstanceCore.

B. Ensure that the following policies are attached to the instance profile for the EC2 instance: EC2InstanceProfileForImageBuilder, EC2InstanceProfileForImageBuilderECRContainerBuilds, and AmazonSSMManagedInstanceCore.

C. Ensure that the AWSImageBuilderFullAccess policy is attached to the instance profile for the EC2 instance.

D. Ensure that the security engineer's IAM role has the s3:PutObject permission for the S3 bucket.

E. Ensure that the instance profile for the EC2 instance has the s3:PutObject permission for the S3 bucket.

▼ 中文

一位安全工程师尝试使用 Amazon EC2 Image Builder 创建一个 EC2 实例的镜像。安全工程师已配置管道将日志发送到一个 Amazon S3 存储桶。当安全工程师运行管道时，构建失败并出现以下错误：

“AccessDenied: Access Denied status code: 403”。

安全工程师必须通过实施符合最小权限访问最佳实践的解决方案来解决此错误。

哪些步骤组合可以满足这些要求？（选择两个。）

- A. 确保以下策略已附加到安全工程师正在使用的 IAM 角色：EC2InstanceProfileForImageBuilder、EC2InstanceProfileForImageBuilderECRContainerBuilds 和 AmazonSSMManagedInstanceCore。
- B. 确保以下策略已附加到 EC2 实例的实例配置文件：EC2InstanceProfileForImageBuilder、EC2InstanceProfileForImageBuilderECRContainerBuilds 和 AmazonSSMManagedInstanceCore。
- C. 确保 AWSImageBuilderFullAccess 策略已附加到 EC2 实例的实例配置文件。
- D. 确保安全工程师的 IAM 角色具有针对 S3 存储桶的 s3:PutObject 权限。
- E. 确保 EC2 实例的实例配置文件具有针对 S3 存储桶的 s3:PutObject 权限。

▼ 解答

BE

1. 考察的知识点

IAM角色和策略的配置，特别是与Amazon EC2 Image Builder相关的权限。

最小权限原则（Least Privilege）的应用。

如何正确配置EC2实例的实例配置文件（Instance Profile）。

Amazon S3权限的配置，尤其是s3:PutObject权限。

2. 选项分析

A. Ensure that the following policies are attached to the IAM role that the security engineer is using:

EC2InstanceProfileForImageBuilder, EC2InstanceProfileForImageBuilderECRContainerBuilds, and

AmazonSSMManagedInstanceCore.

错误：这些策略需要附加到EC2实例的实例配置文件，而不是安全工程师的IAM角色。安全工程师的IAM角色不直接参

与EC2 Image Builder的操作。

B. Ensure that the following policies are attached to the instance profile for the EC2 instance: EC2InstanceProfileForImageBuilder, EC2InstanceProfileForImageBuilderECRContainerBuilds, and

AmazonSSMManagedInstanceCore.

正确：这些策略是EC2 Image Builder所需的基本权限，必须附加到EC2实例的实例配置文件，以便实例能够执行构建任

务。

C. Ensure that the AWSImageBuilderFullAccess policy is attached to the instance profile for the EC2 instance.

错误：AWSImageBuilderFullAccess是一个宽泛的权限策略，不符合最小权限原则。题目要求遵循最佳实践，因此不推荐

使用此策略。

D. Ensure that the security engineer's IAM role has the s3:PutObject permission for the S3 bucket.

错误：s3:PutObject权限需要赋予EC2实例的实例配置文件，而不是安全工程师的IAM角色。EC2实例负责将日志写入

S3，而不是安全工程师。

E. Ensure that the instance profile for the EC2 instance has the s3:PutObject permission for the S3 bucket.

正确：EC2实例需要s3:PutObject权限才能将日志写入指定的S3存储桶。这是解决403错误的关键步骤之一。

▼ 84

▼ 英文

A security engineer must use AWS Key Management Service (AWS KMS) to design a key management solution for a set of Amazon Elastic Block Store (Amazon EBS) volumes that contain sensitive data. The solution needs to ensure that the key material automatically expires in 90 days.

Which solution meets these criteria?

- A. A customer managed key that uses customer provided key material
- B. A customer managed key that uses AWS provided key material
- C. An AWS managed key
- D. Operating system encryption that uses GnuPG

▼ 中文

一名安全工程师必须使用 AWS Key Management Service (AWS KMS) 为一组包含敏感数据的 Amazon Elastic Block Store (Amazon EBS) 卷设计一个密钥管理解决方案。该解决方案需要确保密钥材料在 90 天后自动过期。

哪个解决方案符合这些标准？

- A. 使用客户提供的密钥材料的客户管理密钥
- B. 使用 AWS 提供的密钥材料的客户管理密钥
- C. AWS 管理密钥
- D. 使用 GnuPG 的操作系统加密

▼ 解答

A

1. 考察的知识点

本题考察的是AWS Key Management Service (KMS)的功能，特别是客户管理密钥（Customer Managed Key）和客户提供的密钥材料（Customer Provided Key Material, CPKM）的使用场景。还涉及到密钥生命周期管理，包括密钥的自动过期和安全性要求。

2. 选项分析

A. A customer managed key that uses customer provided key material

正确。客户管理密钥（Customer Managed Key）允许用户提供自己的密钥材料，并通过AWS KMS进行管理。用户可以设置密钥材料的生命周期，例如自动过期时间（90天）。这完全符合题目要求。

B. A customer managed key that uses AWS provided key material

错误。虽然客户管理密钥可以使用AWS提供的密钥材料，但AWS提供的密钥材料无法设置自动过期时间。因此不符合题目要求。

C. An AWS managed key

错误。AWS管理密钥（AWS Managed Key）是由AWS自动创建和管理的，用户无法控制密钥的生命周期或设置自动过期

时间。因此不符合题目要求。

D. Operating system encryption that uses GnuPG

错误。GnuPG是操作系统级别的加密工具，与AWS KMS无关。题目明确要求使用AWS KMS，因此此选项不符合要求。

▼ 85

▼ 英文

A security engineer is building a Java application that is running on Amazon EC2. The application communicates with an Amazon RDS instance and authenticates with a user name and password. Which combination of steps can the engineer take to protect the credentials and minimize downtime when the credentials are rotated? (Choose two.)

A. Have a database administrator encrypt the credentials and store the ciphertext in Amazon S3. Grant permission to the instance role associated with the EC2 instance to read the object and decrypt the ciphertext.

B. Configure a scheduled job that updates the credential in AWS Systems Manager Parameter Store and notifies the engineer that the application needs to be restarted.

C. Configure automatic rotation of credentials in AWS Secrets Manager.

D. Store the credential in an encrypted string parameter in AWS Systems Manager Parameter Store. Grant permission to the instance role associated with the EC2 instance to access the parameter and the AWS KMS key that is used to encrypt it.

E. Configure the Java application to catch a connection failure and make a call to AWS Secrets Manager to retrieve updated credentials when the password is rotated. Grant permission to the instance role associated with the EC2 instance to access Secrets Manager.

▼ 中文

一位安全工程师正在构建一个运行在 Amazon EC2 上的 Java 应用程序。该应用程序与 Amazon RDS 实例通信，并使用用户名和密码进行身份验证。

工程师可以采取哪些步骤来保护凭证并在凭证轮换时最大限度地减少停机时间？（选择两个。）

A. 让数据库管理员加密凭证并将密文存储在 Amazon S3 中。授予与 EC2 实例关联的实例角色读取对象和解密密文的权限

B. 配置一个计划任务，将凭证更新到 AWS Systems Manager Parameter Store，并通知工程师需要重新启动应用程序。

C. 配置 AWS Secrets Manager 中的凭证自动轮换。

D. 将凭证存储在 AWS Systems Manager Parameter Store 的加密字符串参数中。授予与 EC2 实例关联的实例角色访问该参数以及用于加密的 AWS KMS 密钥的权限。

E. 配置 Java 应用程序以捕获连接失败，并在密码轮换时调用 AWS Secrets Manager 以检索更新的凭证。授予与 EC2 实例关联的实例角色访问 Secrets Manager 的权限。

▼ 解答

CE

1. 考察的知识点如何安全地存储和管理应用程序的凭证。

如何使用 AWS 服务（如 Secrets Manager 和 Systems Manager Parameter Store）进行凭证的自动轮换和访问控制。

如何最小化凭证轮换时的应用程序停机时间。

2. 选项分析

A. 使用 S3 存储加密的凭证，但这种方法需要额外的逻辑来管理加密和解密过程，且没有自动轮换功能。

此方法复杂且不符合最佳实践。

B.

错误：虽然 AWS Systems Manager Parameter Store 可以存储加密的凭证，但此选项依赖人工通知和应用程序重启，无

法实现自动轮换和最小化停机时间。

C.

正确：AWS Secrets Manager 提供自动轮换功能，可以安全地管理和轮换数据库凭证，同时最小化应用程序停机时间。

D.

错误：虽然 AWS Systems Manager Parameter Store 支持加密存储，但它不支持自动轮换功能，因此无法满足题目要求

的“最小化停机时间”。

E.

正确：此选项结合了应用程序的动态凭证检索和 AWS Secrets Manager 的自动轮换功能，可以在密码轮换时最小化停机时间。

▼ 86

▼ 英文

A company uses SAML federation to grant users access to AWS accounts. A company workload that is in an isolated AWS account runs on immutable infrastructure with no human access to Amazon EC2. The company requires a specialized user known as a break glass user to have access to the workload AWS account and instances in the case of SAML errors. A recent audit discovered that the company did not create the break glass user for the AWS account that contains the workload.

The company must create the break glass user. The company must log any activities of the break glass user and send the logs to a security team.

Which combination of solutions will meet these requirements? (Choose two.)

A. Create a local individual break glass IAM user for the security team. Create a trail in AWS CloudTrail that has Amazon CloudWatch Logs turned on. Use Amazon EventBridge to monitor local user activities.

B. Create a break glass EC2 key pair for the AWS account. Provide the key pair to the security team. Use AWS CloudTrail to monitor key pair activity. Send notifications to the security team by using Amazon Simple Notification Service (Amazon SNS).

C. Create a break glass IAM role for the account. Allow security team members to perform the AssumeRoleWithSAML operation. Create an AWS CloudTrail trail that has Amazon CloudWatch Logs turned on. Use Amazon EventBridge to monitor security team activities.

D. Create a local individual break glass IAM user on the operating system level of each workload instance. Configure unrestricted security groups on the instances to grant access to the break glass IAM users.

E. Configure AWS Systems Manager Session Manager for Amazon EC2. Configure an AWS CloudTrail filter based on Session Manager. Send the results to an Amazon Simple Notification Service (Amazon SNS) topic.

▼ 中文

一家公司使用SAML联合认证为用户提供访问AWS账户的权限。一家公司在隔离的AWS账户中运行的工作负载使用不可变基础设施，且没有人类访问Amazon EC2的权限。公司要求一个专门的用户，称为紧急访问用户（break glass user），在发生SAML错误时能够访问工作负载的AWS账户和实例。最近的一次审计发现，公司没有为包含工作负载的AWS账户创建紧急访问用户。

公司必须创建紧急访问用户。公司必须记录紧急访问用户的所有活动，并将日志发送给安全团队。哪些解决方案的组合可以满足这些要求？（选择两项）

- A. 为安全团队创建一个本地单独的紧急访问IAM用户。在AWS CloudTrail中创建一个启用了Amazon CloudWatch Logs的跟踪。使用Amazon EventBridge监控本地用户活动。
- B. 为AWS账户创建一个紧急访问EC2密钥对。将密钥对提供给安全团队。使用AWS CloudTrail监控密钥对活动。使用Amazon Simple Notification Service (Amazon SNS)向安全团队发送通知。
- C. 为账户创建一个紧急访问IAM角色。允许安全团队成员执行AssumeRoleWithSAML操作。在AWS CloudTrail中创建一个启用了Amazon CloudWatch Logs的跟踪。使用Amazon EventBridge监控安全团队活动。
- D. 在每个工作负载实例的操作系统级别创建一个本地单独的紧急访问IAM用户。配置不受限制的安全组以授予紧急访问IAM用户访问权限。
- E. 为Amazon EC2配置AWS Systems Manager Session Manager。基于Session Manager配置AWS CloudTrail过滤器。将结果发送到一个Amazon Simple Notification Service (Amazon SNS)主题。

▼ 解答

AE

A.

正确：创建一个本地IAM用户是紧急访问的标准做法，尤其是在SAML不可用的情况下。

正确：使用AWS CloudTrail记录用户活动，并通过Amazon EventBridge监控活动是符合安全要求的。

B.

错误：使用EC2密钥对进行紧急访问不符合最佳实践，因为密钥对的管理和分发存在安全风险。

错误：虽然可以使用CloudTrail监控密钥对活动，但这种方法不够安全和灵活。

C.

错误：题目明确指出SAML可能会出现問題，因此依赖SAML的AssumeRoleWithSAML操作不符合要求。

错误：虽然CloudTrail和EventBridge可以监控活动，但此选项未解决SAML不可用的核心问题。

D.

错误：在操作系统级别创建IAM用户并配置不受限制的安全组会带来严重的安全风险。

错误：这种方法不符合AWS最佳实践，也未提到日志记录和监控。

E.

正确：使用AWS Systems Manager Session Manager可以安全地访问EC2实例，而无需直接登录或使用密钥对。

▼ 87

▼ 英文

A security engineer is working with a product team building a web application on AWS. The application uses Amazon S3 to host the static content, Amazon API Gateway to provide RESTful services, and Amazon DynamoDB as the backend data store. The users already exist in a directory that is exposed through a SAML identity provider. Which combination of the following actions should the engineer take to allow users to be authenticated into the web application and call APIs? (Choose three.)

- A. Create a custom authorization service using AWS Lambda.
- B. Configure a SAML identity provider in Amazon Cognito to map attributes to the Amazon Cognito user pool attributes.
- C. Configure the SAML identity provider to add the Amazon Cognito user pool as a relying party.
- D. Configure an Amazon Cognito identity pool to integrate with social login providers.
- E. Update DynamoDB to store the user email addresses and passwords.
- F. Update API Gateway to use a COGNITO_USER_POOLS authorizer.

▼ 中文

一位安全工程师正在与一个产品团队合作，该团队正在AWS上构建一个Web应用程序。该应用程序使用Amazon S3来托管静态内容，使用Amazon API Gateway提供RESTful服务，并使用Amazon DynamoDB作为后端数据存储。用户已经存在于一个通过SAML身份提供商公开的目录中。工程师应采取以下哪些操作组合以允许用户对Web应用程序进行身份验证并调用API？（选择三个）

- A.使用AWS Lambda创建一个自定义授权服务。
- B.在Amazon Cognito中配置一个SAML身份提供商，以将属性映射到Amazon Cognito用户池属性。
- C.配置SAML身份提供商以将Amazon Cognito用户池添加为依赖方。
- D.配置一个Amazon Cognito身份池以集成社交登录提供商。
- E.更新DynamoDB以存储用户电子邮件地址和密码。
- F.更新API Gateway以使用COGNITO_USER_POOLS授权器。

▼ 解答

BCF

1. 考察的知识点

Amazon Cognito的用户池和身份池的功能与配置。

SAML身份提供商的集成与配置。

API Gateway的授权机制，特别是COGNITO_USER_POOLS授权器的使用。

2. 选项分析

A. Create a custom authorization service using AWS Lambda.

错误：虽然AWS Lambda可以用来创建自定义授权服务，但题目中并未要求自定义授权服务。使用Amazon Cognito和SAML身份提供商已经可以满足需求，因此不需要额外创建Lambda函数。

B. Configure a SAML identity provider in Amazon Cognito to map attributes to the Amazon Cognito user pool attributes.

正确：这是实现用户认证的关键步骤之一。通过配置SAML身份提供商，用户可以通过现有的目录登录到Amazon Cognito用户池。

C. Configure the SAML identity provider to add the Amazon Cognito user pool as a relying party.

正确：将Amazon Cognito用户池配置为SAML身份提供商的依赖方，确保用户可以通过SAML身份提供商进行认证。

D. Configure an Amazon Cognito identity pool to integrate with social login providers.

错误：题目中并未提到需要集成社交登录提供商，且用户已经存在于SAML身份提供商中，因此此选项与题目需求无关。

E. Update DynamoDB to store the user email addresses and passwords.

错误：用户认证应该通过SAML身份提供商和Amazon Cognito完成，而不是直接存储用户的凭证到DynamoDB中，这不符合安全最佳实践。

F. Update API Gateway to use a COGNITO_USER_POOLS authorizer.

正确：使用COGNITO_USER_POOLS授权器可以确保API Gateway能够验证用户的身份，并允许经过认证的用户调用API。

▼ 88

▼ 英文

A company needs to improve its ability to identify and prevent IAM policies that grant public access or cross-account access to resources. The company has implemented AWS Organizations and has started using AWS Identity and Access Management

Access Analyzer to refine overly broad access to accounts in the organization.

A security engineer must automate a response in the company's organization for any newly created policies that are overly permissive. The automation must remediate external access and must notify the company's security team.

Which combination of steps should the security engineer take to meet these requirements? (Choose three.)

A. Create an AWS Step Functions state machine that checks the resource type in the finding and adds an explicit Deny statement in the trust policy for the IAM role. Configure the state machine to publish a notification to an Amazon Simple Notification Service (Amazon SNS) topic.

B. Create an AWS Batch job that forwards any resource type findings to an AWS Lambda function. Configure the Lambda function to add an explicit Deny statement in the trust policy for the IAM role. Configure the AWS Batch job to publish a notification to an Amazon Simple Notification Service (Amazon SNS) topic.

C. In Amazon EventBridge, create an event rule that matches active IAM Access Analyzer findings and invokes AWS Step Functions for resolution.

D. In Amazon CloudWatch, create a metric filter that matches active IAM Access Analyzer findings and invokes AWS Batch for resolution.

E. Create an Amazon Simple Queue Service (Amazon SQS) queue. Configure the queue to forward a notification to the security team that an external principal has been granted access to the specific IAM role and has been blocked.

F. Create an Amazon Simple Notification Service (Amazon SNS) topic for external or cross-account access notices.

Subscribe the security team's email addresses to the topic.

▼ 中文

一家公司需要提高识别和防止 IAM 策略授予公共访问或跨账户访问资源的能力。该公司已经实施了 AWS Organizations，并开始使用 AWS Identity and Access Management Access Analyzer 来优化组织中账户的过于宽泛的访问权限。

一名安全工程师必须在公司的组织中为任何新创建的过于宽松的策略自动化响应。自动化必须修复外部访问并通知公司的安全团队。

安全工程师应采取哪些步骤组合以满足这些要求？（选择三项）

A. 建一个 AWS Step Functions 状态机，该状态机检查发现中的资源类型，并在 IAM 角色的信任策略中添加显式 Deny 语句。配置状态机以向 Amazon Simple Notification Service (Amazon SNS) 主题发布通知。

B. 创建一个 AWS Batch 作业，将任何资源类型的发现转发到 AWS Lambda 函数。配置 Lambda 函数以在 IAM 角色的信任策略中添加显式 Deny 语句。配置 AWS Batch 作业以向 Amazon Simple Notification Service (Amazon SNS) 主题发布通知。

C.在 Amazon EventBridge 中创建一个事件规则，该规则匹配活动的 IAM Access Analyzer 发现并调用 AWS Step Functions 进行解决。

D.在 Amazon CloudWatch 中创建一个指标过滤器，该过滤器匹配活动的 IAM Access Analyzer 发现并调用 AWS Batch 进行解决。

E.创建一个 Amazon Simple Queue Service (Amazon SQS) 队列。配置队列以向安全团队转发通知，通知其某个外部主体已被授予对特定 IAM 角色的访问权限并已被阻止。

F.创建一个 Amazon Simple Notification Service (Amazon SNS) 主题，用于外部或跨账户访问通知。将安全团队的电子邮件地址订阅到该主题。

▼ 解答

ACF

1. 考察的知识点

使用AWS Identity and Access Management (IAM) Access Analyzer来识别和管理过于宽泛的访问权限。

自动化响应和修复IAM策略中的外部或跨账户访问权限。

使用AWS服务（如Step Functions、EventBridge、SNS）来实现通知和自动化流程。

2. 选项分析

A. 分析：正确。Step Functions可以用来自动化处理IAM Access Analyzer的发现，并通过SNS发送通知。此选项符合题目要求的自动化修复和通知功能。

B. 分析：错误。AWS Batch通常用于处理批量数据或计算任务，而不是实时响应IAM Access Analyzer的发现。此选项不适合自动化修复和通知的场景。

C.分析：正确。EventBridge可以实时捕获IAM Access Analyzer的发现，并触发Step Functions进行自动化处理。此选项符合题目要求。

D. 分析：错误。CloudWatch的Metric Filter通常用于监控日志或指标，而不是直接处理IAM Access Analyzer的发现。此外，AWS Batch不适合此场景。

E. 分析：错误。虽然SQS可以用于消息队列，但题目要求的是通知功能，SNS更适合直接通知安全团队。

误。虽然SQS可以用于消息队列，但题目要求的是通知功能，SNS更适合直接通知安全团队。

F. 分析：正确。SNS可以用来发送通知，安全团队可以通过订阅接收相关信息。此选项符合题目要求。

▼ 89

▼ 英文

A security engineer is configuring a mechanism to send an alert when three or more failed sign-in attempts to the AWS Management Console occur during a 5-minute period. The security engineer creates a trail in AWS CloudTrail to assist in this work.

Which solution will meet these requirements?

A. In CloudTrail, turn on Insights events on the trail. Configure an alarm on the insight with eventName matching ConsoleLogin and errorMessage matching "Failed authentication". Configure a threshold of 3 and a period of 5 minutes.

B. Configure CloudTrail to send events to Amazon CloudWatch Logs. Create a metric filter for the relevant log group. Create a filter pattern with eventName matching ConsoleLogin and errorMessage matching "Failed authentication". Create a CloudWatch alarm with a threshold of 3 and a period of 5 minutes.

C. Create an Amazon Athena table from the CloudTrail events. Run a query for eventName matching ConsoleLogin and for errorMessage matching "Failed authentication". Create a

notification action from the query to send an Amazon Simple Notification Service (Amazon SNS) notification when the count equals 3 within a period of 5 minutes.

D. In AWS Identity and Access Management Access Analyzer, create a new analyzer. Configure the analyzer to send an Amazon Simple Notification Service (Amazon SNS) notification when a failed sign-in event occurs 3 times for any IAM user within a period of 5 minutes.

▼ 中文

一名安全工程师正在配置一种机制，以便在 5 分钟内发生三次或更多次失败的 AWS Management Console 登录尝试时发送警报。安全工程师在 [AWS CloudTrail 中创建了一个 trail 来协助完成此工作](#)。哪种解决方案可以满足这些要求？

A.在 CloudTrail 中为 trail 开启 Insights events。为匹配 eventName 为 ConsoleLogin 和 errorMessage 为 "Failed authentication" 的 insight 配置一个 alarm。设置阈值为 3，时间周期为 5 分钟。

B.将 CloudTrail 配置为将事件发送到 Amazon CloudWatch Logs。为相关的日志组创建一个 metric filter。创建一个 filter pattern，匹配 eventName 为 ConsoleLogin 和 errorMessage 为 "Failed authentication"。创建一个 CloudWatch alarm，设置阈值为 3，时间周期为 5 分钟。

C.从 CloudTrail 事件创建一个 Amazon Athena 表。运行一个查询，匹配 eventName 为 ConsoleLogin 和 errorMessage 为 "Failed authentication"。从查询中创建一个通知操作，当计数在 5 分钟内达到 3 时发送 Amazon Simple Notification Service (Amazon SNS) 通知。

D.在 AWS Identity and Access Management Access Analyzer 中创建一个新的 analyzer。配置该 analyzer，当任何 IAM 用户在 5 分钟内发生 3 次失败的登录事件时发送 Amazon Simple Notification Service (Amazon SNS) 通知。

▼ 解答

B

题目分析与解答

1. 考察的知识点

CloudTrail的使用和配置

CloudWatch Logs与Metric Filter的集成

事件监控与告警机制的实现

2. 选项分析

A. In CloudTrail, turn on Insights events on the trail...

分析：CloudTrail Insights主要用于检测异常活动，例如API调用的激增或减少，但它不支持直接基于特定事件名称（如ConsoleLogin）和错误消息（如"Failed authentication"）进行过滤和告警。因此此选项不符合要求。

B. Configure CloudTrail to send events to Amazon CloudWatch Logs...

分析：此选项正确地描述了通过CloudTrail将事件发送到CloudWatch Logs，然后使用Metric Filter创建过滤模式（匹配eventName为ConsoleLogin和errorMessage为"Failed authentication"），并设置CloudWatch Alarm来实现告警。这是实现需求的最佳实践。

C. Create an Amazon Athena table from the CloudTrail events...

分析：虽然Athena可以查询CloudTrail事件，但它不适合实时监控和告警。Athena查询通常用于分析历史数据，而不是实时触发告警。因此此选项不符合要求。

D. In AWS Identity and Access Management Access Analyzer...

分析：IAM Access Analyzer用于分析权限和访问路径，而不是监控登录失败事件。此选项与题目要求无关，因此不正确。

▼ 90

▼ 英文

A company's security engineer is developing an incident response plan to detect suspicious activity in an AWS account for VPC hosted resources. The security engineer needs to provide visibility for as many AWS Regions as possible. Which combination of steps will meet these requirements MOST cost-effectively? (Choose two.)

- A. Turn on VPC Flow Logs for all VPCs in the account.
- B. Activate Amazon GuardDuty across all AWS Regions.
- C. Activate Amazon Detective across all AWS Regions.
- D. Create an Amazon Simple Notification Service (Amazon SNS) topic. Create an Amazon EventBridge rule that responds to findings and publishes the findings to the SNS topic.
- E. Create an AWS Lambda function. Create an Amazon EventBridge rule that invokes the Lambda function to publish findings to Amazon Simple Email Service (Amazon SES).

▼ 中文

一家公司的一名安全工程师正在制定一个事件响应计划，以检测托管在VPC中的AWS账户资源的可疑活动。安全工程师需要尽可能多地提供对AWS区域的可见性。

哪些步骤的组合能够最具成本效益地满足这些要求？（选择两个。）

- A. 为账户中的所有VPC启用VPC Flow Logs。
- B. 在所有AWS区域激活Amazon GuardDuty。
- C. 在所有AWS区域激活Amazon Detective。
- D. 创建一个Amazon Simple Notification Service (Amazon SNS)主题。创建一个Amazon EventBridge规则以响应发现，并将发现发布到SNS主题。
- E. 创建一个AWS Lambda函数。创建一个Amazon EventBridge规则以调用Lambda函数，将发现发布到Amazon Simple Email Service (Amazon SES)。

▼ 解答

BD

1. 考察的知识点

本题主要考察AWS安全服务的使用，包括Amazon GuardDuty、Amazon SNS、Amazon EventBridge等服务的功能和应用场景。

重点关注如何在多个AWS区域中实现成本效益的安全监控和事件响应。

2. 选项分析

A. Turn on VPC Flow Logs for all VPCs in the account.

VPC Flow Logs可以提供网络流量的详细信息，但它仅限于VPC级别的流量监控，无法直接检测到账户级别的威胁。

启用所有VPC的Flow Logs可能会产生较高的成本，且需要额外的工具来分析日志数据。

因此，这个选项虽然有助于监控，但不是最具成本效益的解决方案。

B. Activate Amazon GuardDuty across all AWS Regions.

Amazon GuardDuty是一种托管威胁检测服务，可以在账户级别检测恶意活动和异常行为。

它支持跨区域部署，提供全面的安全监控，且成本相对较低。

这是一个非常有效的解决方案，符合题目要求。

C. Activate Amazon Detective across all AWS Regions.

Amazon Detective用于调查和分析安全事件，但它的主要功能是事件分析，而不是实时检测。

激活Detective会增加成本，且不直接满足题目中“检测可疑活动”的要求。
因此，这个选项不符合题目要求。

D. Create an Amazon Simple Notification Service (Amazon SNS) topic. Create an Amazon EventBridge rule that responds to findings and publishes the findings to the SNS topic.

Amazon SNS可以用来发送通知，而EventBridge可以用来响应GuardDuty的发现并触发通知。
这个组合可以实现事件响应的自动化，且成本较低。
这是一个有效的解决方案，符合题目要求。

E. Create an AWS Lambda function. Create an Amazon EventBridge rule that invokes the Lambda function to publish findings to Amazon Simple Email Service (Amazon SES).

使用Lambda和SES可以实现事件通知，但相比SNS，SES的设置和管理复杂度更高。
此外，这种方法可能会增加额外的成本，不如SNS直接和高效。
因此，这个选项不是最具成本效益的解决方案。

▼ 91

▼ 英文

A company stores images for a website in an Amazon S3 bucket. The company is using Amazon CloudFront to serve the images to end users. The company recently discovered that the images are being accessed from countries where the company does not have a distribution license. Which actions should the company take to secure the images to limit their distribution? (Choose two.)

- A. Update the S3 bucket policy to restrict access to a CloudFront origin access control (OAC).
- B. Update the website DNS record to use an Amazon Route 53 geolocation record deny list of countries where the company lacks a license.
- C. Add a CloudFront geo restriction deny list of countries where the company lacks a license.
- D. Update the S3 bucket policy with a deny list of countries where the company lacks a license.
- E. Enable the Restrict Viewer Access option in CloudFront to create a deny list of countries where the company lacks a license.

▼ 中文

一家公司将网站的图片存储在一个 Amazon S3 bucket 中。该公司使用 Amazon CloudFront 向终端用户提供图片服务。最近，该公司发现图片被访问的国家中有一些是公司没有分销许可的国家。公司应该采取哪些措施来保护图片以限制其分发？（选择两个）

- A.更新 S3 bucket 策略以限制对 CloudFront origin access control (OAC) 的访问。
- B.更新网站的 DNS 记录以使用 Amazon Route 53 地理位置记录拒绝列表来限制公司没有许可的国家。
- C.添加一个 CloudFront 地理限制拒绝列表，以限制公司没有许可的国家。
- D.更新 S3 bucket 策略，添加公司没有许可的国家的拒绝列表。
- E.启用 CloudFront 的 Restrict Viewer Access 选项，以创建公司没有许可的国家的拒绝列表。

▼ 解答

AC

1. 考察的知识点

Amazon S3 Bucket Policy的使用与配置。
Amazon CloudFront的地理限制（Geo Restriction）功能。
如何结合CloudFront和S3来保护内容并限制访问。

2. 选项分析

A.

正确。使用CloudFront的Origin Access Control (OAC)可以确保只有CloudFront可以访问S3中的内容，从而防止直接访问S3资源。这是保护S3资源的最佳实践之一。

B.

错误。Route 53的地理位置记录可以基于用户位置进行流量路由，但它不能直接限制对S3或CloudFront资源的访问。此选项与题目要求不符。

C.

正确。CloudFront的Geo Restriction功能允许基于用户的地理位置限制访问。这是限制内容分发到特定国家的直接方法。

D.

错误。S3 Bucket Policy无法基于地理位置直接限制访问。地理位置限制需要通过CloudFront实现，而不是通过S3 Bucket Policy。

E.

错误。CloudFront的Restrict Viewer Access选项用于启用身份验证（如签名URL或签名Cookie），而不是地理位置限制。此选项与题目要求不符。

▼ 92

▼ 英文

A company has deployed servers on Amazon EC2 instances in a VPC. External vendors access these servers over the internet.

Recently, the company deployed a new application on EC2 instances in a new CIDR range. The company needs to make the application available to the vendors.

A security engineer verified that the associated security groups and network ACLs are allowing the required ports in the inbound direction. However, the vendors cannot connect to the application.

Which solution will provide the vendors access to the application?

A. Modify the security group that is associated with the EC2 instances to have the same outbound rules as inbound rules.

B. Modify the network ACL that is associated with the CIDR range to allow outbound traffic to ephemeral ports.

C. Modify the inbound rules on the internet gateway to allow the required ports.

D. Modify the network ACL that is associated with the CIDR range to have the same outbound rules as inbound rules.

▼ 中文

一家公司在VPC中通过Amazon EC2实例部署了服务器。外部供应商通过互联网访问这些服务器。最近，公司在新的CIDR范围内的EC2实例上部署了一款新应用。公司需要让供应商能够访问该应用。一名安全工程师验证了相关的安全组和网络ACL在入站方向上允许所需的端口。然而，供应商无法连接到该应用。

哪种解决方案可以让供应商访问该应用？

A. 修改与EC2实例关联的安全组，使其出站规则与入站规则一致。

B. 改与CIDR范围关联的网络ACL，以允许出站流量到临时端口。

C. 修改互联网网关上的入站规则以允许所需的端口。

D. 修改与CIDR范围关联的网络ACL，使其出站规则与入站规则一致。

▼ 解答

B

1. 考察的知识点

VPC网络配置，包括安全组和网络ACL的作用与区别。

网络ACL的双向规则设置（入站和出站规则）。

临时端口（Ephemeral Ports）的作用及其在出站流量中的重要性。

2. 选项分析

A. 修改与EC2实例关联的安全组，使其出站规则与入站规则一致。

分析：安全组是状态性的，出站流量会自动允许响应入站流量。因此，修改安全组的出站规则并不会解决问题。此选项错误。

B. 修改与CIDR范围关联的网络ACL，以允许出站流量到临时端口。

分析：网络ACL是无状态的，需要显式允许入站和出站流量。临时端口（通常范围为1024-65535）用于响应入站请求。如果网络ACL未允许出站流量到临时端口，外部用户无法接收到服务器的响应。此选项正确。

C. 修改互联网网关上的入站规则以允许所需的端口。

分析：互联网网关本身不具有入站规则的设置功能。流量控制由安全组和网络ACL负责。此选项错误。

D. 修改与CIDR范围关联的网络ACL，使其出站规则与入站规则一致。

分析：虽然网络ACL需要显式设置出站规则，但简单地使出站规则与入站规则一致并不能解决问题。需要明确允许出站流量到临时端口。此选项错误。

▼ 93

▼ 英文

A company uses infrastructure as code (IaC) to create AWS infrastructure. The company writes the code as AWS CloudFormation templates to deploy the infrastructure. The company has an existing CI/CD pipeline that the company can use to deploy these templates.

After a recent security audit, the company decides to adopt a policy-as-code approach to improve the company's security posture on AWS. The company must prevent the deployment of any infrastructure that would violate a security policy, such as an unencrypted Amazon Elastic Block Store (Amazon EBS) volume.

Which solution will meet these requirements?

A. Turn on AWS Trusted Advisor. Configure security notifications as webhooks in the preferences section of the CI/CD pipeline.

B. Turn on AWS Config. Use the prebuilt rules or customized rules. Subscribe the CI/CD pipeline to an Amazon Simple Notification Service (Amazon SNS) topic that receives notifications from AWS Config.

C. Create rule sets in AWS CloudFormation Guard. Run validation checks for CloudFormation templates as a phase of the CI/CD process.

D. Create rule sets as SCPs. Integrate the SCPs as a part of validation control in a phase of the CI/CD process.

▼ 中文

一家公司使用基础设施即代码（IaC）来创建AWS基础设施。该公司将代码编写为AWS CloudFormation模板以部署基础设施。该公司拥有一个现有的CI/CD管道，可以用于部署这些模板。

在最近的一次安全审计之后，该公司决定采用代码化策略（policy-as-code）的方法，以改善公司在AWS上的安全态势。公司必须阻止任何违反安全策略的基础设施部署，例如未加密的Amazon Elastic Block Store（Amazon EBS）卷。

哪种解决方案可以满足这些要求？

A. 启用AWS Trusted Advisor。在CI/CD管道的偏好设置部分，将安全通知配置为webhooks。

B.启用AWS Config。使用预构建规则或自定义规则。订阅接收来自AWS Config通知的Amazon Simple Notification Service (Amazon SNS) 主题到CI/CD管道。

C.在AWS CloudFormation Guard中创建规则集。在CI/CD流程的一个阶段运行CloudFormation模板的验证检查。

D.将规则集创建为SCPs。在CI/CD流程的一个阶段将SCPs集成为验证控制的一部分。

▼ 解答

C

1. 考察的知识点

本题考察的是AWS的“Policy-as-Code”方法，用于在CI/CD流程中验证基础设施代码是否符合安全策略。

涉及的服务包括AWS CloudFormation Guard、AWS Config、AWS Trusted Advisor和服务控制策略 (SCPs)。

2. 选项分析

A. Turn on AWS Trusted Advisor. Configure security notifications as webhooks in the preferences section of the CI/CD pipeline.

错误：AWS Trusted Advisor主要用于提供账户级别的建议和优化，并不直接支持“Policy-as-Code”功能，也无法在CI/CD流程中验证CloudFormation模板的安全性。

B. Turn on AWS Config. Use the prebuilt rules or customized rules. Subscribe the CI/CD pipeline to an Amazon Simple Notification Service (Amazon SNS) topic that receives notifications from AWS Config.

错误：虽然AWS Config可以监控资源是否符合预定义规则，但它是针对运行时资源的合规性检查，而不是在CI/CD流程中对CloudFormation模板进行验证。

C. Create rule sets in AWS CloudFormation Guard. Run validation checks for CloudFormation templates as a phase of the CI/CD process.

正确：AWS CloudFormation Guard是专门设计用于“Policy-as-Code”的工具，可以在CI/CD流程中验证CloudFormation模板是否符合安全策略。

D. Create rule sets as SCPs. Integrate the SCPs as a part of validation control in a phase of the CI/CD process.

错误：SCPs (Service Control Policies) 用于管理组织中的账户权限，无法直接用于验证CloudFormation模板的安全性。

▼ 94

▼ 英文

A company is running an Amazon RDS for MySQL DB instance in a VPC. The VPC must not send or receive network traffic through the internet.

A security engineer wants to use AWS Secrets Manager to rotate the DB instance credentials automatically. Because of a security policy, the security engineer cannot use the standard AWS Lambda function that Secrets Manager provides to rotate the credentials.

The security engineer deploys a custom Lambda function in the VPC. The custom Lambda function will be responsible for rotating the secret in Secrets Manager. The security engineer edits the DB instance's security group to allow connections from this function. When the function is invoked, the function cannot communicate with Secrets Manager to rotate the secret properly.

What should the security engineer do so that the function can rotate the secret?

- A. Add an egress-only internet gateway to the VPC. Allow only the Lambda function's subnet to route traffic through the egress-only internet gateway.
- B. Add a NAT gateway to the VPC. Configure only the Lambda function's subnet with a default route through the NAT gateway.
- C. Configure a VPC peering connection to the default VPC for Secrets Manager. Configure the Lambda function's subnet to use the peering connection for routes.
- D. Configure a Secrets Manager interface VPC endpoint. Include the Lambda function's private subnet during the configuration process.

▼ 中文

一家公司在 VPC 中运行一个 Amazon RDS for MySQL 数据库实例。该 VPC 不得通过互联网发送或接收网络流量。

一名安全工程师希望使用 AWS Secrets Manager 自动轮换数据库实例的凭证。由于安全策略的限制，该安全工程师无法使用 Secrets Manager 提供的标准 AWS Lambda 函数来轮换凭证。

安全工程师在 VPC 中部署了一个自定义 Lambda 函数。该自定义 Lambda 函数将负责轮换 Secrets Manager 中的密钥。

安全工程师编辑了数据库实例的安全组以允许来自该函数的连接。当函数被调用时，该函数无法与 Secrets Manager 通信以正确轮换密钥。安全工程师应该怎么做才能让函数轮换密钥？

- A. 为 VPC 添加一个仅出口的互联网网关。仅允许 Lambda 函数的子网通过该仅出口的互联网网关路由流量。
- B. 为 VPC 添加一个 NAT 网关。仅为 Lambda 函数的子网配置一个通过 NAT 网关的默认路由。
- C. 配置一个到 Secrets Manager 默认 VPC 的 VPC 对等连接。配置 Lambda 函数的子网使用该对等连接进行路由。
- D. 配置一个 Secrets Manager 接口 VPC 终端节点。在配置过程中包含 Lambda 函数的私有子网。

▼ 解答

D

1. 考察的知识点

VPC网络配置与流量管理

AWS Secrets Manager的接口端点使用

Lambda函数与VPC内资源的通信

2. 选项分析

A. Add an egress-only internet gateway to the VPC. Allow only the Lambda function's subnet to route traffic through the egress-only internet gateway.

错误：Egress-only internet gateway仅适用于IPv6流量，而题目未提到使用IPv6。即使使用IPv6，这种方法仍然会将流量发送到互联网，违反了题目中“VPC必须不通过互联网发送或接收流量”的要求。

B. Add a NAT gateway to the VPC. Configure only the Lambda function's subnet with a default route through the NAT gateway.

错误：虽然NAT网关可以让私有子网访问公共AWS服务，但它需要通过互联网访问AWS服务，这同样违反了题目中“VPC必须不通过互联网发送或接收流量”的要求。

C. Configure a VPC peering connection to the default VPC for Secrets Manager. Configure the Lambda function's subnet to use

the peering connection for routes.

错误：AWS Secrets Manager是一个托管服务，默认情况下不运行在用户的VPC中，因此无法通过VPC对等连接直接访问

Secrets Manager。

D. Configure a Secrets Manager interface VPC endpoint. Include the Lambda function's private subnet during the configuration process.

正确：通过配置Secrets Manager的接口VPC端点，Lambda函数可以在VPC内直接与Secrets Manager通信，而无需通过互

联网。这符合题目中“VPC必须不通过互联网发送或接收流量”的要求。

▼ 95

▼ 英文

The security engineer is managing a traditional three-tier web application that is running on Amazon EC2 instances. The application has become the target of increasing numbers of malicious attacks from the internet.

What steps should the security engineer take to check for known vulnerabilities and limit the attack surface? (Choose two.)

- A. Use AWS Certificate Manager to encrypt all traffic between the client and application servers.
- B. Review the application security groups to ensure that only the necessary ports are open.
- C. Use Elastic Load Balancing to offload Secure Sockets Layer encryption.
- D. Use Amazon Inspector to periodically scan the backend instances.
- E. Use AWS Key Management Service (AWS KMS) to encrypt all the traffic between the client and application servers.

▼ 中文

安全工程师正在管理一个运行在 Amazon EC2 实例上的传统三层 Web 应用程序。该应用程序已成为来自互联网的越来越多恶意攻击的目标。

安全工程师应该采取哪些步骤来检查已知漏洞并限制攻击面？（选择两个。）

- A.使用 AWS Certificate Manager 加密客户端与应用服务器之间的所有流量。
- B.审查应用程序的安全组以确保仅开放必要的端口。
- C.使用 Elastic Load Balancing 卸载安全套接字层加密。
- D.使用 Amazon Inspector 定期扫描后端实例。
- E.使用 AWS Key Management Service (AWS KMS) 加密客户端与应用服务器之间的所有流量。

▼ 解答

BD

1. 考察的知识点

如何使用AWS服务检查已知漏洞（如Amazon Inspector）。

如何通过安全组配置限制攻击面。

理解AWS服务的功能和适用场景（如AWS Certificate Manager、Elastic Load Balancing、AWS KMS）。

2. 选项分析

A. Use AWS Certificate Manager to encrypt all traffic between the client and application servers.

错误：AWS Certificate Manager主要用于管理SSL/TLS证书，但它本身并不直接检查漏洞或限制攻

击面。

加密流量虽然是安全的最佳实践，但与题目要求的“检查漏洞”和“限制攻击面”无直接关系。

B. Review the application security groups to ensure that only the necessary ports are open.

正确：安全组是AWS中限制网络访问的主要工具，审查并关闭不必要的端口可以有效减少攻击面。

C. Use Elastic Load Balancing to offload Secure Sockets Layer encryption.

错误：Elastic Load Balancing可以卸载SSL加密，但这与检查漏洞或限制攻击面无直接关系。

此选项与题目要求不匹配。

D. Use Amazon Inspector to periodically scan the backend instances.

正确：Amazon Inspector是一种自动化的安全评估服务，可以扫描实例以发现已知漏洞。

这直接符合题目要求的“检查漏洞”。

E. Use AWS Key Management Service (AWS KMS) to encrypt all the traffic between the client and application servers.

错误：AWS KMS主要用于管理加密密钥，而不是直接用于加密网络流量。

此选项与题目要求的“检查漏洞”和“限制攻击面”无直接关系。

▼ 96

▼ 英文

A company is using Amazon Elastic Container Service (Amazon ECS) to run its container-based application on AWS. The company needs to ensure that the container images contain no severe vulnerabilities. The company also must ensure that only specific IAM roles and specific AWS accounts can access the container images.

Which solution will meet these requirements with the LEAST management overhead?

A. Pull images from the public container registry. Publish the images to Amazon Elastic Container Registry (Amazon ECR) repositories with scan on push configured in a centralized AWS account. Use a CI/CD pipeline to deploy the images to different AWS accounts. Use identity-based policies to restrict access to which IAM principals can access the images.

B. Pull images from the public container registry. Publish the images to a private container registry that is hosted on Amazon EC2 instances in a centralized AWS account. Deploy host-based container scanning tools to EC2 instances that run Amazon ECS. Restrict access to the container images by using basic authentication over HTTPS.

C. Pull images from the public container registry. Publish the images to Amazon Elastic Container Registry (Amazon ECR) repositories with scan on push configured in a centralized AWS account. Use a CI/CD pipeline to deploy the images to different AWS accounts. Use repository policies and identity-based policies to restrict access to which IAM principals and accounts can access the images.

D. Pull images from the public container registry. Publish the images to AWS CodeArtifact repositories in a centralized AWS account. Use a CI/CD pipeline to deploy the images to different AWS accounts. Use repository policies and identity-based policies to restrict access to which IAM principals and accounts can access the images.

▼ 中文

一家公司正在使用 Amazon Elastic Container Service (Amazon ECS) 在 AWS 上运行其基于容器的应用程序。该公司需要确保容器镜像不包含严重漏洞。公司还必须确保只有特定的 IAM 角色和特定的 AWS 账户可以访问容器镜像。

哪种解决方案能够以最少的管理开销满足这些要求？

A. 从公共容器注册表中拉取镜像。将镜像发布到配置了推送时扫描的 Amazon Elastic Container Registry (Amazon ECR) 存储库中，这些存储库位于一个集中式 AWS 账户中。使用 CI/CD 管道将镜像部署到不同的 AWS 账户。使用基于身份的策略限制哪些 IAM 主体可以访问镜像。

B.从公共容器注册表中拉取镜像。将镜像发布到托管在集中式 AWS 账户中的 Amazon EC2 实例上的私有容器注册表中。在运行 Amazon ECS 的 EC2 实例上部署基于主机的容器扫描工具。通过 HTTPS 上的基本身份验证限制对容器镜像的访问。

C.从公共容器注册表中拉取镜像。将镜像发布到配置了推送时扫描的 Amazon Elastic Container Registry (Amazon ECR) 存储库中，这些存储库位于一个集中式 AWS 账户中。使用 CI/CD 管道将镜像部署到不同的 AWS 账户。使用存储库策略和基于身份的策略限制哪些 IAM 主体和账户可以访问镜像。

D.从公共容器注册表中拉取镜像。将镜像发布到集中式 AWS 账户中的 AWS CodeArtifact 存储库中。使用 CI/CD 管道将镜像部署到不同的 AWS 账户。使用存储库策略和基于身份的策略限制哪些 IAM 主体和账户可以访问镜像。

▼ 解答

C

1. 考察的知识点

Amazon Elastic Container Registry (Amazon ECR) 的功能，包括推送时扫描 (scan on push)。如何使用 IAM 策略和存储库策略来限制对资源的访问。跨账户资源共享和 CI/CD 管道的使用。

2. 选项分析

A. Pull images from the public container registry. Publish the images to Amazon Elastic Container Registry (Amazon ECR) repositories with scan on push configured in a centralized AWS account. Use a CI/CD pipeline to deploy the images to different AWS accounts. Use identity-based policies to restrict access to which IAM principals can access the images.

正确性：此选项使用了 Amazon ECR 的推送时扫描功能，可以检测容器镜像中的漏洞，符合需求。

问题：仅使用基于身份的策略限制 IAM 主体的访问，而没有提到存储库策略，无法完全满足“限制特定账户访问”的需求。

结论：部分正确，但不是最佳答案。

B. Pull images from the public container registry. Publish the images to a private container registry that is hosted on Amazon EC2 instances in a centralized AWS account. Deploy host-based container scanning tools to EC2 instances that run Amazon ECS. Restrict access to the container images by using basic authentication over HTTPS.

正确性：此选项使用了私有容器注册表和主机级扫描工具，但管理复杂性较高。

问题：需要手动管理 EC2 实例和扫描工具，增加了管理开销；使用基本身份验证而非 IAM 策略，安全性较低。

结论：不符合“最少管理开销”的要求。

C. Pull images from the public container registry. Publish the images to Amazon Elastic Container Registry (Amazon ECR) repositories with scan on push configured in a centralized AWS account. Use a CI/CD pipeline to deploy the images to different AWS accounts. Use repository policies and identity-based policies to restrict access to which IAM principals and accounts can access the images.

正确性：此选项使用了 Amazon ECR 的推送时扫描功能，可以检测容器镜像中的漏洞，符合需求。

优势：结合了存储库策略和基于身份的策略，可以精确限制 IAM 主体和账户的访问权限，满足所有要求。

结论：最佳答案。

D. Pull images from the public container registry. Publish the images to AWS CodeArtifact repositories in a centralized AWS

account. Use a CI/CD pipeline to deploy the images to different AWS accounts. Use repository policies and identity-based policies to restrict access to which IAM principals and accounts can access the images.
正确性：AWS CodeArtifact 是一个软件包管理服务，不适合存储容器镜像。

▼ 97

▼ 英文

A company's data scientists want to create artificial intelligence and machine learning (AI/ML) training models by using Amazon SageMaker. The training models will use large datasets in an Amazon S3 bucket. The datasets contain sensitive information.

On average, the data scientists need 30 days to train models. The S3 bucket has been secured appropriately. The company's data retention policy states that all data that is older than 45 days must be removed from the S3 bucket.

Which action should a security engineer take to enforce this data retention policy?

- A. Configure an S3 Lifecycle rule on the S3 bucket to delete objects after 45 days.
- B. Create an AWS Lambda function to check the last-modified date of the S3 objects and delete objects that are older than 45 days. Create an S3 event notification to invoke the Lambda function for each PutObject operation.
- C. Create an AWS Lambda function to check the last-modified date of the S3 objects and delete objects that are older than 45 days. Create an Amazon EventBridge rule to invoke the Lambda function each month.
- D. Configure S3 Intelligent-Tiering on the S3 bucket to automatically transition objects to another storage class.

▼ 中文

一家公司的数据科学家希望使用 Amazon SageMaker 创建人工智能和机器学习 (AI/ML) 训练模型。训练模型将使用 Amazon S3 存储桶中的大型数据集。这些数据集包含敏感信息。

平均而言，数据科学家需要 30 天来训练模型。S3 存储桶已被适当保护。公司的数据保留政策规定，所有超过 45 天的数据必须从 S3 存储桶中删除。

安全工程师应该采取什么措施来执行此数据保留政策？

- A. 在 S3 存储桶上配置一个 S3 Lifecycle 规则，以在 45 天后删除对象。
- B. 创建一个 AWS Lambda 函数来检查 S3 对象的最后修改日期，并删除超过 45 天的对象。创建一个 S3 事件通知以在每次 PutObject 操作时调用 Lambda 函数。
- C. 创建一个 AWS Lambda 函数来检查 S3 对象的最后修改日期，并删除超过 45 天的对象。创建一个 Amazon EventBridge 规则以每月调用 Lambda 函数。
- D. 在 S3 存储桶上配置 S3 Intelligent-Tiering，以自动将对象转换到另一个存储类别。

▼ 解答

A

1. 考察的知识点

Amazon S3 数据生命周期管理

数据保留策略的实施

如何使用 AWS 服务自动化数据管理任务

2. 选项分析

A. Configure an S3 Lifecycle rule on the S3 bucket to delete objects after 45 days.

正确：S3 Lifecycle 规则是专门设计用于管理对象的生命周期，包括自动删除过期数据。它是实现数

据保留策略的最佳实践。

高效：无需额外的计算资源或复杂的配置。

B. Create an AWS Lambda function to check the last-modified date of the S3 objects and delete objects that are older than 45

days. Create an S3 event notification to invoke the Lambda function for each PutObject operation.

错误：虽然可以通过 Lambda 函数实现类似功能，但这种方法复杂且不必要。S3 Lifecycle 规则已经提供了内置的解决

方案。

额外开销：需要编写代码、维护 Lambda 函数，并处理事件通知。

C. Create an AWS Lambda function to check the last-modified date of the S3 objects and delete objects that are older than 45

days. Create an Amazon EventBridge rule to invoke the Lambda function each month.

错误：与选项 B 类似，这种方法复杂且不必要。S3 Lifecycle 规则已经可以自动处理数据删除。

额外开销：需要编写代码、维护 Lambda 函数，并配置 EventBridge 规则。

D. Configure S3 Intelligent-Tiering on the S3 bucket to automatically transition objects to another storage class.

错误：S3 Intelligent-Tiering 是用于优化存储成本的解决方案，而不是用于删除过期数据。

不符合要求：题目明确要求删除超过 45 天的数据，而不是转移到其他存储类别。

▼ 98

▼ 英文

A security engineer is troubleshooting an AWS Lambda function that is named MyLambdaFunction. The function is encountering an error when the function attempts to read the objects in an Amazon S3 bucket that is named DOC-EXAMPLEBUCKET. The S3 bucket has the following bucket policy:

```
{
  "Effect": "Allow",
  "Principal": {
    "Service": "lambda.amazonaws.com"
  },
  "Action": "s3:GetObject",
  "Resource": "arn:aws:s3:::DOC-EXAMPLE-BUCKET",
  "Condition": {
    "ArnLike": {
      "aws:SourceArn": "arn:aws:lambda::function:MyLambdaFunction"
    }
  }
}
```

Which change should the security engineer make to the policy to ensure that the Lambda function can read the bucket objects?

A. Remove the Condition element. Change the Principal element to the following:

```
{
  "AWS": "arn:aws:lambda::function:MyLambdaFunction"
}
```

B. Change the Action element to the following:

```
[
    "s3:GetObject*",
    "s3:GetBucket*"
]
```

C. Change the Resource element to "arn:aws:s3::DOC-EXAMPLE-BUCKET/".

将 Resource 元素更改为 "arn:aws:s3::DOC-EXAMPLE-BUCKET/"。

D. Change the Resource element to "arn:aws:lambda::function:MyLambdaFunction". Change the Principal element to the following:

```
{
    "Service": "s3.amazonaws.com"
}
```

▼ 中文

一名安全工程师正在排查一个名为 MyLambdaFunction 的 AWS Lambda 函数的问题。当该函数尝试读取名为 DOCEXAMPLE-BUCKET 的 Amazon S3 存储桶中的对象时，函数遇到了错误。该 S3 存储桶具有以下存储桶策略：

```
{
    "Effect": "Allow",
    "Principal": {
        "Service": "lambda.amazonaws.com"
    },
    "Action": "s3:GetObject",
    "Resource": "arn:aws:s3::DOC-EXAMPLE-BUCKET",
    "Condition": {
        "ArnLike": {
            "aws:SourceArn": "arn:aws:lambda::function:MyLambdaFunction"
        }
    }
}
```

安全工程师应对策略进行哪些更改，以确保 Lambda 函数能够读取存储桶对象？

A. 移除 Condition 元素。将 Principal 元素更改为以下内容：

```
{
    "AWS": "arn:aws:lambda::function:MyLambdaFunction"
}
```

B. 将 Action 元素更改为以下内容：

```
[
    "s3:GetObject*",
    "s3:GetBucket*"
]
```

C. 将 Resource 元素更改为 "arn:aws:s3::DOC-EXAMPLE-BUCKET/*"。

D. 将 Resource 元素更改为 "arn:aws:lambda::function:MyLambdaFunction"。将 Principal 元素更改为以下内容：

```
{
  "Service": "s3.amazonaws.com"
}
```

▼ 解答

C

1. 考察的知识点

本题考察的是AWS IAM策略的配置，特别是S3 Bucket Policy的正确设置，以及如何确保AWS Lambda函数能够访问S3资源。

涉及的知识点包括：Principal、Action、Resource、Condition元素的使用，以及S3 ARN格式的正确性。

2. 选项分析

A. Remove the Condition element. Change the Principal element to the following:

移除Condition元素会导致策略失去对特定Lambda函数的限制，变得过于宽松，可能允许其他Lambda函数访问该S3 Bucket。

更改Principal元素可能会破坏当前策略的正确性，因为当前Principal已经正确指定了Lambda服务。此选项不解决问题，且可能引入安全风险，因此错误。

B. Change the Action element to the following:

Action元素当前已经正确设置为"s3:GetObject"，这是Lambda函数读取S3对象所需的权限。

更改Action元素没有意义，因为问题不在于Action的配置，因此此选项错误。

C. Change the Resource element to "arn:aws:s3::DOC-EXAMPLE-BUCKET/*".

当前Resource元素仅指定了Bucket本身，而未包含Bucket中的对象（即未包含/后缀）。

Lambda函数需要访问Bucket中的对象，因此Resource需要指定为"arn:aws:s3::DOC-EXAMPLE-BUCKET/"。*

此选项正确，因为它解决了问题并符合最佳实践。

D. Change the Resource element to "arn:aws:lambda::function:MyLambdaFunction". Change the Principal element to the following:

following:

将Resource更改为Lambda函数的ARN是错误的，因为Resource应该指定S3 Bucket及其对象，而不是Lambda函数。

更改Principal元素也没有意义，因为当前Principal已经正确指定了Lambda服务。

此选项完全错误。

▼ 99

▼ 英文

An IAM user receives an Access Denied message when the user attempts to access objects in an Amazon S3 bucket. The user and the S3 bucket are in the same AWS account. The S3 bucket is configured to use server-side encryption with AWS KMS keys (SSE-KMS) to encrypt all of its objects at rest by using a customer managed key from the same AWS account. The S3 bucket has no bucket policy defined. The IAM user has been granted permissions through an IAM policy that allows the kms:Decrypt permission to the customer managed key. The IAM policy also allows the s3:List* and s3:Get* permissions for the S3 bucket and its objects.

Which of the following is a possible reason that the IAM user cannot access the objects in the S3 bucket?

A. The IAM policy needs to allow the kms:DescribeKey permission.

B. The S3 bucket has been changed to use the AWS managed key to encrypt objects at rest.

- C. An S3 bucket policy needs to be added to allow the IAM user to access the objects.
- D. The KMS key policy has been edited to remove the ability for the AWS account to have full access to the key.

▼ 中文

IAM 用户尝试访问 Amazon S3 存储桶中的对象时收到“Access Denied”消息。该用户和 S3 存储桶位于同一个 AWS 账户中。S3 存储桶配置为使用 AWS KMS 密钥 (SSE-KMS) 通过同一 AWS 账户的客户管理密钥对其所有静态对象进行服务器端加密。S3 存储桶没有定义存储桶策略。IAM 用户已通过 IAM 策略授予权限，该策略允许对客户管理密钥的 kms:Decrypt 权限。IAM 策略还允许对 S3 存储桶及其对象的 s3:List* 和 s3:Get* 权限。

以下哪项可能是 IAM 用户无法访问 S3 存储桶中的对象的原因？

- A. IAM 策略需要允许 kms:DescribeKey 权限。
- B. S3 存储桶已更改为使用 AWS 管理密钥对静态对象进行加密。
- C. 需要添加一个 S3 存储桶策略以允许 IAM 用户访问对象。
- D. KMS 密钥策略已被编辑，移除了 AWS 账户对密钥的完全访问权限。

▼ 解答

D

1. 考察的知识点

IAM 权限管理，包括 IAM 策略和 KMS 密钥策略的交互。

Amazon S3 的访问控制机制，包括 SSE-KMS 加密和权限验证。

如何排查“Access Denied”错误的原因。

2. 选项分析

A. The IAM policy needs to allow the kms:DescribeKey permission.

错误：kms:DescribeKey 权限用于查看密钥的元数据，但与解密操作无关。用户已经拥有 kms:Decrypt 权限，这足以解密对象。

B. The S3 bucket has been changed to use the AWS managed key to encrypt objects at rest.

错误：题目明确说明 S3 存储桶使用的是客户管理密钥（Customer Managed Key），而不是 AWS 管理密钥（AWS Managed Key）。此选项与题目描述不符。

C. An S3 bucket policy needs to be added to allow the IAM user to access the objects.

错误：题目明确说明 S3 存储桶没有定义存储桶策略，但 IAM 用户已经通过 IAM 策略获得了 s3:List 和 s3:Get 权限，因此不需要额外的存储桶策略。

D. The KMS key policy has been edited to remove the ability for the AWS account to have full access to the key.

正确：KMS 密钥策略是控制密钥访问的核心机制。如果密钥策略被编辑并移除了 AWS 账户对密钥的完全访问权限，即使 IAM 策略允许 kms:Decrypt 权限，用户仍然无法解密对象。

▼ 100

▼ 英文

A company has a guideline that mandates the encryption of all Amazon S3 bucket data in transit. A security engineer must implement an S3 bucket policy that denies any S3 operations if data is not encrypted.

Which S3 bucket policy will meet this requirement?

A.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "AllowSSLRequestsOnly",
    "Action": "s3:*",
    "Effect": "Deny",
    "Resource": [
      "arn:aws:s3::DOC-EXAMPLE-BUCKET",
      "arn:aws:s3::DOC-EXAMPLE-BUCKET/*"
    ],
    "Condition": {
      "Bool": {
        "aws:SecureTransport": "true"
      }
    },
    "Principal": "*"
  }]
}
```

B.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "AllowSSLRequestsOnly",
    "Action": "s3:*",
    "Effect": "Deny",
    "Resource": [
      "arn:aws:s3::DOC-EXAMPLE-BUCKET",
      "arn:aws:s3::DOC-EXAMPLE-BUCKET/*"
    ],
    "Condition": {
      "Bool": {
        "aws:SecureTransport": "false"
      }
    },
    "Principal": "*"
  }]
}
```

C.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "AllowSSLRequestsOnly",
    "Action": "s3:*",
    "Effect": "Deny",
    "Resource": [
      "arn:aws:s3::DOC-EXAMPLE-BUCKET",
      "arn:aws:s3::DOC-EXAMPLE-BUCKET/*"
    ],
    "Condition": {
      "StringNotEquals": {
        "s3:x-amz-server-side-encryption": "AES256"
      }
    },
    "Principal": "*"
  }]
}
```

D.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "AllowSSLRequestsOnly",
    "Action": "s3:*",
    "Effect": "Deny",
    "Resource": [
      "arn:aws:s3::DOC-EXAMPLE-BUCKET",
      "arn:aws:s3::DOC-EXAMPLE-BUCKET/*"
    ],
    "Condition": {
      "StringNotEquals": {
        "s3:x-amz-server-side-encryption": true
      }
    }
  }],
  "Principal": "*"
}]
}
```

▼ 中文

一家公司有一项指南，要求对所有 Amazon S3 存储桶数据在传输过程中进行加密。一名安全工程师必须实施一个 S3 存储桶策略，**拒绝任何未加密数据的 S3 操作**。

哪个 S3 存储桶策略可以满足此要求？

A.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "AllowSSLRequestsOnly",
    "Action": "s3:*",
    "Effect": "Deny",
    "Resource": [
      "arn:aws:s3::DOC-EXAMPLE-BUCKET",
      "arn:aws:s3::DOC-EXAMPLE-BUCKET/*"
    ],
    "Condition": {
      "Bool": {
        "aws:SecureTransport": "true"
      }
    }
  }],
  "Principal": "*"
}]
}
```

B.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "AllowSSLRequestsOnly",
    "Action": "s3:*",
    "Effect": "Deny",
    "Resource": [
      "arn:aws:s3::DOC-EXAMPLE-BUCKET",
      "arn:aws:s3::DOC-EXAMPLE-BUCKET/*"
    ],
    "Condition": {
      "Bool": {
        "aws:SecureTransport": "false"
      }
    }
  }],
  "Principal": "*"
}]
}
```

C.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "AllowSSLRequestsOnly",
    "Action": "s3:*",
    "Effect": "Deny",
    "Resource": [
      "arn:aws:s3::DOC-EXAMPLE-BUCKET",
      "arn:aws:s3::DOC-EXAMPLE-BUCKET/*"
    ],
    "Condition": {
      "StringNotEquals": {
        "s3:x-amz-server-side-encryption": "AES256"
      }
    },
    "Principal": "*"
  }]
}
```

D.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "AllowSSLRequestsOnly",
    "Action": "s3:*",
    "Effect": "Deny",
    "Resource": [
      "arn:aws:s3::DOC-EXAMPLE-BUCKET",
      "arn:aws:s3::DOC-EXAMPLE-BUCKET/*"
    ],
    "Condition": {
      "StringNotEquals": {
        "s3:x-amz-server-side-encryption": true
      }
    },
    "Principal": "*"
  }]
}
```

▼ 解答

B

1. 考察的知识点

Amazon S3的安全性配置，包括数据加密。
S3 Bucket Policy的使用和语法。
如何强制加密数据传输（如使用HTTPS）。

2. 选项分析

A: 错误。选项A可能没有正确实现强制加密传输的逻辑，或者语法不符合S3 Bucket Policy的要求。
B: 正确。选项B实现了一个S3 Bucket Policy，明确要求所有传输必须使用加密（如HTTPS）。这是符合题目要求的解决方案。
C: 错误。选项C可能遗漏了强制加密的部分，或者没有正确配置条件语句。
D: 错误。选项D可能包含不相关的条件，或者没有完全覆盖题目要求的场景。